République du Cameroun

Université de Yaoundé I

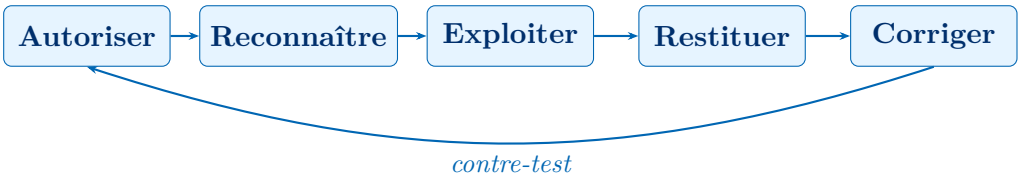
École Nationale Supérieure Polytechnique de Yaoundé

Département de Génie Informatique · Niveau 4

Hacking Éthique II

Autoriser, reconnaître, tester, restituer :
le test d'intrusion au service de la défense

HE2 - UE SEC4062



MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

École Nationale Supérieure Polytechnique de Yaoundé · Université de Yaoundé I

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE SEC4062

AVANT-PROPOS

> « Ce qui distingue le testeur de l'attaquant,
> ce n'est pas l'outil : c'est l'autorisation. »
>
> Principe du cours

Ce cours s'adresse aux élèves ingénieurs de quatrième année du Département de Génie Informatique de l'École Nationale Supérieure Polytechnique de Yaoundé. Il suppose acquis le cours de sécurité informatique (SEC3266), en particulier les réseaux, les identités, les systèmes et les applications, et s'articule avec l'audit des systèmes d'information (INF3226) et l'analyse des risques (GES4062). Il est la seconde partie de l'enseignement du hacking éthique : il approfondit la démarche du test d'intrusion, des règles d'engagement au rapport.

Il repose sur une conviction : on ne défend bien que ce que l'on sait attaquer. Mais il en tire une exigence : chaque technique est enseignée avec son cadre légal, sa détection et sa parade, et uniquement pour des systèmes que l'on est autorisé à tester. Le cours ne fournit pas de code d'attaque prêt à l'emploi ; il apprend à raisonner comme un attaquant pour conseiller un défenseur.

Ce que ce cours n'est pas. Il n'est pas une préparation à une certification, ni un catalogue d'outils, ni une invitation à tester sans mandat. Un test non autorisé est une infraction au Cameroun, même animé par la curiosité : la loi vise expressément l'accès obtenu « par défi intellectuel ».

Ce que ce cours est. Un traité de vingt-six chapitres, en six parties précédées d'un prologue. La Partie I pose le cadre : définitions et métiers, droit camerounais, règles d'engagement, méthodologies. La Partie II apprend à reconnaître : renseignement en sources ouvertes, balayage, analyse des vulnérabilités. La Partie III traite des systèmes et des réseaux, dont l'annuaire Active Directory. La Partie IV porte sur les applications web, les API, le mobile et le nuage. La Partie V va au-delà des systèmes : sans fil, ingénierie sociale, équipe rouge, détection. La Partie VI apprend à restituer : rapport, contre-test, divulgation, laboratoire, mesure.

Un fil rouge. Après la crise de mars (Opération GAROUA, cours SEC3266 et GES4062), LiZbiZ commande un test d'intrusion de son système (Opération LOGONE). La BANQUE SANAGA conduit un exercice d'équipe rouge (Opération MBAM), et l'ANPP fait tester son portail et son API (Opération MEFOU). Les noms, les dates, les adresses et les montants sont fictifs ; les mécanismes sont exacts, et les textes de loi sont cités d'après leur version officielle.

© *MaletYon*

Comment travailler. Lisez chaque chapitre avec sa fiche d'auto-évaluation ; faites les exercices avant de lire leurs corrigés ; pratiquez dans les labs de NDAP SUKULU, qui travaillent sur des pièces et jamais sur des systèmes réels. Pour aller plus loin, construisez votre propre laboratoire isolé (Chapitre 25).

MINKA MI NGUIDJOÏ Thierry Emmanuel
Yaoundé, novembre 2026

MODE D'EMPLOI DU COURS

Structure générale

Le cours compte un prologue et six parties, soit 26 chapitres, pour 60 heures en présentiel réparties en trente séances de deux heures. Les fiches d'auto-évaluation et les dix laboratoires de NDAP SUKULU sont des travaux à faire hors de ces 60 heures.

Partie	Thème	Compétences visées	Niveau
Prologue	La lettre d'autorisation	Lire un mandat, séparer constatation et opinion	★☆☆
I	Le cadre du test	Métiers, droit, règles d'engagement, méthodes	★☆☆
II	Reconnaître	Sources ouvertes, balayage, vulnérabilités	★★☆
III	Systèmes et réseaux	Exploitation, réseau, Active Directory, privilèges, mots de passe	★★☆ à ★★★
IV	Applications et nuage	Web, injections, API, mobile, nuage	★★☆ à ★★★
V	Au-delà des systèmes	Sans fil, ingénierie sociale, équipe rouge, détection	★★★
VI	Restituer et progresser	Rapport, contre-test, divulgation, laboratoire, mesure	★★☆

Les trente séances

© *MaletYon*

Séance	Contenu	Partie
1	Prologue : la lettre d'autorisation	Prologue
2	Le hacking éthique (Ch. 1)	I
3	Le cadre juridique (Ch. 2)	I
4	Règles d'engagement (Ch. 3)	I
5	Méthodologies et référentiels (Ch. 4)	I
6	Reconnaissance passive (Ch. 5)	II
7	Balayage et énumération (Ch. 6)	II
8	Analyser et prioriser (Ch. 7)	II
9	L'exploitation (Ch. 8)	III
10	Attaques réseau (Ch. 9)	III
11–12	Active Directory (Ch. 10)	III
13	Élévation de privilèges (Ch. 11)	III
14	Post-exploitation (Ch. 12)	III
15	Mots de passe (Ch. 13)	III
16–17	Tester une application web (Ch. 14)	IV
18	Injections et contrôle d'accès (Ch. 15)	IV
19	API et mobile (Ch. 16)	IV
20	Nuage et conteneurs (Ch. 17)	IV
21	Sans fil et objets connectés (Ch. 18)	V
22	Ingénierie sociale (Ch. 19)	V
23–24	Équipe rouge et équipe violette (Ch. 20)	V
25	Détection et contournement (Ch. 21)	V
26	Le rapport de test (Ch. 22)	VI
27	Contre-test (Ch. 23)	VI
28	Divulgation coordonnée (Ch. 24)	VI
29	Le laboratoire (Ch. 25)	VI
30	Mesurer ; synthèse (Ch. 26)	VI

Les encadrés

Définition

Définition. Introduit un terme avec sa définition ; les termes définis sont indexés et repris dans le glossaire (Annexe A).

Scénario Opérationnel · Titre du scénario

Scénario opérationnel. Un épisode d'une des opérations du cours : LOGONE (test d'intrusion de LiZbiZ), MBAM (équipe rouge de la BANQUE SANAGA), MEFOU (portail et API de l'ANPP).

Fiche de constat · T-xx · Intitulé

Fiche de constat. Présente un constat de test sous une forme constante : description, preuve, gravité, impact, recommandation, détection.

Procédure de test

Procédure de test. Dit, pas à pas, ce qu'il faut faire, dans le cadre d'une autorisation écrite.

Application Pentesteur

Application métier. Traduit le chapitre en gestes concrets pour l'un des métiers visés : pentesteur, auditeur de sécurité, analyste SOC et équipe rouge, RSSI.

Jurisprudence & Droit applicable

Cite un texte de loi d'après sa version officielle, puis en tire la portée pour le testeur.

★ Attention

Violation typique et **règle** : une erreur fréquente, et ce qu'il faut faire à la place.

Exercice

Exercice. Dix par chapitre, gradués en trois niveaux : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert. Les corrigés figurent dans le livret de correction.

Conventions

- Toute technique est présentée pour des systèmes que l'on est autorisé à tester, avec sa détection et sa parade.
- Chaque analyse indique un niveau de confiance : faible, moyenne ou élevée, et reste séparée de la constatation.
- Les adresses IP et les noms de domaine des exemples sont fictifs ou réservés à la documentation.
- Les **termes clés** apparaissent en gras ; les normes s'écrivent **[ISO/IEC 29147]**, les lois camerounaises **Loi n° 2010/012**.

Matériel d'accompagnement

- **Annexes** : glossaire, outils, modèles et procédures, textes juridiques et normatifs, bibliographie commentée, contacts (Annexes A à F).
- **Livret de correction** : corrigés des exercices et des fiches, réservé au formateur.
- **NDAP SUKULU** : fiches d'auto-évaluation et laboratoires, présentés dans la section qui suit.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, ***ndap sukulu*** désigne la salle de classe et ***malet yon*** signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions, des pièces à examiner et une correction immédiate. Il est édité par **MaletYon**, « ton enseignant », et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- **Une fiche d'auto-évaluation par chapitre.** Chaque fiche puise vingt questions dans une banque de quarante (QCM, vrai ou faux, textes à trous). Elle dure trente minutes ; la copie validée est verrouillée et notée aussitôt. Le seuil de réussite est de 60 %.
- **Des laboratoires pratiques.** Chaque lab place l'étudiant devant les pièces d'une affaire du fil rouge (tableurs, journaux, contrats, procès-verbaux) dans un bureau d'analyste virtuel, ouvert dans le navigateur. Il dure soixante minutes, se termine par des points de contrôle notés automatiquement et renvoie aux sections du livre qu'il mobilise.

© MaletYon

➢ **Un suivi pour l'enseignant** : rapport de classe, notes par fiche et par lab, journal d'activité.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

Comment y travailler

1. Se connecter au portail NDAP SUKULU avec ses identifiants et le code de cours **SEC4062**.
2. Pour un lab, commencer par vérifier l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.txt`), puis travailler sur la copie du dossier `travail` : les pièces originales sont en lecture seule et l'activité est journalisée, comme dans une vraie mission.
3. Lire le rappel de cours affiché par le lab et relire les sections citées avant de répondre.

Note

Si le portail n'est pas encore ouvert. En attendant le déploiement de NDAP SUKULU, les fiches de questions sont fournies au format texte dans le dossier `fiches` du cours, prêtes à être distribuées. Les corrections des fiches figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte dix laboratoires, disponibles sous le code SEC4062. Ils travaillent tous sur des pièces (relevés, journaux, exports, résultats de balayage) et jamais sur un système réel : ils entraînent le raisonnement du testeur et du défenseur, pas le geste d'attaque.

Lab	Sujet	Chapitre	Opération
HE2-LAB-01	Périmètre : trier les cibles autorisées	3	LOGONE
HE2-LAB-02	OSINT : sous-domaines et exposition	5	LOGONE
HE2-LAB-03	Lire un résultat de balayage	6	LOGONE
HE2-LAB-04	Prioriser des vulnérabilités	7	LOGONE
HE2-LAB-05	Active Directory : chemins vers les administrateurs	10	LOGONE
HE2-LAB-06	Élévation de privilèges Linux : relevé	11	LOGONE
HE2-LAB-07	Audit de mots de passe	13	LOGONE
HE2-LAB-08	Historique HTTP : contrôle d'accès et injection	15	MEFOU
HE2-LAB-09	Équipe violette : couverture de détection	20	MBAM
HE2-LAB-10	Rapport : calculer les scores CVSS	22	LOGONE

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi du cours v

NDAP SUKULU, la salle de classe compagnon ix

Prologue Opérationnel 3

0 Prologue : la Lettre d'Autorisation 3

0.1 Pourquoi un Test, et Pourquoi Maintenant . . . 4
0.2 La Lettre d'Autorisation . . . 5
0.3 Douze Jours de Test . . . 5
0.4 Ce que le Test a Montré . . . 6
0.5 Les Questions du Cours . . . 7

I Le Cadre du Test 11

1 Le Hacking Éthique : Définitions, Métiers, Types de Tests 13

1.1 Définir . . . 14
1.2 Les Types d'Évaluation Offensive . . . 14
1.3 Approches et Points de Départ . . . 15
1.4 Les Métiers . . . 15
1.5 Valeur et Limites d'un Test . . . 16

2 Le Cadre Juridique Camerounais 19

2.1 Les Infractions qui Concernent le Testeur . . . 20
2.2 L'Autorisation . . . 20
2.3 Les Données, les Tiers, les Outils . . . 21
2.4 Les Réflexes du Testeur . . . 22

3 Règles d'Engagement et Éthique de la Mission 25

3.1 Les Règles d'Engagement . . . 26
3.2 Le Périmètre . . . 26
3.3 Communiquer et S'Arrêter . . . 27
3.4 Données et Découvertes Fortuites . . . 27
3.5 La Déontologie du Testeur . . . 28

© *MaletYon*

4 Méthodologies et Référentiels **31**

4.1 Les Phases d'un Test . . . 32
4.2 Les Guides Spécialisés . . . 32
4.3 Décrire l'Attaquant : ATT&CK . . . 32
4.4 Coter la Gravité : CVSS . . . 33
4.5 Le Journal de Mission . . . 34

II Reconnaître **37**

5 Reconnaissance Passive et OSINT **39**

5.1 Passive ou Active . . . 40
5.2 Les Sources Ouvertes . . . 40
5.3 La Surface d'Attaque Externe . . . 41
5.4 Les Limites de la Collecte . . . 41
5.5 Réduire l'Exposition . . . 41

6 Balayage et Énumération **45**

6.1 Découvrir les Hôtes . . . 46
6.2 Balayer les Ports . . . 46
6.3 Identifier les Services . . . 46
6.4 Balayer sans Nuire . . . 47
6.5 Ce que Voit le Défenseur . . . 47

7 Analyser et Prioriser les Vulnérabilités **51**

7.1 Les Scanners de Vulnérabilités . . . 52
7.2 Vérifier : Faux Positifs et Faux Négatifs . . . 52
7.3 CVE et Catalogues . . . 52
7.4 Prioriser . . . 53
7.5 Présenter . . . 53

III Systèmes et Réseaux **57**

8 L'Exploitation : Principes et Cadres **59**

8.1 Le Vocabulaire de l'Exploitation . . . 60
8.2 Démontrer ou Non . . . 60
8.3 Le Risque pour la Production . . . 61
8.4 Les Cadres d'Exploitation . . . 61
8.5 La Preuve Minimale . . . 61

9 Attaques Réseau et Authentification **65**

9.1 NTLM et Kerberos . . . 66

9.2 L'Empoisonnement des Résolutions Locales . . . 66
9.3 Le Relais d'Authentification . . . 66
9.4 Détecter et Corriger . . . 67

10 Active Directory 71

10.1 L'Annuaire et ses Privilèges . . . 72
10.2 Kerberos en Bref . . . 72
10.3 Le Kerberoasting . . . 73
10.4 L'AS-REP Roasting . . . 73
10.5 Les Chemins d'Attaque . . . 73
10.6 Le Modèle par Niveaux et les Défenses . . . 74

11 Élévation de Privilèges 79

11.1 Vertical et Horizontal . . . 80
11.2 Les Vecteurs sous Linux . . . 80
11.3 Les Vecteurs sous Windows . . . 80
11.4 Lire un Relevé . . . 81
11.5 Corriger et Détecter . . . 81

12 Post-Exploitation, Mouvement Latéral, Persistance 85

12.1 Les Objectifs de la Post-Exploitation . . . 86
12.2 Le Mouvement Latéral . . . 86
12.3 La Persistance . . . 87
12.4 Les Limites du Testeur . . . 87
12.5 Ce que Voient les Journaux . . . 87

13 Mots de Passe : Attaques et Défenses 91

13.1 En Ligne ou Hors Ligne . . . 92
13.2 Les Attaques . . . 92
13.3 Le Hachage . . . 92
13.4 L'Audit de Mots de Passe . . . 93
13.5 La Politique . . . 94

IV Applications et Nuage 97

14 Tester une Application Web 99

14.1 L'Application vue par le Testeur . . . 100
14.2 Le Guide de Test de l'OWASP . . . 100
14.3 Cartographier . . . 101
14.4 Authentification et Session . . . 101
14.5 Lire un Historique HTTP . . . 102

14.6 Classer selon le Top 10 . . . 102

15 Injections et Contrôle d'Accès 105

15.1 Le Mécanisme de l'Injection . . . 106
15.2 Injection de Requête et Script dans le Navigateur . . . 106
15.3 La Référence Directe à un Objet . . . 106
15.4 Horizontal et Vertical . . . 107
15.5 Tester sans Nuire . . . 107

16 Interfaces de Programmation et Applications Mobiles 111

16.1 L'Interface de Programmation vue par le Testeur . . . 112
16.2 Le Top 10 des API . . . 112
16.3 La Façade Mobile . . . 112
16.4 Tester le Mobile avec le MASVS . . . 113
16.5 L'Opération MEFOU . . . 113

17 Tester le Nuage et les Conteneurs 117

17.1 La Responsabilité Partagée . . . 118
17.2 Les Erreurs de Configuration . . . 118
17.3 Secrets et Droits . . . 118
17.4 Conteneurs et Orchestration . . . 118
17.5 Tester dans les Limites du Contrat . . . 119

V Au-delà des Systèmes 123

18 Sans-Fil et Objets Connectés 125

18.1 Les Faiblesses du Sans-Fil . . . 126
18.2 Point d'Accès Pirate et Portail Jumeau . . . 126
18.3 Les Objets Connectés . . . 126
18.4 Tester Légalement . . . 127

19 Ingénierie Sociale 131

19.1 Les Leviers de l'Ingénierie Sociale . . . 132
19.2 Les Formes d'Hameçonnage . . . 132
19.3 Une Campagne Éthique . . . 132
19.4 Mesurer sans Stigmatiser . . . 133
19.5 Les Parades . . . 133

20 Équipe Rouge et Équipe Violette 137

20.1 Trois Exercices Distincts . . . 138
20.2 L'Exercice par Objectifs . . . 138
20.3 Le Scénario Fondé sur une Menace . . . 138

20.4 Mesurer la Détection . . . 139
20.5 L'Équipe Violette . . . 139
20.6 L'Opération MBAM . . . 139

21 Se Faire Détecter : le Point de Vue du Défenseur 143

21.1 Voir Chaque Étape . . . 144
21.2 Des Techniques aux Traces . . . 144
21.3 La Matrice de Couverture . . . 144
21.4 Écrire une Règle . . . 145
21.5 Le Testeur, Allié du Défenseur . . . 145

VI Restituer et Progresser 149

22 Le Rapport de Test d'Intrusion 151

22.1 La Structure du Rapport . . . 152
22.2 Deux Lecteurs, Deux Niveaux . . . 152
22.3 Coter et Hiérarchiser . . . 152
22.4 L'Anatomie d'un Constat . . . 153
22.5 Les 14 Constats de LOGONE . . . 153

23 Le Contre-Test 157

23.1 Qu'est-ce qu'un Contre-Test . . . 158
23.2 Fond ou Palliatif . . . 158
23.3 L'État des Constats . . . 158
23.4 Clore la Mission . . . 159

24 La Divulgation Coordonnée 161

24.1 Trois Façons de Divulguer . . . 162
24.2 Le Processus Coordonné . . . 162
24.3 Les Normes 29147 et 30111 . . . 163
24.4 Le Cadre Juridique . . . 163
24.5 Rédiger un Signalement . . . 163

25 Le Laboratoire et la Pratique Continue 167

25.1 Pourquoi un Laboratoire Fermé . . . 168
25.2 Monter son Laboratoire . . . 168
25.3 Plateformes et Épreuves . . . 168
25.4 Entretenir ses Compétences . . . 169
25.5 La Plateforme NDAP SUKULU . . . 169

26 Mesurer la Sécurité Offensive 171

26.1 Ce que Mesure un Test . . . 172

26.2 Des Indicateurs Honnêtes 172
26.3 Le Verdict à Trois Valeurs 172
26.4 Les Indicateurs Trompeurs 173
26.5 Le Cycle d'Amélioration 173

A Glossaire **177**

B Référentiel des Outils **181**

C Modèles et Procédures **183**

D Textes Juridiques et Normatifs **185**

E Bibliographie Commentée **187**

F Contacts et Ressources **189**

Références bibliographiques **191**

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

PROLOGUE : LA LETTRE D'AUTORISATION

> « Sans lettre d'autorisation, le meilleur test d'intrusion est une infraction. »
>
> Principe du cours

Niveau : *Fondamental* • Cours SEC3266 (Sécurité informatique).

✦ Objectifs du chapitre

- ➢ Lire un mandat de test d'intrusion et en repérer les éléments essentiels.
- ➢ Situer le test dans la vie d'une organisation : après une crise, après un audit, avant une décision.
- ➢ Distinguer ce que le test prouve de ce qu'il ne prouve pas.
- ➢ Séparer constatations, suppositions et opinions dans un résultat de test.
- ➢ Formuler les questions auxquelles le cours répond.

Question directrice : que faut-il signer avant de toucher un seul système ?

Le 12 octobre 2026, M. ETEME signe la lettre qui autorise le cabinet NYONG SÉCURITÉ à attaquer le système d'information de LiZbiZ. Sept mois plus tôt, un attaquant avait fait la même chose sans demander la permission (Opération GAROUA). Cette fois, tout est écrit : qui teste, quoi, quand, comment, et qui appeler si quelque chose tourne mal. Ce prologue suit la mission, appelée Opération LOGONE, de la signature au rapport.

Plan du chapitre.

1. Pourquoi un test, et pourquoi maintenant (section 0.1).
2. La lettre d'autorisation (section 0.2).
3. Douze jours de test (section 0.3).
4. Ce que le test a montré (section 0.4).

© *MaletYon*

5. Les questions du cours (section 0.5).

0.1 Pourquoi un Test, et Pourquoi Maintenant

LiZbiZ[1] a beaucoup changé depuis mars : second facteur sur la passerelle, bastion, sauvegardes immuables, registre des risques, audit d'octobre. Le comité des risques veut savoir si ces mesures résistent à un attaquant réel, et non seulement à une liste de vérification. Il commande un **test d'intrusion** : une attaque autorisée, bornée et restituée.

Acteur	Rôle dans l'Opération LOGONE
M. ETEME	Directeur général de LiZbiZ, signataire de la lettre d'autorisation
M. KOUNOU	Responsable informatique, contact technique d'urgence
Mme MOUAFO	Gestionnaire des risques, commanditaire opérationnelle
M. BIKORO	Chef de mission, NYONG SÉCURITÉ
Mme NGO MBOCK	Pentesteuse, tests internes et Active Directory
M. TAMO	Analyste, tests web et ingénierie sociale

Tableau 0.1. Les acteurs de l'Opération LOGONE

0.2 La Lettre d'Autorisation

[1] LiZbiZ, NYONG SÉCURITÉ, la BANQUE SANAGA, l'ANPP et leurs personnels sont fictifs, comme les dates, les adresses et les montants du cours ; les techniques, les normes et les textes de loi cités sont réels.

Rubrique	Contenu de la lettre du 12 octobre
Parties	LiZbiZ SA (M. ETEME) et NYONG SÉCURITÉ (M. BIKORO)
Objectif	Vérifier qu'un attaquant externe ou interne ne peut pas obtenir les droits d'administrateur du domaine ni lire la base des clients
Périmètre externe	Plage 198.51.100.0/27 et domaine lizbiz.cm
Périmètre interne	Réseaux de Douala (10.10.0.0/16) et de Garoua (10.20.0.0/16), sauf 10.10.50.0/24 (paie, hébergée pour un tiers)
Exclusions	Déni de service ; système de paie ; intrusion physique
Ingénierie sociale	Courriels d'hameçonnage simulés à 60 adresses validées par la direction des ressources humaines
Fenêtre	Du 19 au 30 octobre ; tests internes de 8 h à 18 h, sauf accord écrit
Contacts d'urgence	M. KOUNOU et M. BIKORO, joignables jour et nuit ; mot d'arrêt convenu
Données	Aucune copie de données personnelles ; preuves masquées ; destruction à la remise du rapport

Tableau 0.2. Extrait de la lettre d'autorisation de l'Opération LOGONE

★ Attention

Violation typique. Tester une adresse « voisine » du périmètre parce qu'elle semble appartenir au client.

Règle : seul ce qui est écrit est autorisé. Le réseau de la paie, hébergé pour un tiers, n'appartient pas au signataire : le tester, même par erreur, serait un accès non autorisé (Chapitre 2).

0.3 Douze Jours de Test

Dates	Activité
19–20 oct.	Reconnaissance externe : sources ouvertes, sous-domaines, services exposés
21–22 oct.	Tests externes : passerelle, portail de suivi, messagerie
23 oct.	Campagne d'hameçonnage simulée
26–28 oct.	Tests internes depuis un poste fourni : balayage, Active Directory, partages
29 oct.	Démonstration du chemin vers les administrateurs du domaine ; arrêt des tests
30 oct.	Réunion de restitution à chaud

Tableau 0.3. Le calendrier de l'Opération LOGONE

0.4 Ce que le Test a Montré

Scénario Opérationnel · Opération LOGONE. La restitution du 30 octobre

Constatations.

- Externe : la passerelle exige bien un second facteur ; aucun accès obtenu depuis Internet.
- Hameçonnage : 14 clics sur 60 destinataires, 5 saisies de mot de passe, 9 signalements au support.
- Interne : en 5 heures, depuis un poste ordinaire, Mme NGO MBOCK obtient les droits d'administrateur du domaine en exploitant le mot de passe faible d'un compte de service.
- Détection : le centre de surveillance de nuit signale le balayage interne en 40 minutes, mais ne voit pas l'obtention des droits.
- Bilan : 14 constats, dont 2 critiques, 4 élevés, 5 moyens et 3 faibles.

Analyse (confiance élevée). La porte d'entrée de mars est fermée ; la maison, elle, reste ouverte à qui y entre. Le test ne prouve pas qu'aucune autre voie n'existe : il prouve que celle-ci existait, à cette date, dans ce périmètre.

Application Pentesteur

Arrêter quand l'objectif est démontré. Mme NGO MBOCK s'arrête dès qu'elle obtient les droits : elle capture la preuve (une capture d'écran du groupe, sans données), prévient M. BIKORO, qui prévient M. KOUNOU. Aller plus loin n'apporterait rien et créerait un risque.

Application RSSI

Commander un test pour décider. Le RSSI commande un test avec une question précise (« peut-on devenir administrateur du domaine ? »), et non pour obtenir une note. Le rapport doit l'aider à décider où investir.

0.5 Les Questions du Cours

Partie	Question posée par l'Opération LOGONE	Chapitres
I. Cadre	Qu'est-ce qui rend ce test légal et utile ?	1 à 4
II. Reconnaître	Qu'a-t-on appris sans toucher aux systèmes ?	5 à 7
III. Systèmes	Comment un compte de service mène-t-il au domaine ?	8 à 13
IV. Applications	Le portail et l'API sont-ils sûrs ?	14 à 17
V. Au-delà	Les personnes et le SOC tiennent-ils ?	18 à 21
VI. Restituer	Comment écrire, corriger, vérifier, mesurer ?	22 à 26

Tableau 0.4. Les questions du cours

❍

★ **À retenir**

Ce qu'il faut retenir de ce chapitre :

- ➢ **Un test d'intrusion** est une attaque autorisée, bornée et restituée.
- ➢ **La lettre d'autorisation** fixe parties, objectif, périmètre, exclusions, fenêtre, contacts et traitement des données.
- ➢ **Seul ce qui est écrit est autorisé** ; un tiers non signataire est hors périmètre.
- ➢ **On s'arrête** quand l'objectif est démontré.
- ➢ **Un test prouve** l'existence d'une voie, pas l'absence d'autres voies.

● **Note**

Points de contrôle de l'élève. Je sais : énumérer les rubriques d'une lettre d'autorisation ; repérer une cible hors périmètre ; résumer les résultats de l'Opération LOGONE ; dire ce qu'un test prouve et ne prouve pas.

✍ **Exercice 0.1. Le taux** ★☆☆

Calculez le taux de clics, de saisies et de signalements de la campagne d'hameçonnage.

✍ **Exercice 0.2. Hors périmètre** ★☆☆

Les adresses 10.10.50.12, 10.20.3.50 et 198.51.100.40 sont-elles dans le périmètre de la lettre ? Justifiez.

✍ Exercice 0.3. Les registres ★☆☆

Classez en constatation, supposition ou opinion : « le SOC est incompétent » ; « le balayage a été signalé en 40 minutes » ; « un attaquant réel aurait été plus discret ».

✍ Exercice 0.4. Prouver ★★☆

Pourquoi le test ne prouve-t-il pas que LiZbiZ est sûre depuis Internet ? Que peut-on en dire honnêtement ?

✍ Exercice 0.5. L'arrêt ★★☆

Mme NGO MBOCK aurait pu lire la base des clients après avoir obtenu les droits. Pourquoi s'arrête-t-elle ? Quelle preuve garde-t-elle ?

✍ Exercice 0.6. Le tiers ★★☆

Le système de paie est hébergé par LiZbiZ pour un tiers. Que faudrait-il pour l'inclure dans un prochain test ?

✍ Exercice 0.7. Les données ★★☆

Pourquoi la lettre interdit-elle de copier des données personnelles ? Quels risques courrait le cabinet sans cette clause ?

✍ Exercice 0.8. La détection ★★☆

Le SOC a vu le balayage mais pas l'obtention des droits. Qu'en concluez-vous pour ses règles de détection ?

✍ Exercice 0.9. Une lettre ★★★

Rédigez la lettre d'autorisation complète de l'Opération LOGONE, à partir du Tableau 0.2.

✍ Exercice 0.10. La question ★★★

Proposez trois questions précises que la BANQUE SANAGA pourrait poser à un test d'intrusion, et pour chacune le périmètre nécessaire.

● Note

Pour aller plus loin.

- NIST SP 800-115 [21].
- Loi n° 2010/012, articles 65 et suivants [12].

Note

Transition. Avant les techniques, les mots et les métiers. Le Chapitre 1 définit le hacking éthique et les types de tests.

partie I

Le Cadre du Test

© *MaletYon*

1

LE HACKING ÉTHIQUE : DÉFINITIONS, MÉTIERS, TYPES DE TESTS

« Le testeur et l'attaquant connaissent les mêmes techniques ; seul le premier rend compte de ce qu'il a fait. »

Principe du cours

Niveau : *Fondamental* • Prologue ; cours SEC3266.

✦ Objectifs du chapitre

- ➢ Définir le hacking éthique et le test d'intrusion.
- ➢ Distinguer test d'intrusion, analyse de vulnérabilités, audit, équipe rouge et programme de primes.
- ➢ Choisir une approche (boîte noire, grise, blanche) et un point de départ (externe, interne, présumé compromis).
- ➢ Décrire les métiers de la sécurité offensive et leurs compétences.
- ➢ Situer la valeur et les limites d'un test.

Question directrice : de quoi LiZbiZ avait-elle besoin : un balayage, un audit ou un test d'intrusion ?

En septembre, M. KOUNOU propose d'acheter un scanner de vulnérabilités ; Mme NKENG rappelle que l'audit d'octobre est prévu ; Mme MOUAFO veut savoir si un attaquant peut encore devenir administrateur du domaine. Trois besoins, trois réponses différentes. Ce chapitre apprend à choisir.

Plan du chapitre.

1. Définir (section 1.1).
2. Les types d'évaluation offensive (section 1.2).
3. Approches et points de départ (section 1.3).
4. Les métiers (section 1.4).

© *MaletYon*

5. Valeur et limites d'un test (section 1.5).

1.1 Définir

Définition

Hacking éthique : emploi des techniques des attaquants, avec l'autorisation écrite du propriétaire du système, dans un périmètre et une durée fixés, pour en révéler les faiblesses et aider à les corriger. **Test d'intrusion** : évaluation dans laquelle le testeur imite un attaquant réel pour contourner les mesures de sécurité et démontrer l'impact d'une compromission [21].

Trois conditions font le caractère éthique : l'*autorisation* (écrite, par qui a le pouvoir de la donner), la *limitation* (périmètre, méthodes, fenêtre) et la *restitution* (tout ce qui est trouvé est rapporté au client, et à lui seul). Sans l'une d'elles, le même geste devient une infraction ou une faute professionnelle.

1.2 Les Types d'Évaluation Offensive

Type	Question	Livrable
Analyse de vulnérabilités	Quelles failles connues sont présentes ?	Liste priorisée, souvent automatique
Test d'intrusion	Jusqu'où un attaquant peut-il aller ?	Chemins d'attaque démontrés, constats, recommandations
Audit de sécurité	Les mesures sont-elles conformes à un référentiel ?	Constats d'écarts (cours INF3226)
Exercice d'équipe rouge	Détecte-t-on et répond-on à un adversaire réaliste ?	Scénario, détections, délais
Programme de primes	Des chercheurs externes trouvent-ils des failles ?	Rapports de chercheurs, rémunérés selon la gravité

Tableau 1.1. Les évaluations offensives

Les CIS Controls consacrent leur contrôle 18 aux tests d'intrusion : ils s'adressent aux organisations qui ont déjà mis en place les mesures de base ; tester avant d'avoir inventorié et corrigé n'apprend rien que le balayage n'aurait dit [2].

1.3 Approches et Points de Départ

Approche	Ce que sait le testeur	Intérêt
Boîte noire	Rien, sauf le périmètre	Imite l'attaquant externe ; coûteuse en temps
Boîte grise	Un compte, des plans partiels	Bon compromis, le plus fréquent
Boîte blanche	Code, configurations, schémas	Couverture maximale

Tableau 1.2. Les approches

Le **point de départ** compte autant : *externe* (depuis Internet), *interne* (depuis un poste du réseau) ou *présumé compromis* (on suppose qu'un poste est déjà aux mains de l'attaquant, comme après l'hameçonnage de février). Ce dernier scénario, dit d'*intrusion présumée*, mesure la défense en profondeur.

Scénario Opérationnel · Opération LOGONE. Le choix de l'approche

Décision (septembre). Boîte grise : un compte d'utilisateur ordinaire et un poste fourni pour l'interne ; les schémas réseau sont communiqués. Deux points de départ : externe, et intrusion présumée.

Analyse (confiance élevée). La boîte noire aurait consacré des jours à retrouver ce que LiZbiZ sait déjà ; l'intrusion présumée répond à la vraie question : que se passe-t-il quand le prochain hameçonnage réussit ?

1.4 Les Métiers

Métier	Activité
Pentesteur	Conduit les tests, démontre les chemins d'attaque, rédige les constats
Auditeur de sécurité	Vérifie la conformité aux référentiels, peut intégrer des tests techniques
Analyste SOC et équipe rouge	L'un détecte et répond, l'autre émule l'adversaire ; ensemble, ils forment l'équipe violette
RSSI	Commande, cadre, arbitre les corrections, rend compte à la direction

Tableau 1.3. Les métiers visés par le cours

Application Pentesteur

Trois compétences au même niveau. La technique (systèmes, réseaux, applications), la méthode (périmètre, traçabilité, arrêt) et l'écrit (un constat qu'un directeur

comprend et qu'un administrateur sait corriger).

1.5 Valeur et Limites d'un Test

★ Attention

Violation typique. Présenter un test sans constat critique comme une preuve de sécurité.

Règle : un test est borné dans le temps, le périmètre et les méthodes ; il prouve l'existence des failles trouvées, pas l'absence des autres. Le rapport dit ce qui n'a pas été testé.

Fiche de constat · T-00 · Modèle de fiche de constat

Description : ce qui a été trouvé, en une phrase. **Preuve :** la trace (capture, requête, horodatage), sans données sensibles. **Gravité :** score CVSS et contexte. **Impact :** ce qu'un attaquant pourrait faire. **Recommandation :** la correction et sa vérification. **Détection :** ce qui aurait dû alerter.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Hacking éthique** : autorisation, limitation, restitution.
- **Cinq évaluations offensives** répondent à des questions différentes.
- **Boîte noire, grise, blanche** ; départ externe, interne ou présumé compromis.
- **Quatre métiers** ; l'équipe violette réunit attaque et défense.
- **Un test** prouve l'existence d'une faille, pas l'absence des autres.

● Note

Points de contrôle de l'élève. Je sais : définir le hacking éthique et le test d'intrusion ; choisir un type d'évaluation pour une question donnée ; choisir une approche et un point de départ ; décrire les métiers ; énoncer les limites d'un test.

✍ Exercice 1.1. Quel type ? ★☆☆

Quel type d'évaluation répond à : « nos serveurs ont-ils des correctifs en retard ? » ; « notre SOC verrait-il un attaquant ? » ; « sommes-nous conformes à l'ISO/IEC 27001 ? »

✍ Exercice 1.2. Les trois conditions ★☆☆

Un étudiant teste le site de son école « pour l'aider ». Quelles conditions du hacking éthique manquent ?

✍ Exercice 1.3. Approche ★☆☆

Quelle approche choisir pour l'ANPP, qui fournit le code de son portail ?

✍ Exercice 1.4. Intrusion présumée ★★☆

Expliquez en quoi le point de départ « présumé compromis » répond mieux à la question de LiZbiZ qu'un test externe seul.

✍ Exercice 1.5. Contrôle 18 ★★☆

Pourquoi les CIS Controls placent-ils les tests d'intrusion en dernier ? Que doit faire une organisation avant ?

✍ Exercice 1.6. Violette ★★☆

Qu'apporte une équipe violette par rapport à un test d'intrusion classique ?

✍ Exercice 1.7. Primes ★★☆

Quels prérequis une organisation doit-elle réunir avant d'ouvrir un programme de primes aux failles ?

✍ Exercice 1.8. Limites ★★☆

Rédigez le paragraphe « limites » du rapport de l'Opération LOGONE.

✍ Exercice 1.9. Un programme ★★★

Proposez à la BANQUE SANAGA un programme d'évaluations offensives sur deux ans, en combinant les types du Tableau 1.1.

✍ Exercice 1.10. Le profil ★★★

Rédigez la fiche de poste d'un pentesteur junior pour NYONG SÉCURITÉ : missions, compétences, éthique, progression.

● Note

Pour aller plus loin.

➢ NIST SP 800-115 [21] ; CIS Controls [2].

Note

Transition. L'autorisation n'est pas une formalité : c'est elle que la loi regarde. Le Chapitre 2 présente le droit camerounais.

2

LE CADRE JURIDIQUE CAMEROUNAIS

« La curiosité n'est pas une autorisation. »

Principe du cours

Niveau : *Fondamental* • Chapitre 1 ; cours SEC3266, chapitre sur le droit.

✦ Objectifs du chapitre

- ➢ Citer les infractions de la loi n° 2010/012 qui concernent le testeur.
- ➢ Expliquer pourquoi l'autorisation écrite fait la différence entre un test et une infraction.
- ➢ Identifier qui peut autoriser un test, et qui ne le peut pas.
- ➢ Repérer les risques juridiques propres aux données personnelles, aux tiers et aux outils.
- ➢ Adopter les réflexes qui protègent le testeur et son client.

Question directrice : qu'est-ce qui sépare Mme NGO MBOCK de l'attaquant de mars ?

En mars, un attaquant est entré dans le système de LiZbiZ, s'y est maintenu et a obtenu les droits d'administrateur. En octobre, Mme NGO MBOCK a fait presque la même chose. Les gestes se ressemblent ; les qualifications juridiques sont opposées. La différence tient en une feuille signée. Ce chapitre en explique la portée.

Plan du chapitre.

1. Les infractions qui concernent le testeur (section 2.1).
2. L'autorisation (section 2.2).
3. Les données, les tiers, les outils (section 2.3).
4. Les réflexes du testeur (section 2.4).

© *MaletYon*

2.1 Les Infractions qui Concernent le Testeur

Jurisprudence & Droit applicable

Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun (texte officiel)

Article 65, alinéa 2 : *« Est puni des peines prévues à l'alinéa 1 ci-dessus, tout accès non autorisé, à l'ensemble ou à une partie d'un réseau de communications électroniques ou d'un système d'information ou d'un équipement terminal. »*

Article 65, alinéa 4 : *« Est puni des mêmes peines prévues à l'alinéa 1 ci-dessus, celui qui, sans droit, permet l'accès dans un réseau de communications électroniques ou dans un système d'information par défi intellectuel. »*

Portée. Les peines de l'alinéa 1 sont de cinq à dix ans d'emprisonnement et de 5 à 10 millions de FCFA d'amende, ou l'une de ces deux peines. L'alinéa 4 vise expressément le « défi intellectuel » : la bonne intention ou la curiosité ne justifient pas un accès sans droit.

Article	Comportement visé	Geste de test concerné
65 (1)	Interception de données sans droit ni autorisation	Écoute du réseau, interception d'échanges
65 (2) et (4)	Accès non autorisé ; accès permis par défi intellectuel	Toute connexion à un système hors mandat
66	Perturbation ou interruption du fonctionnement par l'altération des données	Test qui fait tomber un service
68	Accès ou maintien frauduleux avec perturbation grave	Exploitation qui endommage
69	Accès sans droit, en violation des mesures de sécurité, pour obtenir des données	Lecture de données au-delà du nécessaire
70	Attaque par saturation pour faire effondrer une ressource	Test de charge ou de déni de service
71	Introduction de données pour supprimer ou modifier les données	Modification de données de production

Tableau 2.1. Les articles de la loi n° 2010/012 qui concernent le testeur

2.2 L'Autorisation

L'autorisation écrite rend l'accès « autorisé » au sens de l'article 65. Encore faut-il qu'elle émane de la personne qui a le pouvoir de la donner : le propriétaire ou l'exploitant du système, par son représentant habilité.

Qui peut autoriser ?	Commentaire
Le dirigeant de l'organisation	Oui, ou son délégataire désigné par écrit
Le responsable informatique	Seulement s'il a reçu délégation
Un salarié qui « veut savoir »	Non
L'hébergeur ou le fournisseur de nuage	Pour son infrastructure ; le client peut avoir besoin de son accord selon le contrat
Un tiers dont les systèmes sont reliés	Non pour le système du client ; il autorise seulement ses propres systèmes

Tableau 2.2. Le pouvoir d'autoriser

★ Attention

Violation typique. Se contenter d'un accord oral ou d'un courriel d'un technicien.

Règle : l'autorisation est écrite, signée par une personne habilitée, datée, et précise le périmètre et les méthodes. Le testeur en garde une copie sur lui pendant les tests physiques et dans son dossier.

2.3 Les Données, les Tiers, les Outils

● Note

Les données personnelles. Un test peut faire voir des données personnelles (fichier des clients, paie). La loi n° 2024/017 relative à la protection des données à caractère personnel s'applique à leur traitement ; ses articles sont à lire dans le texte publié au Journal officiel. La règle du cours : ne consulter que ce qui prouve la faille, ne rien copier, masquer les preuves, détruire ce qui reste à la fin de la mission.

Risque	Parade
Tiers touché	Vérifier la propriété de chaque adresse avant de tester ; exclure ce qui appartient à d'autres
Interruption de service	Exclure le déni de service ; prévenir avant toute action risquée ; mot d'arrêt
Outils	Utiliser des outils de provenance sûre, sur des postes dédiés ; ne pas diffuser d'outil offensif hors cadre
Preuves	Tracer chaque action (horodatage, adresse source) pour pouvoir prouver ce qui a été fait, et ce qui ne l'a pas été

Tableau 2.3. Risques juridiques et parades

Scénario Opérationnel · Opération LOGONE. L'incident évité

Constatation. Le 26 octobre, M. TAMO s'apprête à balayer la plage 10.10.0.0/16 entière. Mme NGO MBOCK lui rappelle l'exclusion de 10.10.50.0/24 (paie, hébergée pour un tiers). La commande est corrigée avant d'être lancée ; l'incident est consigné.

Analyse (confiance élevée). Le balayage aurait touché un système dont LiZbiZ n'est pas propriétaire : un accès non autorisé au sens de l'article 65, et une faute contractuelle du cabinet.

2.4 Les Réflexes du Testeur

Procédure de test

Avant, pendant, après

1. **Avant** : lettre signée par une personne habilitée ; périmètre vérifié adresse par adresse ; contrat avec clause de responsabilité et assurance du cabinet.
2. **Pendant** : rester dans le périmètre et la fenêtre ; journaliser chaque action ; s'arrêter et prévenir au moindre doute ou incident.
3. **Après** : remettre le rapport au seul client ; détruire les données et les accès créés ; conserver le journal des actions.

Application Auditeur de sécurité

Vérifier le mandat avant le premier geste. L'auditeur qui intègre des tests techniques vérifie lui-même la lettre, le périmètre et le pouvoir du signataire ; il ne se fie pas à ce que lui dit l'audité.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'article 65** réprime l'accès non autorisé, y compris « par défi intellectuel ».
- **Les articles 66 à 71** visent la perturbation, le maintien frauduleux, l'obtention de données, la saturation, la modification.
- **L'autorisation** est écrite, signée par une personne habilitée, précise.
- **Données, tiers, outils, preuves** : quatre risques à maîtriser.
- **Avant, pendant, après** : les réflexes qui protègent le testeur et le client.

Note

Points de contrôle de l'élève. Je sais : citer l'article 65 et ses alinéas 2 et 4 ; relier un geste de test à un article ; dire qui peut autoriser ; énumérer les réflexes avant, pendant et après.

✍ Exercice 2.1. Quel article ? ★☆☆

Quel article vise : un test de charge qui fait tomber un site ; la lecture de données clients au-delà du nécessaire ; un accès « pour voir » ?

✍ Exercice 2.2. Défi intellectuel ★☆☆

Que signifie, pour un étudiant passionné, l'alinéa 4 de l'article 65 ?

✍ Exercice 2.3. Les peines ★☆☆

Quelles sont les peines prévues à l'article 65, alinéa 1 ?

✍ Exercice 2.4. Qui autorise ? ★★☆

Un administrateur de la BANQUE SANAGA vous envoie un courriel « vous pouvez tester notre serveur ». Que faites-vous ?

✍ Exercice 2.5. Le nuage ★★☆

LiZbiZ veut faire tester sa messagerie en ligne. Quelles autorisations faut-il vérifier ?

✍ Exercice 2.6. Les données ★★☆

Pendant un test, vous accédez au fichier des clients. Que faites-vous, étape par étape ?

✍ Exercice 2.7. L'incident évité ★★☆

Rédigez l'entrée du journal de mission sur l'incident évité du 26 octobre.

✍ Exercice 2.8. L'outil ★★☆

Un collègue veut publier sur Internet l'outil qu'il a écrit pendant une mission. Quels risques juridiques et contractuels voyez-vous ?

✍ Exercice 2.9. Le contrat ★★★

Rédigez les clauses juridiques d'un contrat de test d'intrusion : autorisation, responsabilité, assurance, données, confidentialité.

✍ Exercice 2.10. Comparer ★★★

Comparez la situation de l'attaquant de mars et celle de Mme NGO MBOCK au regard des articles 65, 68 et 69 : éléments matériels, autorisation, conséquences.

● Note

Pour aller plus loin.

➢ Loi n° 2010/012 [12] ; loi n° 2024/017 [13].

● Note

Transition. L'autorisation se traduit en règles concrètes : les règles d'engagement, objet du Chapitre 3.

3

RÈGLES D'ENGAGEMENT ET ÉTHIQUE DE LA MISSION

> « Ce qui n'est pas écrit dans les règles d'engagement est interdit. »
>
> Principe du cours

Niveau : *Fondamental* • Chapitres 1 et 2.

✦ Objectifs du chapitre

- ➢ Rédiger les règles d'engagement d'un test.
- ➢ Définir un périmètre vérifiable, adresse par adresse.
- ➢ Organiser la communication et l'arrêt d'urgence.
- ➢ Traiter les données rencontrées et les découvertes fortuites.
- ➢ Appliquer les principes déontologiques du testeur.

Question directrice : que faire quand on trouve, au milieu d'un test, une trace d'attaque réelle ?

Le 27 octobre, Mme NGO MBOCK découvre sur un serveur de Garoua un compte « svc_maj2 » créé le 4 mars : la trace de l'attaquant de l'Opération GAROUA, oubliée lors du nettoyage. Ce n'est pas l'objet du test. Que faire ? Les règles d'engagement le disent, si elles ont été bien écrites.

Plan du chapitre.

1. Les règles d'engagement (section 3.1).
2. Le périmètre (section 3.2).
3. Communiquer et s'arrêter (section 3.3).
4. Données et découvertes fortuites (section 3.4).
5. La déontologie du testeur (section 3.5).

© MaletYon

3.1 Les Règles d'Engagement

Définition

Règles d'engagement : document qui précise, pour une mission de test, ce qui est autorisé, comment, quand, par qui, et ce qu'il faut faire en cas d'incident. Il complète la lettre d'autorisation et la rend opérationnelle.

Rubrique	Contenu
Objectifs	Questions auxquelles le test répond, drapeaux à atteindre
Périmètre	Adresses, domaines, applications, comptes ; exclusions
Méthodes	Autorisées (balayage, exploitation contrôlée, hameçonnage simulé) et interdites (déni de service, destruction)
Fenêtre	Dates, heures, fuseau horaire ; tests de nuit sur accord
Équipe	Noms des testeurs, adresses IP sources, postes utilisés
Communication	Contacts, canal chiffré, points d'avancement
Arrêt	Mot d'arrêt, motifs d'arrêt, reprise
Données	Ce qu'on peut consulter, ce qu'on ne copie jamais, destruction
Découvertes	Conduite à tenir face à une compromission réelle ou à une faille critique

Tableau 3.1. Les rubriques des règles d'engagement

3.2 Le Périmètre

Un périmètre vérifiable se décrit en adresses et en noms précis, avec leur propriétaire. Une plage en notation CIDR (10.20.0.0/16) couvre 65 536 adresses ; une exclusion (10.10.50.0/24) en retire 256. Avant chaque action, le testeur vérifie que la cible est dedans.

Procédure de test

Vérifier qu'une cible est dans le périmètre

1. La cible appartient-elle à une plage ou à un domaine listés ?
2. Appartient-elle à une exclusion ? Si oui, elle est hors périmètre.
3. Le signataire en est-il propriétaire ou exploitant ? (vérifier les registres d'adresses et le contrat d'hébergement)

4. La méthode envisagée est-elle autorisée pour cette cible ?
5. L'heure est-elle dans la fenêtre ?

★ Attention

Violation typique. Suivre un lien ou une redirection vers un domaine non listé (un prestataire de paiement, un fournisseur en nuage).

Règle : un domaine découvert pendant le test n'entre pas dans le périmètre de lui-même. On le note et on demande un avenant écrit.

3.3 Communiquer et S'Arrêter

Situation	Conduite
Service ralenti ou arrêté	Arrêt immédiat, appel du contact d'urgence
Faille critique exploitable depuis Internet	Prévenir le client sans attendre le rapport
Trace d'une compromission réelle	Arrêt du test sur la cible, appel du contact, préservation
Doute sur le périmètre	Ne pas agir ; demander par écrit
Mot d'arrêt prononcé par le client	Arrêt de toutes les actions

Tableau 3.2. Quand prévenir, quand s'arrêter

3.4 Données et Découvertes Fortuites

Scénario Opérationnel · Opération LOGONE. Le compte du 4 mars

Constatation. Le 27 octobre à 10 h 12, Mme NGO MBOCK trouve, membre des administrateurs du domaine, le compte « svc_maj2 », créé le 4 mars à 2 h 04 (cours SEC3266, lab de journaux).

Conduite. Elle s'arrête, ne touche pas au compte, note l'heure et la preuve, appelle M. BIKORO, qui appelle M. KOUNOU à 10 h 25 selon les règles d'engagement. LiZbiZ désactive le compte, ouvre un incident et fait vérifier l'absence d'autre persistance ; le test reprend le lendemain.

Analyse (confiance élevée). La découverte relève de la réponse aux incidents, pas du test. Exploiter ce compte aurait mêlé l'activité de l'attaquant et celle du testeur, et détruit des preuves.

3.5 La Déontologie du Testeur

Principe	Application
Légalité	Rien hors mandat ; rien d'interdit par la loi
Minimisation	Faire le minimum nécessaire pour prouver ; ne pas aller au-delà de l'objectif
Confidentialité	Résultats au seul client ; aucune publication sans accord
Loyauté	Rapporter tout, y compris ses propres erreurs pendant le test
Compétence	Ne pas employer une technique que l'on ne maîtrise pas sur un système de production

Tableau 3.3. Les principes déontologiques du testeur

Fiche de constat · T-15 · Découverte fortuite (hors constats du test)

Description : compte « svc_maj2 » membre des administrateurs du domaine, créé le 4 mars par l'attaquant. **Preuve :** liste des membres du groupe et date de création (capture du 27 octobre, 10 h 12). **Gravité :** critique (accès persistant d'un attaquant). **Recommandation :** désactiver, ouvrir un incident, rechercher toute autre persistance. **Détection :** la revue des comptes à privilèges aurait dû le voir.

Application Analyste SOC et équipe rouge

Distinguer le testeur de l'attaquant. Les règles d'engagement donnent au SOC les adresses sources et les fenêtres du testeur. Toute activité hors de ces adresses ou de ces heures se traite comme une attaque réelle.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Les règles d'engagement** rendent l'autorisation opérationnelle : objectifs, périmètre, méthodes, fenêtre, équipe, communication, arrêt, données, découvertes.
- **Le périmètre** se vérifie adresse par adresse avant chaque action.
- **On s'arrête et on prévient** en cas d'incident, de faille critique ou de doute.
- **Une compromission réelle** découverte relève de la réponse aux incidents.
- **Légalité, minimisation, confidentialité, loyauté, compétence.**

Note

Points de contrôle de l'élève. Je sais : rédiger des règles d'engagement ; vérifier qu'une cible est dans le périmètre ; dire quand s'arrêter et qui prévenir ; traiter une découverte fortuite ; appliquer les principes déontologiques.

Exercice 3.1. CIDR ★☆☆

Combien d'adresses comptent 198.51.100.0/27 et 10.10.50.0/24 ? L'adresse 198.51.100.40 est-elle dans la première plage ?

Exercice 3.2. Les rubriques ★☆☆

Quelle rubrique des règles d'engagement répond à : « puis-je tester à 22 h ? » ; « que faire si le site tombe ? » ; « puis-je copier un fichier pour preuve ? »

Exercice 3.3. Redirection ★☆☆

Le portail de suivi redirige vers « paiement.exemple-prestataire.cm ». Pouvez-vous le tester ? Que faites-vous ?

Exercice 3.4. Faille critique ★★☆

Vous découvrez le premier jour une faille critique exploitable depuis Internet. Attendez-vous le rapport final ? Rédigez le message au client.

Exercice 3.5. Le SOC ★★☆

Faut-il prévenir le SOC d'un test ? Comparez les avantages d'un test annoncé et d'un test non annoncé.

Exercice 3.6. Minimisation ★★☆

Donnez trois exemples de gestes qui dépassent le minimum nécessaire pour prouver une faille.

Exercice 3.7. Sa propre erreur ★★☆

Un testeur a supprimé par erreur un fichier de configuration. Que dit le principe de loyauté ? Que doit-il faire ?

Exercice 3.8. Mot d'arrêt ★★☆

Proposez la procédure d'arrêt et de reprise d'un test, avec ses responsables.

✍ Exercice 3.9. Des règles complètes ★★★

Rédigez les règles d'engagement de l'Opération MEFOU (portail et API de l'ANPP), selon les rubriques du Tableau 3.1.

✍ Exercice 3.10. Le dilemme ★★★

Pendant un test, vous trouvez la preuve qu'un salarié détourne des fonds. Analysez la situation selon la méthode de résolution d'un dilemme (cours SEC3266) et dites ce que vous faites.

Note

Pour aller plus loin.

- NIST SP 800-115, planification [21].
- PTES, phase de pré-engagement [20].

Note

Transition. Le cadre posé, il faut une méthode pour conduire le test : le Chapitre 4 présente les méthodologies et les référentiels.

4

MÉTHODOLOGIES ET RÉFÉRENTIELS

« Une méthode ne remplace pas le talent ;
elle empêche d'oublier ce que le talent n'a pas vu. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 1 à 3.

✦ Objectifs du chapitre

- ➢ Décrire les phases d'un test selon le NIST SP 800-115 et le PTES.
- ➢ Situer l'OSSTMM, l'OWASP WSTG et les autres guides.
- ➢ Utiliser MITRE ATT&CK pour décrire un comportement d'attaquant.
- ➢ Exprimer la gravité d'une faille par le CVSS.
- ➢ Tenir le journal de mission qui rend un test reproductible.

Question directrice : comment être sûr de ne rien avoir oublié ?

Au premier jour, M. BIKORO remet à son équipe une liste de vérification fondée sur des référentiels publics, et un journal de mission vierge. Chaque test y sera noté. Quand LiZbiZ demandera « avez-vous testé la messagerie ? », la réponse sera écrite, avec l'heure.

Plan du chapitre.

1. Les phases d'un test (section 4.1).
2. Les guides spécialisés (section 4.2).
3. Décrire l'attaquant : ATT&CK (section 4.3).
4. Coter la gravité : CVSS (section 4.4).
5. Le journal de mission (section 4.5).

© MaletYon

4.1 Les Phases d'un Test

Phase	NIST SP 800-115	PTES
Préparer	Planification	Pré-engagement
Reconnaître	Découverte	Collecte de renseignements, modélisation des menaces
Analyser	Découverte (vulnérabilités)	Analyse des vulnérabilités
Exploiter	Attaque	Exploitation, post-exploitation
Restituer	Rapport	Rapport

Tableau 4.1. Les phases d'un test (d'après le NIST SP 800-115 et le PTES)

Le NIST SP 800-115 décrit les techniques de test et d'évaluation de la sécurité de l'information [21]. Le PTES (*Penetration Testing Execution Standard*) détaille sept phases, du pré-engagement au rapport [20]. Les phases ne sont pas strictement successives : une découverte en exploitation relance la reconnaissance.

4.2 Les Guides Spécialisés

Référentiel	Apport
OSSTMM (ISECOM)	Méthode de mesure de la sécurité opérationnelle, avec des métriques de surface d'attaque [8]
OWASP WSTG	Guide de test des applications web, scénario par scénario [16]
OWASP MASTG et MASVS	Test et exigences des applications mobiles
NIST SP 800-115	Cadre général, techniques, rapport

Tableau 4.2. Guides de test

4.3 Décrire l'Attaquant : ATT&CK

Définition

MITRE ATT&CK : base de connaissances publique, fondée sur des observations réelles, qui décrit les tactiques (le but de l'attaquant à une étape) et les techniques (la manière de l'atteindre) des adversaires [24].

Tactique	Exemple dans l'Opération GAROUA
Accès initial	Comptes valides volés par hameçonnage
Exécution	Lancement d'un outil sur le serveur de fichiers
Persistance	Création du compte svc_maj2
Élévation de privilèges	Exploitation d'un serveur non corrigé
Découverte	Balayage du réseau interne
Mouvement latéral	Connexions avec le mot de passe local partagé
Exfiltration	Copie de 40 Go vers un stockage externe
Impact	Chiffrement des serveurs

Tableau 4.3. Quelques tactiques d'ATT&CK appliquées à l'attaque de mars

Décrire un test en techniques ATT&CK permet au SOC de vérifier, technique par technique, s'il aurait détecté chaque geste (Chapitre 20).

4.4 Coter la Gravité : CVSS

■ Définition

CVSS (*Common Vulnerability Scoring System*), publié par le FIRST : système qui exprime la gravité technique d'une vulnérabilité par un score de 0 à 10, calculé à partir de métriques (vecteur d'attaque, complexité, privilèges requis, interaction de l'utilisateur, impacts sur la confidentialité, l'intégrité et la disponibilité) [5].

Score	Qualification
0,0	Aucune
0,1 à 3,9	Faible
4,0 à 6,9	Moyenne
7,0 à 8,9	Élevée
9,0 à 10,0	Critique

Tableau 4.4. Les qualifications CVSS

★ Attention

Violation typique. Classer les constats par le seul score CVSS.

Règle : le score dit la gravité technique ; la priorité dépend aussi de l'exposition, de la valeur de l'actif et de l'exploitation connue (Chapitre 7). Le score de base se calcule, le contexte se juge.

4.5 Le Journal de Mission

Procédure de test

Tenir le journal de mission

1. Une ligne par action : heure, testeur, adresse source, cible, outil ou commande, résultat.
2. Les captures et les fichiers de preuve, nommés et horodatés.
3. Les incidents et les arrêts, avec qui a été prévenu.
4. Les tests prévus mais non faits, et pourquoi.
5. Conservation selon le contrat, accès restreint.

Scénario Opérationnel · Opération LOGONE. La question de la messagerie

Constatation. Le 5 novembre, M. KOUNOU demande si la messagerie en ligne a été testée. Le journal répond : test de la configuration (authentification, règles de transfert) le 22 octobre de 9 h 10 à 11 h 40, aucune faille ; pas de test de l'interface d'administration, hors périmètre.

Analyse (confiance élevée). Sans journal, la réponse aurait été un souvenir. Avec lui, c'est une constatation vérifiable.

Application Pentesteur

Écrire au fil de l'eau. Le journal se tient pendant le test, pas le soir. Une action non notée est une action que l'on ne pourra ni expliquer au client, ni défendre en cas d'incident.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- ➢ **Préparer, reconnaître, analyser, exploiter, restituer** : les phases du NIST SP 800-115 et du PTES.
- ➢ **OSSTMM, OWASP WSTG, MASTG** spécialisent la méthode.
- ➢ **ATT&CK** décrit l'attaquant en tactiques et techniques.
- ➢ **Le CVSS** cote la gravité technique ; la priorité y ajoute le contexte.
- ➢ **Le journal de mission** rend le test vérifiable.

Note

Points de contrôle de l'élève. Je sais : nommer les phases d'un test ; choisir un guide spécialisé ; décrire une attaque en tactiques ATT&CK ; qualifier un score CVSS ; tenir un journal de mission.

✍ Exercice 4.1. Les phases ★☆☆

Dans quelle phase se range : la lettre d'autorisation ; le balayage des ports ; la démonstration d'accès aux administrateurs du domaine ?

✍ Exercice 4.2. Qualifier ★☆☆

Qualifiez les scores CVSS 9,8 ; 7,5 ; 5,3 ; 3,1.

✍ Exercice 4.3. Tactiques ★☆☆

Rangez dans les tactiques d'ATT&CK : la suppression des sauvegardes ; la connexion avec le mot de passe du technicien ; la copie de 40 Go.

✍ Exercice 4.4. Le guide ★★☆

Quel guide utiliser pour tester l'API de l'ANPP ? Et son application mobile ?

✍ Exercice 4.5. Le contexte ★★☆

Deux failles ont un score de 8,1 : l'une sur un serveur exposé à Internet, l'autre sur un poste isolé. Laquelle corriger d'abord ? Pourquoi ?

✍ Exercice 4.6. Le journal ★★☆

Rédigez cinq lignes du journal de mission du 26 octobre (tests internes).

✍ Exercice 4.7. Non fait ★★☆

Pourquoi noter les tests prévus mais non faits ? Donnez deux raisons légitimes de ne pas faire un test prévu.

✍ Exercice 4.8. ATT&CK et SOC ★★☆

Comment la description d'un test en techniques ATT&CK aide-t-elle le SOC à s'améliorer ?

✍ Exercice 4.9. Liste de vérification ★★★

Construisez la liste de vérification des tests internes de l'Opération LOGONE, phase par phase.

✍ Exercice 4.10. Comparer ★★★

Comparez le NIST SP 800-115, le PTES et l'OSSTMM : objet, niveau de détail, usage recommandé.

● Note

Pour aller plus loin.

- NIST SP 800-115 [21] ; PTES [20] ; OSSTMM [8].
- MITRE ATT&CK [24] ; CVSS v3.1 [5].

● Note

Transition. La Partie II commence par ce que l'on apprend sans toucher aux systèmes : la reconnaissance passive (Chapitre 5).

partie II

Reconnaître

© MaletYon

5

RECONNAISSANCE PASSIVE ET OSINT

« L'attaquant connaît souvent votre système d'information mieux que votre inventaire. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 3 et 4.

✦ Objectifs du chapitre

- ➢ Distinguer reconnaissance passive et active.
- ➢ Exploiter les sources ouvertes : DNS, certificats publics, annonces, réseaux professionnels, dépôts de code.
- ➢ Construire la surface d'attaque externe d'une organisation.
- ➢ Rester dans le cadre légal et éthique de la collecte.
- ➢ Transformer les résultats en mesures de réduction de l'exposition.

Question directrice : que voyait-on de LiZbiZ depuis Internet, sans rien toucher ?

Les 19 et 20 octobre, M. TAMO ne se connecte à aucun système de LiZbiZ. Il lit ce que le monde peut lire : les enregistrements DNS, les journaux publics de certificats, les offres d'emploi, les profils professionnels des salariés. À la fin du deuxième jour, il connaît trois serveurs exposés que l'inventaire de M. KOUNOU ignore.

Plan du chapitre.

1. Passive ou active (section 5.1).
2. Les sources ouvertes (section 5.2).
3. La surface d'attaque externe (section 5.3).
4. Les limites de la collecte (section 5.4).
5. Réduire l'exposition (section 5.5).

© *MaletYon*

5.1 Passive ou Active

Définition

Reconnaissance passive : collecte d'informations sans interagir avec les systèmes de la cible (sources publiques, services tiers). **Reconnaissance active** : collecte par interaction directe (résolution de noms auprès des serveurs de la cible, balayage). Le renseignement en sources ouvertes, ou **OSINT**, rassemble les informations publiquement accessibles.

La reconnaissance passive ne laisse presque aucune trace chez la cible : elle est aussi ce que fait un attaquant avant d'attaquer. ATT&CK lui consacre une tactique entière, la *reconnaissance* [24].

5.2 Les Sources Ouvertes

Source	Ce qu'elle révèle	Exemple chez LiZbiZ
Enregistrements DNS	Serveurs, messagerie, services	Serveurs de messagerie hébergés en nuage
Journaux de transparence des certificats	Noms de domaine pour lesquels un certificat a été émis	14 sous-domaines de lizbiz.cm
Registres d'adresses	Plages attribuées, hébergeur	La plage 198.51.100.0/27
Offres d'emploi	Technologies utilisées	« Administrateur de notre pare-feu et de notre passerelle d'accès distant »
Réseaux professionnels	Organigramme, format des adresses	prenom.nom@lizbiz.cm
Dépôts de code publics	Configurations, secrets oubliés	Aucun secret trouvé

Tableau 5.1. Sources ouvertes et apports

Les journaux de **transparence des certificats**, définis par la RFC 6962, enregistrent publiquement les certificats émis par les autorités participantes [11]. Ils servent à détecter les certificats émis par erreur ; ils révèlent aussi les noms de serveurs qu'une organisation croyait discrets.

5.3 La Surface d'Attaque Externe

Scénario Opérationnel · Opération LOGONE. Ce que l'inventaire ignorait

Constatations (20 octobre). Sur 14 sous-domaines trouvés dans les journaux de certificats, 11 figurent à l'inventaire. Trois n'y sont pas : « ancien-portail.lizbiz.cm » (ancienne version du portail de suivi, encore en ligne), « test-api.lizbiz.cm » (environnement de test) et « vpn2.lizbiz.cm » (ancienne passerelle d'accès distant, non retirée).

Analyse (confiance moyenne). Les trois serveurs oubliés sont précisément ceux qui ne reçoivent ni correctifs ni second facteur. Leur résolution et leur appartenance à la plage du périmètre restent à vérifier avant tout test actif (Chapitre 3).

Fiche de constat · T-03 · Ancienne passerelle d'accès distant non retirée

Description : « vpn2.lizbiz.cm » répond sur Internet et accepte une authentification par mot de passe seul. **Preuve :** entrée du journal de certificats, page de connexion (capture du 21 octobre). **Gravité :** élevée. **Impact :** contournement du second facteur de la passerelle principale. **Recommandation :** retirer le service, révoquer son certificat, inscrire le retrait au processus de fin de vie. **Détection :** inventaire externe périodique.

5.4 Les Limites de la Collecte

★ Attention

Violation typique. Se connecter à un compte trouvé dans une fuite publique « pour vérifier qu'il fonctionne ».

Règle : utiliser un identifiant volé, même publié, est un accès non autorisé s'il n'est pas prévu par les règles d'engagement. La collecte passive s'arrête à la lecture ; on signale la fuite au client.

La collecte sur les personnes (salariés, dirigeants) touche à des données personnelles : on se limite à ce qui sert le test (format des adresses, fonctions exposées), on ne constitue pas de dossier individuel, et on détruit les données à la fin de la mission (Chapitre 2).

5.5 Réduire l'Exposition

Procédure de test

Mesurer et réduire sa propre exposition

1. Surveiller les journaux de certificats pour ses domaines.
2. Comparer chaque trimestre la surface externe observée à l'inventaire.

3. Retirer les services anciens et les environnements de test exposés.
4. Relire les offres d'emploi et les communications techniques publiques.
5. Rechercher ses domaines dans les dépôts de code publics.

Application RSSI

Faire faire l'OSINT de sa propre organisation. Le RSSI commande chaque trimestre une reconnaissance passive de son organisation : ce qu'un attaquant voit gratuitement, il doit le voir avant lui.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Passive** : sans toucher la cible ; **active** : en interagissant.
- **DNS, certificats, registres, annonces, réseaux, dépôts** : les sources ouvertes.
- **La surface externe observée** se compare à l'inventaire ; les écarts sont souvent les failles.
- **La collecte s'arrête à la lecture** ; données personnelles minimisées.
- **Faire l'OSINT de soi-même**, avant l'attaquant.

Note

Points de contrôle de l'élève. Je sais : distinguer reconnaissance passive et active ; citer six sources ouvertes ; expliquer la transparence des certificats ; comparer surface observée et inventaire ; respecter les limites de la collecte.

Exercice 5.1. Passive ou active ★☆☆

Classez : lire un journal de certificats ; résoudre un nom auprès du serveur DNS de la cible ; consulter une offre d'emploi ; balayer un port.

Exercice 5.2. L'écart ★☆☆

Combien de sous-domaines trouvés ne figuraient pas à l'inventaire de LiZbiZ ? Quelle part du total ?

✍ Exercice 5.3. Les certificats ★☆☆

Pourquoi les journaux de transparence des certificats révèlent-ils des serveurs « discrets » ?

✍ Exercice 5.4. L'offre d'emploi ★★☆

Réécrivez l'offre d'emploi de LiZbiZ pour qu'elle reste attractive sans révéler ses technologies de sécurité.

✍ Exercice 5.5. Le compte publié ★★☆

Vous trouvez dans une fuite publique l'adresse et le mot de passe d'un salarié de LiZbiZ. Que faites-vous, et que ne faites-vous pas ?

✍ Exercice 5.6. Les personnes ★★☆

Quelles informations sur les salariés le testeur peut-il collecter pour une campagne d'hameçonnage simulée, et lesquelles doit-il s'interdire ?

✍ Exercice 5.7. T-03 ★★☆

Expliquez pourquoi l'ancienne passerelle annule l'effet du second facteur de la passerelle principale.

✍ Exercice 5.8. La procédure ★★☆

Transformez la procédure « mesurer et réduire sa propre exposition » en indicateur clé de risque avec des seuils (cours GES4062).

✍ Exercice 5.9. L'ANPP ★★★

Préparez le plan de reconnaissance passive de l'Opération MEFOU : sources, informations attendues, limites.

✍ Exercice 5.10. ATT&CK ★★★

Pour la tactique « reconnaissance » d'ATT&CK, proposez trois mesures défensives qui la rendent plus difficile ou plus visible.

● Note

Pour aller plus loin.

- ➢ RFC 6962 [11] ; MITRE ATT&CK [24].
- ➢ PTES, collecte de renseignements [20].

Note

Transition. La reconnaissance active commence par le balayage. C'est l'objet du Chapitre 6.

6

BALAYAGE ET ÉNUMÉRATION

« Un port ouvert est une question :
qui répond, et pourquoi est-il là ? »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 5 ; cours SEC3266, chapitres sur les réseaux.

✦ Objectifs du chapitre

- ➢ Expliquer la découverte d'hôtes et le balayage de ports TCP et UDP.
- ➢ Interpréter les états d'un port : ouvert, fermé, filtré.
- ➢ Identifier les services et leurs versions, et énumérer leurs informations.
- ➢ Conduire un balayage maîtrisé, sans perturber la production.
- ➢ Relier le balayage à sa détection par le défenseur.

Question directrice : combien de portes ouvertes comptait vraiment LiZbiZ ?

Le 21 octobre, M. TAMO balaye la plage externe de LiZbiZ ; le 26, depuis le poste fourni, Mme NGO MBOCK balaye les réseaux de Garoua. Les résultats mettent en regard ce qui devrait être ouvert, selon la matrice des flux du cours SEC3266, et ce qui l'est.

Plan du chapitre.

1. Découvrir les hôtes (section 6.1).
2. Balayer les ports (section 6.2).
3. Identifier les services (section 6.3).
4. Balayer sans nuire (section 6.4).
5. Ce que voit le défenseur (section 6.5).

© MaletYon

6.1 Découvrir les Hôtes

La découverte cherche les adresses qui répondent : requêtes ICMP, requêtes ARP sur le réseau local, tentatives de connexion TCP vers des ports courants. Un hôte qui ne répond pas au « ping » n'est pas forcément éteint : un pare-feu peut filtrer l'ICMP.

Définition

Énumération : étape qui, après la découverte, extrait d'un service les informations qu'il livre (noms de partages, comptes, versions, bannières, configuration).

6.2 Balayer les Ports

TCP établit une connexion en trois temps (SYN, SYN-ACK, ACK) défini par la RFC 9293 [4]. Le balayage exploite les réponses à un SYN.

État	Réponse observée	Signification
Ouvert	SYN-ACK	Un service écoute
Fermé	RST	L'hôte répond, aucun service
Filtré	Aucune réponse ou message ICMP d'interdiction	Un filtrage intercepte

Tableau 6.1. Les états d'un port TCP

Le balayage UDP est plus lent et plus incertain : un service UDP ouvert ne répond souvent rien, ce qui le confond avec un port filtré. On le réserve aux ports utiles (DNS, SNMP, NTP).

6.3 Identifier les Services

Scénario Opérationnel · Opération LOGONE. Prévu et constaté

Constatations. Externe : 7 hôtes actifs sur 32 adresses, 18 ports ouverts, dont 4 non prévus par la matrice des flux (dont l'ancienne passerelle, constat T-03). Interne, Garoua : 214 hôtes actifs ; le protocole de partage de fichiers SMBv1 est actif sur deux serveurs ; une imprimante expose son interface d'administration avec le mot de passe par défaut (constat déjà signalé en mars, cours SEC3266).

Analyse (confiance élevée). Les écarts entre la matrice et la réalité sont autant de constats : un service non prévu n'est ni surveillé, ni corrigé.

Port	Service	Information à énumérer
22	SSH	Version, méthodes d'authentification acceptées
80, 443	HTTP, HTTPS	Serveur, application, certificat, pages
445	SMB	Version du protocole, partages accessibles, signature
389	LDAP	Annuaire : domaine, possibilité d'interrogation anonyme
161 (UDP)	SNMP	Communauté par défaut, informations système

Tableau 6.2. Ports courants et énumération

6.4 Balayer sans Nuire

Procédure de test

Un balayage maîtrisé

1. Vérifier le périmètre et les exclusions (Chapitre 3).
2. Commencer par la découverte, puis les ports courants, puis le reste.
3. Limiter le débit sur les réseaux fragiles (automates, imprimantes, liaisons lentes).
4. Éviter les scripts intrusifs sur la production sans accord.
5. Enregistrer les résultats bruts, horodatés, dans le journal.

★ Attention

Violation typique. Lancer un balayage complet à plein débit sur une liaison inter-sites lente.

Règle : un balayage peut saturer un équipement ou une liaison et interrompre un service : c'est la conséquence que réprime l'article 66 si elle n'est pas maîtrisée. On adapte le débit au réseau.

6.5 Ce que Voit le Défenseur

Un balayage est bruyant : une source qui contacte de nombreux ports ou de nombreux hôtes en peu de temps est un motif classique (cours SEC3266). Le SOC de LiZbiZ a détecté le balayage interne en 40 minutes.

Application Analyste SOC et équipe rouge

Corréler les balayages internes. Une règle simple : alerte si une même source interne contacte plus de 100 ports ou 50 hôtes en dix minutes. Elle aurait vu PC-

GAR-07 en mars (SEC3266) et le testeur en octobre.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- ➢ **Découverte, balayage, énumération** : trois étapes.
- ➢ **Ouvert, fermé, filtré** : trois états d'un port TCP ; UDP est plus incertain.
- ➢ **Comparer la réalité à la matrice des flux** : chaque écart est un constat.
- ➢ **Balayer sans nuire** : périmètre, progressivité, débit, scripts prudents.
- ➢ **Le balayage est bruyant** : le SOC doit le voir.

● Note

Points de contrôle de l'élève. Je sais : expliquer la découverte d'hôtes ; interpréter l'état d'un port ; choisir quoi énumérer selon le service ; conduire un balayage maîtrisé ; écrire une règle de détection simple.

✍ **Exercice 6.1. Les états** ★☆☆

Quel état attribuer à un port qui répond par RST ? par SYN-ACK ? qui ne répond pas ?

✍ **Exercice 6.2. Le ping** ★☆☆

Pourquoi un hôte qui ne répond pas au « ping » peut-il être actif ?

✍ **Exercice 6.3. Les écarts** ★☆☆

Sur les 18 ports ouverts à l'externe, combien étaient prévus par la matrice des flux ?

✍ **Exercice 6.4. UDP** ★★☆

Pourquoi un balayage UDP est-il plus lent et plus incertain qu'un balayage TCP ?

✍ **Exercice 6.5. SMBv1** ★★☆

Rédigez la fiche de constat « SMBv1 actif sur deux serveurs ».

✍ **Exercice 6.6. L'imprimante** ★★☆

L'imprimante avait déjà été signalée en mars. Que révèle sa présence en octobre sur la gestion des corrections ? (cours GES4062)

✍ Exercice 6.7. Le débit ★★☆

Proposez un plan de balayage des 214 hôtes de Garoua qui ne sature pas la liaison avec Douala.

✍ Exercice 6.8. Détecter ★★☆

Le SOC a mis 40 minutes à voir le balayage. Proposez deux améliorations pour réduire ce délai.

✍ Exercice 6.9. Énumération ★★★

Pour chacun des ports du Tableau 6.2, dites quelle mesure défensive réduit l'information livrée à un attaquant.

✍ Exercice 6.10. Inventaire continu ★★★

Concevez un processus de balayage interne mensuel, autorisé, qui alimente l'inventaire et la matrice des flux de LiZbiZ.

● Note

Pour aller plus loin.

➢ RFC 9293 (TCP) [4] ; NIST SP 800-115 [21].

● Note

Transition. Un service identifié doit être confronté aux failles connues : le Chapitre 7 apprend à les analyser et à les prioriser.

7

ANALYSER ET PRIORISER LES VULNÉRABILITÉS

« Un rapport de trois cents failles
est un rapport qu'on ne lira pas. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 4 et 6.

✦ Objectifs du chapitre

- ➢ Utiliser un scanner de vulnérabilités et en connaître les limites.
- ➢ Écarter les faux positifs par la vérification.
- ➢ Comprendre les identifiants CVE et les catalogues de failles exploitées.
- ➢ Prioriser par la gravité, l'exploitation connue, l'exposition et la valeur de l'actif.
- ➢ Présenter une liste courte, ordonnée et justifiée.

Question directrice : par quoi commencer, parmi 312 résultats ?

Le scanner lancé le 26 octobre sur les réseaux de Garoua produit 312 résultats. M. KOUNOU n'a ni le temps ni l'équipe de tout corriger. Mme NGO MBOCK doit lui remettre une liste courte : ce qui est vrai, ce qui est dangereux, et dans quel ordre.

Plan du chapitre.

1. Les scanners de vulnérabilités (section 7.1).
2. Vérifier : faux positifs et faux négatifs (section 7.2).
3. CVE et catalogues (section 7.3).
4. Prioriser (section 7.4).
5. Présenter (section 7.5).

❍

© *MaletYon*

7.1 Les Scanners de Vulnérabilités

Un **scanner de vulnérabilités** compare les services et les versions observés à une base de failles connues, et tente parfois des vérifications. Il peut travailler *sans authentification* (vue d'attaquant externe) ou *avec authentification* (il lit les versions installées : bien plus précis).

Limite	Conséquence
Déduction par la version	Une version corrigée par un rétroportage peut être signalée vulnérable
Bases incomplètes	Les failles de configuration et de logique sont mal vues
Absence de contexte	Le scanner ne sait pas ce qui est critique pour le métier
Bruit	Des centaines de résultats de faible intérêt

Tableau 7.1. Limites des scanners

7.2 Vérifier : Faux Positifs et Faux Négatifs

Définition

Faux positif : faille signalée qui n'existe pas. **Faux négatif** : faille présente que l'outil n'a pas signalée. Le premier fait perdre du temps ; le second donne une fausse assurance.

Scénario Opérationnel · Opération LOGONE. De 312 à 41

Constatations. Sur 312 résultats bruts : 158 sont des informations sans gravité ; 96 sont des doublons (même faille sur plusieurs hôtes, regroupée) ; 17 sont des faux positifs (versions corrigées par rétroportage). Restent 41 vulnérabilités distinctes et vérifiées, dont 3 figurent au catalogue des failles exploitées.

Analyse (confiance élevée). Le travail du testeur n'est pas de recopier le scanner, mais de transformer ses résultats en constats vrais et ordonnés.

7.3 CVE et Catalogues

Référence	Rôle
CVE	Identifiant public unique d'une vulnérabilité (programme CVE, MITRE) [23]
CVSS	Gravité technique, de 0 à 10 (FIRST) [5]
EPSS	Probabilité estimée d'exploitation dans les 30 jours (FIRST) [6]
Catalogue KEV	Liste des vulnérabilités dont l'exploitation est avérée (CISA) [3]

Tableau 7.2. Les références utiles à la priorisation

7.4 Prioriser

Procédure de test

Une règle de priorisation (convention du cours)

1. **Priorité 1** : exploitation avérée (catalogue KEV) et actif exposé à Internet ou critique ; ou CVSS d'au moins 9 sur un actif exposé.
2. **Priorité 2** : CVSS d'au moins 7 sur un actif interne critique, ou probabilité d'exploitation élevée.
3. **Priorité 3** : le reste, traité dans le cycle normal des correctifs (cours SEC3266, Chapitre sur les systèmes).

★ Attention

Violation typique. Trier uniquement par le score CVSS décroissant.

Règle : une faille de score 7,5 exploitée activement sur la passerelle passe avant une faille de score 9,1 sur un poste isolé, sans exploitation connue. On croise gravité, exploitation, exposition et valeur.

7.5 Présenter

Fiche de constat · T-06 · SMBv1 actif sur deux serveurs de Garoua

Description : le protocole SMBv1, obsolète, est accepté par FS-02 et APP-01. **Preuve :** négociation du protocole (relevé du 26 octobre). **Gravité :** élevée (vulnérabilités connues de SMBv1, exploitées par le passé à grande échelle). **Impact :** exécution de code à distance si un correctif manque. **Recommandation :** désactiver SMBv1, vérifier les clients qui en dépendent. **Détection :** journaliser les négociations SMBv1.

Application RSSI

Demander peu, mais juste. Le RSSI attend du rapport une liste de priorité 1 courte et argumentée, qu'il peut faire corriger dans le mois, et une annexe complète pour le cycle normal.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Un scanner** compare des versions à une base ; avec authentification, il est plus précis.
- **On vérifie** : faux positifs écartés, faux négatifs recherchés à la main.
- **CVE, CVSS, EPSS, KEV** : identifier, coter, estimer, savoir ce qui est exploité.
- **On priorise** en croisant gravité, exploitation, exposition et valeur.
- **On présente** une liste courte de priorité 1 et une annexe.

● Note

Points de contrôle de l'élève. Je sais : dire les limites d'un scanner ; distinguer faux positif et faux négatif ; expliquer CVE, CVSS, EPSS et KEV ; appliquer une règle de priorisation ; rédiger un constat.

✍ Exercice 7.1. Les chiffres ★☆☆

Vérifiez que 312 résultats moins les informations, les doublons et les faux positifs laissent 41 vulnérabilités.

✍ Exercice 7.2. Faux positif ★☆☆

Pourquoi une version corrigée par rétroportage est-elle souvent signalée à tort ?

✍ Exercice 7.3. Les références ★☆☆

Associez à chaque question la bonne référence (CVE, CVSS, EPSS, KEV) : « est-elle exploitée ? » ; « quelle gravité ? » ; « quel nom ? » ; « quelle probabilité d'être exploitée bientôt ? »

✍ Exercice 7.4. Prioriser ★★☆

Appliquez la règle du cours à : CVSS 7,5 au catalogue KEV sur la passerelle ; CVSS 9,1 sans exploitation sur un poste isolé ; CVSS 5,3 sur le portail.

✍ Exercice 7.5. Authentifié ★★☆

Pourquoi un balayage authentifié réduit-il les faux positifs ? Quelles précautions exige-t-il ?

✍ Exercice 7.6. Faux négatifs ★★☆

Citez trois types de failles qu'un scanner voit mal, et comment le testeur les recherche.

✍ Exercice 7.7. T-06 ★★☆

Quels clients pourraient encore dépendre de SMBv1 chez LiZbiZ ? Comment le vérifier avant de le désactiver ?

✍ Exercice 7.8. Regrouper ★★☆

Pourquoi regrouper une même faille présente sur 40 hôtes en un seul constat ? Que faut-il indiquer pour ne rien perdre ?

✍ Exercice 7.9. Une politique ★★★

Rédigez la politique de priorisation des vulnérabilités de LiZbiZ, avec les délais associés à chaque priorité.

✍ Exercice 7.10. Mesurer ★★★

Proposez trois indicateurs du processus de gestion des vulnérabilités et leurs seuils.

● Note

Pour aller plus loin.

- ➢ FIRST, CVSS [5] et EPSS [6] ; CISA, catalogue KEV [3].
- ➢ NIST SP 800-40 Rev. 4 [22].

● Note

Transition. Une faille vérifiée se démontre par l'exploitation, dans un cadre maîtrisé. La Partie III commence par ses principes (Chapitre 8).

partie III

Systèmes et Réseaux

© MaletYon

8

L'EXPLOITATION : PRINCIPES ET CADRES

« Démontrer, pas détruire. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 3 et 7.

✦ Objectifs du chapitre

- ➢ Distinguer vulnérabilité, exploit, charge utile et preuve de concept.
- ➢ Choisir de démontrer ou de ne pas démontrer une faille.
- ➢ Évaluer le risque d'une exploitation pour la production.
- ➢ Utiliser un cadre d'exploitation de manière maîtrisée.
- ➢ Produire une preuve minimale, vérifiable et sans dommage.

Question directrice : faut-il exploiter l'ancien portail pour prouver qu'il est vulnérable ?

L'ancien portail de suivi, oublié depuis 2024, utilise une version d'application connue pour une faille d'exécution de code à distance. Le scanner le dit. M. KOUNOU répond que « ce serveur ne sert plus à rien ». M. BIKORO décide de démontrer la faille, avec la plus petite preuve possible. Pourquoi, et comment ?

Plan du chapitre.

1. Le vocabulaire de l'exploitation (section 8.1).
2. Démontrer ou non (section 8.2).
3. Le risque pour la production (section 8.3).
4. Les cadres d'exploitation (section 8.4).
5. La preuve minimale (section 8.5).

© MaletYon

8.1 Le Vocabulaire de l'Exploitation

Définition

Exploit : moyen (programme, requête, séquence d'actions) qui tire parti d'une vulnérabilité pour obtenir un effet non prévu. **Charge utile** : ce que l'exploit exécute une fois la faille déclenchée. **Preuve de concept** : démonstration minimale qu'une faille est exploitable, sans en tirer tout le parti possible.

Effet recherché	Exemple de preuve minimale
Exécution de code	Afficher l'identité du compte d'exécution et le nom de la machine
Lecture de fichier	Lire un fichier sans valeur (version, fichier de test déposé par accord)
Contournement d'authentification	Afficher la page d'accueil d'un compte de test fourni
Élévation de privilèges	Afficher l'appartenance au groupe obtenu

Tableau 8.1. Effets et preuves minimales

8.2 Démontrer ou Non

Démontrer une faille la rend indiscutable et en mesure l'impact réel ; ne pas la démontrer évite tout risque pour la production. La décision dépend de l'objectif, des règles d'engagement et du risque.

Procédure de test

Décider d'exploiter

1. L'exploitation est-elle autorisée pour cette cible ?
2. L'exploit est-il connu, stable, compris ? Sait-on ce qu'il fait ?
3. Quel est le pire effet possible (arrêt, corruption) ? Est-il acceptable ?
4. Le client est-il prévenu, la fenêtre adaptée, une sauvegarde faite ?
5. La preuve minimale suffit-elle à l'objectif ?

Attention

Violation typique. Lancer un exploit téléchargé sans l'avoir lu.

Règle : un exploit d'origine inconnue peut contenir une porte dérobée, détruire des données ou faire tomber le service. On n'emploie sur la production que du code dont on connaît la provenance et l'effet, après l'avoir essayé dans un laboratoire (Chapitre 25).

8.3 Le Risque pour la Production

Type de faille	Risque de l'exploitation	Précaution
Dépassement de mémoire	Arrêt du service, instabilité	Laboratoire d'abord ; fenêtre creuse
Injection dans une base	Modification de données	Requêtes en lecture seule
Exécution de commande	Commande destructrice par erreur	Commandes d'identification seulement
Déni de service	Interruption certaine	Exclu par défaut

Tableau 8.2. Risques et précautions

8.4 Les Cadres d'Exploitation

Les **cadres d'exploitation** réunissent des modules d'exploits, de charges utiles et d'outils de post-exploitation, documentés et maintenus. Ils réduisent le risque des exploits isolés, mais ne dispensent ni de comprendre le module, ni de vérifier qu'il est adapté à la version ciblée. Le cours ne détaille pas leur emploi : il en retient l'usage professionnel : modules connus, options vérifiées, journal de chaque lancement.

8.5 La Preuve Minimale

Scénario Opérationnel · Opération LOGONE. L'ancien portail

Constatation. Le 22 octobre à 14 h 05, après accord de M. KOUNOU et sauvegarde du serveur, M. TAMO déclenche la faille de l'ancien portail avec un module connu. La preuve : l'affichage de l'identité du compte de service web et du nom de la machine. Aucune autre commande n'est exécutée ; la session est fermée à 14 h 08.

Analyse (confiance élevée). « Ce serveur ne sert plus à rien » : mais il est en ligne, dans la DMZ, et le compte web peut lire la configuration de connexion à la base du portail actuel. La démonstration a transformé une alerte du scanner en constat incontestable.

Fiche de constat · T-09 · Exécution de code sur l'ancien portail de suivi

Description : « ancien-portail.lizbiz.cm » exécute une version d'application vulnérable à une exécution de code à distance. **Preuve :** capture du 22 octobre, 14 h 06 (identité du compte, nom de la machine). **Gravité :** élevée dans le contexte (serveur exposé). **Recommandation :** retirer le serveur ; à défaut, le mettre à jour et l'isoler. **Détection :** processus inhabituel lancé par le compte web.

Application Pentesteur

Une commande, une preuve, on ferme. Le pentesteur prépare à l'avance la commande de preuve, l'exécute une fois, capture, ferme la session et note l'heure. Explorer « tant qu'on y est » n'est pas une preuve, c'est un risque.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Vulnérabilité, exploit, charge utile, preuve de concept** : quatre notions distinctes.
- **On décide d'exploiter** selon l'autorisation, la stabilité, le pire effet et l'objectif.
- **Jamais d'exploit inconnu** sur la production ; laboratoire d'abord.
- **Les cadres d'exploitation** réduisent le risque sans dispenser de comprendre.
- **Une preuve minimale** suffit : une commande, une capture, on ferme.

Note

Points de contrôle de l'élève. Je sais : définir exploit, charge utile et preuve de concept ; dérouler la décision d'exploiter ; associer une précaution à un type de faille ; choisir une preuve minimale.

Exercice 8.1. Vocabulaire ★☆☆

Dans l'épisode de l'ancien portail, identifiez la vulnérabilité, l'exploit, la charge utile et la preuve.

Exercice 8.2. Preuve minimale ★☆☆

Proposez une preuve minimale pour une lecture de fichier arbitraire sur un serveur web.

Exercice 8.3. Déni de service ★☆☆

Pourquoi le déni de service est-il exclu par défaut ? Quel article de la loi n° 2010/012 le concerne ?

Exercice 8.4. Décider ★★☆

Appliquez la procédure de décision à une faille de dépassement de mémoire sur le serveur de base de données de la facturation.

✍ Exercice 8.5. L'exploit inconnu ★★☆

Citez trois dangers d'un exploit téléchargé sur un site non vérifié.

✍ Exercice 8.6. « Ne sert plus à rien » ★★☆

Comment répondre à M. KOUNOU, qui juge l'ancien portail sans importance ?

✍ Exercice 8.7. La détection ★★☆

Quels journaux auraient permis de détecter l'exploitation de l'ancien portail ?

✍ Exercice 8.8. Ne pas démontrer ★★☆

Donnez deux situations où le testeur doit renoncer à démontrer une faille, et comment il la rapporte alors.

✍ Exercice 8.9. Une procédure ★★★

Rédigez la procédure d'exploitation contrôlée de NYONG SÉCURITÉ : accord, préparation, exécution, preuve, fermeture, journal.

✍ Exercice 8.10. Laboratoire ★★★

Décrivez le laboratoire qui permet de valider un module d'exploitation avant son emploi chez un client.

● Note

Pour aller plus loin.

➢ NIST SP 800-115 [21] ; PTES [20].

● Note

Transition. Sur le réseau interne, l'attaquant cherche des secrets qui circulent : le Chapitre 9 traite des attaques réseau et de l'authentification.

9

ATTAQUES RÉSEAU ET AUTHENTIFICATION

« Un réseau qui crie ses questions à tout le monde
finit par recevoir une mauvaise réponse. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 8 ; cours SEC3266, chapitres sur les réseaux et les identités.

✦ Objectifs du chapitre

- ➢ Expliquer les protocoles d'authentification d'un réseau Windows (NTLM, Kerberos).
- ➢ Comprendre l'empoisonnement des résolutions de noms locales.
- ➢ Comprendre le relais d'authentification et ses conditions.
- ➢ Relier chaque attaque à sa détection et à sa parade.
- ➢ Rédiger les constats correspondants.

Question directrice : comment un poste ordinaire peut-il recueillir des secrets sans rien attaquer ?

Le 26 octobre, depuis le poste fourni, Mme NGO MBOCK observe le trafic local de Garoua. Des postes demandent à tout le réseau « qui est srv-imprim ? », un serveur qui n'existe plus. Une machine qui répondrait « c'est moi » recevrait leur tentative d'authentification. Ce chapitre explique pourquoi, et comment fermer cette porte.

Plan du chapitre.

1. NTLM et Kerberos (section 9.1).
2. L'empoisonnement des résolutions locales (section 9.2).
3. Le relais d'authentification (section 9.3).
4. Détecter et corriger (section 9.4).

© MaletYon

9.1 NTLM et Kerberos

Protocole	Principe	Faiblesse exploitable
NTLM	Défi et réponse calculée à partir du haché du mot de passe	La réponse peut être relayée ou cassée hors ligne si le mot de passe est faible
Kerberos	Tickets délivrés par un centre de distribution de clés (RFC 4120)	Tickets de service chiffrés avec le secret du compte de service (Chapitre 10)

Tableau 9.1. Deux protocoles d'authentification

Kerberos, défini par la RFC 4120, est le protocole par défaut d'un domaine Active Directory [15] ; NTLM subsiste pour la compatibilité, et c'est souvent lui que vise l'attaquant.

9.2 L'Empoisonnement des Résolutions Locales

Quand un nom ne se résout pas par le DNS, Windows peut interroger tout le réseau local par LLMNR (RFC 4795) ou NBT-NS [1]. N'importe quelle machine peut répondre. Un attaquant présent sur le réseau répond à ces questions et reçoit en retour une tentative d'authentification NTLM.

Définition

Empoisonnement de résolution : réponse frauduleuse à une requête de résolution de nom diffusée sur le réseau local, qui détourne la connexion de la victime vers l'attaquant (ATT&CK, T1557).

Scénario Opérationnel · Opération LOGONE. Les questions sans réponse

Constatation. En une heure d'écoute passive, 37 requêtes LLMNR pour des noms inexistants (dont « srv-imprim », retiré en 2025), émises par 22 postes. Avec l'accord de M. KOUNOU, une réponse contrôlée de dix minutes recueille 6 réponses NTLM de 4 comptes ; aucune n'est cassée, les mots de passe concernés étant longs.

Analyse (confiance élevée). La faille est structurelle (LLMNR et NBT-NS actifs) ; son impact dépend de la force des mots de passe et de la possibilité de relais.

9.3 Le Relais d'Authentification

Au lieu de casser la réponse NTLM, l'attaquant peut la *relayer* aussitôt vers un autre serveur, et s'y authentifier comme la victime. Le relais est possible lorsque le serveur cible n'exige pas la **signature** des échanges (SMB) ou la liaison au canal (HTTP, LDAP).

Condition	Situation chez LiZbiZ
Requêtes diffusées détournables	LLMNR et NBT-NS actifs
Serveurs sans signature SMB exigée	31 serveurs sur 34 à Garoua
Comptes à privilèges qui s'authentifient	Comptes d'administration utilisés depuis des postes ordinaires

Tableau 9.2. Les conditions du relais (Opération LOGONE)

★ Attention

Violation typique. Relayer une authentification vers un serveur de production sans accord.

Règle : le relais crée une session réelle au nom d'un salarié : il n'est démontré que vers une cible et un compte convenus, et la session est fermée aussitôt la preuve faite.

9.4 Détecter et Corriger

Parade	Effet
Désactiver LLMNR et NBT-NS	Supprime les requêtes diffusées détournables
Exiger la signature SMB	Empêche le relais vers SMB
Protection étendue de l'authentification (LDAP, HTTP)	Lie l'authentification au canal
Réduire NTLM au profit de Kerberos	Réduit la surface
Comptes d'administration séparés, bastion	Les secrets d'administration ne circulent pas depuis les postes
Détection	Répondant inconnu aux requêtes LLMNR ; authentifications NTLM d'un compte depuis une machine inhabituelle

Tableau 9.3. Parades et détection

Fiche de constat · T-07 · Signature SMB non exigée et LLMNR actif

Description : 31 serveurs sur 34 n'exigent pas la signature SMB ; LLMNR et NBT-NS sont actifs sur les postes. **Preuve :** relevés du 26 octobre ; réponses NTLM recueillies (masquées). **Gravité :** moyenne (élevée si un compte à privilèges est capturé). **Recommandation :** désactiver LLMNR et NBT-NS par stratégie de groupe ; exiger la signature SMB. **Détection :** surveiller les réponses LLMNR

d'hôtes non autorisés.

Application Analyste SOC et équipe rouge

Poser un piège. Un poste « leurre » émet régulièrement une requête LLMNR pour un nom inexistant : toute réponse signale un empoisonneur sur le réseau.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **NTLM** se relaie ou se casse si le mot de passe est faible ; **Kerberos** est le protocole par défaut du domaine.
- **LLMNR et NBT-NS** diffusent des questions auxquelles n'importe qui peut répondre.
- **Le relais** exige l'absence de signature ou de liaison au canal.
- **Désactiver, signer, lier, séparer, détecter** : les parades.
- **Démontrer** seulement vers une cible convenue, et fermer aussitôt.

● Note

Points de contrôle de l'élève. Je sais : comparer NTLM et Kerberos ; expliquer l'empoisonnement LLMNR ; énoncer les conditions du relais ; proposer les parades et une détection.

✍ Exercice 9.1. LLMNR ★☆☆

Pourquoi un poste envoie-t-il une requête LLMNR pour « srv-imprim » ? Quelle mesure d'hygiène l'aurait évité ?

✍ Exercice 9.2. Proportion ★☆☆

Quelle part des serveurs de Garoua n'exige pas la signature SMB ?

✍ Exercice 9.3. Kerberos ★☆☆

Quel organisme a défini Kerberos version 5 dans la RFC 4120 ? Quel est le rôle du centre de distribution de clés ?

✍ Exercice 9.4. Casser ou relayer ★★☆

Pourquoi les réponses recueillies n'ont-elles pas été cassées ? Que faudrait-il pour qu'elles le soient ?

✍ Exercice 9.5. Les conditions ★★☆

Laquelle des trois conditions du Tableau 9.2 est la plus simple à supprimer ? Laquelle protège le mieux ?

✍ Exercice 9.6. Le piège ★★☆

Décrivez le poste « leurre » et la règle d'alerte du SOC.

✍ Exercice 9.7. Effets de bord ★★☆

Quels risques de dysfonctionnement faut-il vérifier avant d'exiger la signature SMB partout ?

✍ Exercice 9.8. ATT&CK ★★☆

Dans quelle tactique d'ATT&CK se range l'empoisonnement de résolution ? Pourquoi ?

✍ Exercice 9.9. Plan de correction ★★★

Rédigez le plan de correction de T-07 en trois vagues, avec les tests de non-régression.

✍ Exercice 9.10. Réduire NTLM ★★★

Proposez une démarche pour mesurer l'usage de NTLM chez LiZbiZ et le réduire sans interrompre les applications.

Note

Pour aller plus loin.

- RFC 4120 (Kerberos) [15] ; RFC 4795 (LLMNR) [1].
- MITRE ATT&CK [24].

Note

Transition. Kerberos et l'annuaire forment le cœur du réseau Windows : le Chapitre 10 est consacré à Active Directory.

10

ACTIVE DIRECTORY

> « Dans un domaine, l'attaquant ne cherche pas la faille ;
> il cherche le chemin. »
>
> Principe du cours

Niveau : *Expert* • Chapitre 9 ; cours SEC3266, chapitre sur les identités.

✦ Objectifs du chapitre

- ➢ Décrire les objets d'un annuaire Active Directory et les groupes à privilèges.
- ➢ Expliquer l'obtention de tickets Kerberos et ses détournements (kerberoasting, AS-REP roasting).
- ➢ Raisonner en chemins d'attaque dans un graphe de droits.
- ➢ Appliquer le modèle d'administration par niveaux.
- ➢ Détecter et corriger les faiblesses les plus exploitées.

Question directrice : comment un compte d'utilisateur ordinaire devient-il administrateur du domaine en cinq heures ?

Le 28 octobre, Mme NGO MBOCK part du compte d'utilisateur ordinaire fourni par LiZbiZ. Elle n'exploite aucune faille logicielle. Elle interroge l'annuaire, comme tout utilisateur peut le faire, demande un ticket pour un service, casse hors ligne le mot de passe d'un compte de service, et découvre que ce compte est administrateur du domaine. Ce chapitre, sur deux séances, déroule ce chemin et ses parades.

Plan du chapitre.

1. L'annuaire et ses privilèges (section 10.1).
2. Kerberos en bref (section 10.2).
3. Le kerberoasting (section 10.3).
4. L'AS-REP roasting (section 10.4).
5. Les chemins d'attaque (section 10.5).

© *MaletYon*

6. Le modèle par niveaux et les défenses (section 10.6).

10.1 L'Annuaire et ses Privilèges

Définition

Active Directory : service d'annuaire de Microsoft qui gère, dans un *domaine*, les comptes, les groupes, les ordinateurs et les stratégies, et qui authentifie les utilisateurs par Kerberos. Les **contrôleurs de domaine** en hébergent la base.

Objet ou groupe	Pourquoi il intéresse l'attaquant
Admins du domaine	Contrôle total du domaine
Administrateurs de l'entreprise	Contrôle de toute la forêt
Opérateurs de sauvegarde, de serveur	Accès étendu, souvent oublié
Comptes de service	Mots de passe rarement changés, droits souvent excessifs
Stratégies de groupe	Exécution de code sur toutes les machines liées
Listes de contrôle d'accès	Un droit d'écriture sur un objet peut suffire à en prendre le contrôle

Tableau 10.1. Ce que vise l'attaquant dans l'annuaire

Tout utilisateur authentifié peut, par défaut, lire l'essentiel de l'annuaire : comptes, groupes, attributs. C'est utile au fonctionnement, et c'est ce qui rend la reconnaissance interne si facile.

10.2 Kerberos en Bref

Étape	Échange	Secret utilisé
1	L'utilisateur demande un ticket d'accès général (TGT) au centre de distribution	Clé dérivée du mot de passe de l'utilisateur (pré-authentification)
2	Il présente le TGT et demande un ticket de service pour un nom de service (SPN)	Clé du centre de distribution
3	Le centre renvoie un ticket de service chiffré	Clé dérivée du mot de passe du *compte de service*
4	L'utilisateur présente le ticket au service	Le service le déchiffre

Tableau 10.2. Les échanges Kerberos (d'après la RFC 4120)

10.3 Le Kerberoasting

Définition

Kerberoasting : technique (ATT&CK T1558.003) par laquelle un utilisateur authentifié demande des tickets de service pour des comptes associés à un SPN, puis tente de retrouver hors ligne leur mot de passe à partir du ticket chiffré.

Demander un ticket de service est un geste normal : n'importe quel utilisateur le fait. La faiblesse est ailleurs : un compte de service dont le mot de passe est court ou prévisible se casse hors ligne, sans laisser de trace d'échec.

Scénario Opérationnel · Opération LOGONE. Le compte de la facturation

Constatations (28 octobre).

- 9 h 10 : interrogation de l'annuaire ; 6 comptes ont un SPN.
- 9 h 25 : tickets de service demandés pour ces 6 comptes.
- 11 h 40 : le mot de passe de « svc_sql_facturation » est retrouvé hors ligne : 11 caractères, formé du nom de l'application, d'un symbole et d'une année.
- 14 h 05 : ce compte est membre des Admins du domaine (déjà relevé à la revue des comptes de mars, cours SEC3266).
- 14 h 10 : preuve capturée, test arrêté, contacts prévenus.

Analyse (confiance élevée). Aucune faille logicielle : trois faiblesses de configuration se combinent (mot de passe faible, mot de passe jamais changé, droits excessifs). Le SOC n'a rien vu : aucune règle ne surveillait les demandes de tickets.

10.4 L'AS-REP Roasting

Lorsqu'un compte a la *pré-authentification Kerberos désactivée*, n'importe qui peut demander pour lui une réponse chiffrée avec une clé dérivée de son mot de passe, et tenter de la casser hors ligne (ATT&CK T1558.004). Cette option, parfois activée pour d'anciennes applications, devrait être exceptionnelle et tracée. Chez LiZbiZ, deux comptes l'avaient encore, dont un compte de test oublié.

10.5 Les Chemins d'Attaque

L'annuaire forme un **graphe** : des utilisateurs membres de groupes, des groupes ayant des droits sur des objets, des sessions ouvertes sur des machines. Un chemin d'attaque est une suite d'arêtes qui mène d'un compte ordinaire à un groupe à privilèges. Des outils publics de cartographie calculent ces chemins ; les défenseurs les utilisent pour les couper.

Arête	Relation	Exemple chez LiZbiZ
1	Membre de	svc_sql_facturation → Admins du domaine
2	Session ouverte sur	Un administrateur connecté sur PC-GAR-12
3	Administrateur local de	Le groupe « Support Garoua » sur tous les postes de Garoua
4	Droit d'écriture sur	Le groupe « Support Garoua » peut modifier le groupe « Admins serveurs »

Tableau 10.3. Des relations qui forment des chemins

★ Attention

Violation typique. Corriger le seul compte exploité et déclarer le problème résolu.

Règle : le test a montré *un* chemin. La correction consiste à cartographier tous les chemins vers les groupes à privilèges et à couper les plus courts, puis à refaire la cartographie.

10.6 Le Modèle par Niveaux et les Défenses

Le **modèle d'administration par niveaux** sépare les comptes et les machines en niveaux (contrôleurs de domaine et identités ; serveurs ; postes) : un compte d'un niveau ne s'ouvre jamais sur une machine d'un niveau inférieur, pour que ses secrets n'y soient jamais exposés.

Défense	Effet
Comptes de service gérés	Mots de passe longs, aléatoires, changés automatiquement : le kerberoasting devient inutile
Mots de passe de 25 caractères au moins pour les autres comptes de service	Rend le cassage hors ligne irréaliste
Retrait des droits excessifs	Un compte de service n'est pas administrateur du domaine
Pré-authentification obligatoire	Supprime l'AS-REP roasting
Mot de passe administrateur local unique (LAPS)	Bloque le mouvement latéral (cours SEC3266)
Groupe Protected Users, modèle par niveaux	Limite l'exposition des secrets à privilèges
Détection	Événements de demande de ticket inhabituels (nombreux SPN en peu de temps, chiffrement faible demandé)

Tableau 10.4. Les défenses de l'annuaire

Fiche de constat · T-01 · Compte de service à privilèges et mot de passe faible

Description : « svc_sql_facturation » a un SPN, un mot de passe de 11 caractères prévisible, jamais changé, et appartient aux Admins du domaine. **Preuve :** appartenance au groupe (capture du 28 octobre, 14 h 08), mot de passe non reproduit. **Gravité :** critique. **Impact :** contrôle total du domaine par tout utilisateur authentifié. **Recommandation :** retirer le compte des Admins du domaine, le convertir en compte de service géré, cartographier les autres chemins. **Détection :** alerte sur les demandes de tickets en rafale.

Application Analyste SOC et équipe rouge

Placer un compte « appât ». Un compte de service fictif, avec un SPN et aucun usage légitime : toute demande de ticket le concernant signale une tentative de kerberoasting.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'annuaire** est lisible par tout utilisateur ; les groupes à privilèges, les comptes de service et les droits sont les cibles.
- **Kerberos** chiffre le ticket de service avec le secret du compte de service : d'où le kerberoasting.
- **AS-REP roasting** : la pré-authentification désactivée expose le compte.
- **On raisonne en chemins** ; on cartographie et on coupe les plus courts.
- **Comptes de service gérés, moindre privilège, niveaux, détection** : les défenses.

Note

Points de contrôle de l'élève. Je sais : nommer les groupes à privilèges ; décrire les quatre échanges Kerberos ; expliquer le kerberoasting et l'AS-REP roasting ; lire un chemin d'attaque ; proposer les défenses et une détection.

✍ Exercice 10.1. Les groupes ★☆☆

Citez trois groupes ou types de comptes d'un domaine qui intéressent en priorité l'attaquant, et pourquoi.

✍ Exercice 10.2. Le secret ★☆☆

Avec quel secret le ticket de service est-il chiffré ? Pourquoi est-ce la source du kerberoasting ?

✍ Exercice 10.3. Chronologie ★☆☆

Combien de temps s'écoule entre l'interrogation de l'annuaire et la preuve d'accès aux Admins du domaine ?

✍ Exercice 10.4. Les trois faiblesses ★★☆

Identifiez les trois faiblesses de configuration combinées dans T-01, et la mesure qui supprime chacune.

✍ Exercice 10.5. Pourquoi le SOC n'a rien vu ★★☆

Pourquoi le kerberoasting est-il discret ? Quelle règle aurait pu le voir ?

✍ Exercice 10.6. Le chemin ★★☆

À partir du Tableau 10.3, décrivez un second chemin, sans le compte de la facturation, qui mène un membre de « Support Garoua » vers des droits élevés.

✍ Exercice 10.7. Niveaux ★★☆

Un administrateur du domaine lit ses courriels sur PC-GAR-12. Quelle règle du modèle par niveaux viole-t-il ? Quel risque crée-t-il ?

✍ Exercice 10.8. AS-REP ★★☆

Comment recenser les comptes dont la pré-authentification est désactivée ? Que faire de chacun ?

✍ Exercice 10.9. Le plan ★★★

Rédigez le plan de durcissement de l'annuaire de LiZbiZ sur trois mois, à partir du Tableau 10.4.

✍ Exercice 10.10. Mesurer les chemins ★★★

Proposez un indicateur fondé sur les chemins d'attaque (nombre, longueur) et un objectif pour le comité des risques.

Note

Pour aller plus loin.

➢ RFC 4120 [15] ; MITRE ATT&CK [24].

Note

Transition. Sur une machine, l'attaquant cherche aussi à passer d'un compte limité à un compte d'administration : le Chapitre 11 traite de l'élévation de privilèges.

11

ÉLÉVATION DE PRIVILÈGES

« L'élévation de privilèges exploite rarement le noyau ;
elle exploite le plus souvent une négligence de configuration. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 8 ; cours SEC3266, chapitre sur les systèmes.

✦ Objectifs du chapitre

- ➢ Distinguer élévation verticale et mouvement horizontal.
- ➢ Recenser les vecteurs d'élévation sous Linux et sous Windows.
- ➢ Lire un relevé de configuration pour y repérer un vecteur.
- ➢ Classer les vecteurs par probabilité et par risque de dommage.
- ➢ Proposer la correction et la détection de chaque vecteur.

Question directrice : un compte web limité peut-il devenir administrateur du serveur ?

Après la démonstration sur l'ancien portail (Chapitre 8), M. TAMO dispose d'un compte web sans privilège. Plutôt que d'exploiter le serveur, il en lit la configuration, avec l'accord de M. KOUNOU : droits sudo, programmes SUID, tâches planifiées, fichiers modifiables. Trois vecteurs apparaissent ; un seul suffit.

Plan du chapitre.

1. Vertical et horizontal (section 11.1).
2. Les vecteurs sous Linux (section 11.2).
3. Les vecteurs sous Windows (section 11.3).
4. Lire un relevé (section 11.4).
5. Corriger et détecter (section 11.5).

© MaletYon

11.1 Vertical et Horizontal

Définition

Élévation de privilèges : obtention de droits supérieurs à ceux du compte de départ (verticale : utilisateur vers administrateur). **Mouvement horizontal** : passage d'un compte à un autre de même niveau, souvent pour atteindre des données ou une autre machine.

11.2 Les Vecteurs sous Linux

Vecteur	Faiblesse	Correction
sudo trop large	Commande autorisée sans mot de passe qui permet d'ouvrir un interpréteur	Restreindre aux commandes nécessaires
Programme SUID inhabituel	S'exécute avec les droits de son propriétaire	Retirer le bit SUID, supprimer le fichier
Tâche planifiée modifiable	Script exécuté par root, modifiable par d'autres	Droits stricts sur les scripts
Capacités excessives	Un binaire dispose d'une capacité qui contourne les contrôles	Retirer la capacité
Fichier sensible lisible	Clé, mot de passe dans un fichier accessible	Droits stricts, coffre de secrets
Noyau non corrigé	Faille du noyau	Correctifs ; vecteur risqué à exploiter

Tableau 11.1. Vecteurs d'élévation sous Linux

11.3 Les Vecteurs sous Windows

Vecteur	Faiblesse	Correction
Service mal protégé	Binaire ou configuration du service modifiable par un utilisateur	Droits stricts ; comptes de service dédiés
Chemin de service sans guillemets	Chemin avec espaces interprété par morceaux	Mettre le chemin entre guillemets
Installation toujours élevée	Stratégie qui installe tout paquet avec les droits système	Désactiver la stratégie
Mot de passe en clair	Script ou fichier de configuration lisible	Supprimer, changer le mot de passe
Administrateur local partagé	Même mot de passe sur toutes les machines	Mot de passe unique par machine

Tableau 11.2. Vecteurs d'élévation sous Windows

Scénario Opérationnel · Opération LOGONE. Le script du partage

Constatation. Sur le partage de fichiers `\\FS-01\scripts`, lisible par tous les utilisateurs, un script de déploiement contient en clair le mot de passe du compte administrateur local des postes de Douala.

Analyse (confiance élevée). Depuis mars, chaque poste a son propre mot de passe administrateur local (LAPS) ; mais ce script, antérieur, a servi à leur installation, et 23 postes non réinstallés gardent l'ancien mot de passe commun. C'est le constat critique T-02.

11.4 Lire un Relevé

Procédure de test

Recenser les vecteurs à partir d'un relevé

1. Comptes et groupes : qui a l'UID 0 (Linux), qui est administrateur local (Windows) ?
2. Droits délégués : `sudo -l` ; services et leurs droits.
3. Programmes SUID et capacités hors des chemins du système.
4. Tâches planifiées et scripts qu'elles exécutent : qui peut les modifier ?
5. Fichiers lisibles contenant des secrets.
6. Version du noyau et correctifs, en dernier recours.

★ Attention

Violation typique. Commencer par une faille du noyau.

Règle : une exploitation du noyau peut faire tomber le serveur. On cherche d'abord les vecteurs de configuration, sans risque et plus probables ; on rapporte la faille du noyau sans l'exploiter, sauf accord explicite.

11.5 Corriger et Détecter

Fiche de constat · T-02 · Mot de passe administrateur local en clair

Description : un script lisible par tous sur `\\FS-01\scripts` contient le mot de passe administrateur local commun de 23 postes de Douala. **Preuve :** chemin et date du fichier, mot de passe masqué. **Gravité :** critique. **Impact :** administration de 23 postes et mouvement latéral. **Recommandation :** supprimer le script, changer le

mot de passe sur les 23 postes (LAPS), rechercher d'autres secrets dans les partages. **Détection :** connexions avec le compte administrateur local depuis le réseau.

Application Auditeur de sécurité

Chercher les secrets là où on travaille. L'auditeur recherche les mots de passe dans les partages, les scripts, les stratégies de groupe et les dépôts internes : c'est souvent là, et non dans les serveurs, que se trouvent les clés du domaine.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Vertical** (plus de droits) et **horizontal** (autre compte).
- **Linux** : sudo, SUID, tâches, capacités, fichiers, noyau.
- **Windows** : services, chemins, stratégies, mots de passe en clair, administrateur local partagé.
- **On lit la configuration d'abord** ; le noyau en dernier.
- **Chaque vecteur** a sa correction et sa détection.

Note

Points de contrôle de l'élève. Je sais : distinguer élévation et mouvement horizontal ; citer les vecteurs Linux et Windows ; lire un relevé dans l'ordre ; rédiger un constat avec correction et détection.

Exercice 11.1. Vertical ou horizontal ★☆☆

Classez : passer du compte web au compte root ; utiliser le compte d'un collègue de même service ; devenir administrateur local d'un poste.

Exercice 11.2. SUID ★☆☆

Pourquoi un fichier SUID appartenant à root dans `/tmp` est-il suspect ? (cours SEC3266, lab de durcissement)

Exercice 11.3. Chemin ★☆☆

Expliquez le risque d'un chemin de service non entouré de guillemets.

✍ Exercice 11.4. sudo ★★☆

Un utilisateur peut lancer un éditeur de texte en sudo sans mot de passe. Pourquoi est-ce dangereux ? Que proposez-vous ?

✍ Exercice 11.5. Le script ★★☆

Pourquoi 23 postes gardent-ils l'ancien mot de passe malgré LAPS ? Comment les retrouver ?

✍ Exercice 11.6. Ordre ★★☆

Justifiez l'ordre de la procédure de recensement.

✍ Exercice 11.7. Tâche planifiée ★★☆

Une tâche exécutée par root lance un script modifiable par le groupe « web ». Rédigez le constat.

✍ Exercice 11.8. Détecter ★★☆

Quels événements Windows permettent de détecter l'usage du compte administrateur local depuis le réseau ?

✍ Exercice 11.9. Recherche de secrets ★★★

Concevez une campagne interne, autorisée, de recherche de secrets dans les partages de LiZbiZ : périmètre, méthode, traitement des résultats.

✍ Exercice 11.10. Standard ★★★

Rédigez cinq règles d'un standard de configuration qui ferment les vecteurs des Tableaux 11.1 et 11.2.

● Note

Pour aller plus loin.

➢ MITRE ATT&CK [24] ; CIS Benchmarks [2].

● Note

Transition. Une fois des droits obtenus, l'attaquant s'étend et s'installe : c'est la post-exploitation, objet du Chapitre 12.

12

POST-EXPLOITATION, MOUVEMENT LATÉRAL, PERSISTANCE

> « Le testeur laisse le système tel qu'il l'a trouvé ;
> l'attaquant y laisse une porte. »
>
> Principe du cours

Niveau : *Expert* • Chapitres 10 et 11.

✦ Objectifs du chapitre

- ➢ Décrire les objectifs de la post-exploitation : comprendre, s'étendre, durer, atteindre les données.
- ➢ Expliquer les techniques de mouvement latéral et leurs traces.
- ➢ Reconnaître les mécanismes de persistance.
- ➢ Fixer les limites du testeur : démontrer sans installer.
- ➢ Relier chaque technique aux événements qui la détectent.

Question directrice : que fait l'attaquant après être devenu administrateur, et que doit faire le testeur ?

En mars, l'attaquant devenu administrateur a créé un compte, installé un service, copié 40 Go et détruit les sauvegardes. En octobre, Mme NGO MBOCK devenue administratrice s'est arrêtée dans les cinq minutes. Ce chapitre décrit ce qu'un attaquant fait après l'élévation, pour que le défenseur le voie, et ce que le testeur s'interdit.

Plan du chapitre.

1. Les objectifs de la post-exploitation (section 12.1).
2. Le mouvement latéral (section 12.2).
3. La persistance (section 12.3).
4. Les limites du testeur (section 12.4).

© *MaletYon*

5. Ce que voient les journaux (section 12.5).

12.1 Les Objectifs de la Post-Exploitation

Objectif	Tactique ATT&CK	Dans l'Opération GAROUA
Comprendre l'environnement	Découverte	Balayage du réseau, interrogation de l'annuaire
S'étendre	Mouvement latéral	Connexions avec le mot de passe local partagé
Durer	Persistance	Compte svc_maj2, service WinUpd32
Atteindre les données	Collecte, exfiltration	Copie de 40 Go
Agir	Impact	Suppression des sauvegardes, chiffrement

Tableau 12.1. Les objectifs de la post-exploitation [24]

12.2 Le Mouvement Latéral

Définition

Mouvement latéral : ensemble des techniques par lesquelles un attaquant, présent sur une machine, prend le contrôle d'autres machines du réseau, le plus souvent avec des identifiants valides.

Technique	Principe	Trace principale
Services d'administration à distance	Exécution d'une commande par création de service distant	Événement 7045 (service installé)
Bureau à distance	Session graphique	Ouverture de session de type 10
Instrumentation à distance	Exécution par l'interface d'administration Windows	Processus enfant inhabituel
Réutilisation d'empreinte	Authentification NTLM avec le haché, sans le mot de passe	Ouverture de session réseau avec NTLM depuis une machine inhabituelle

Tableau 12.2. Techniques de mouvement latéral et traces

12.3 La Persistance

Mécanisme	Exemple	Trace
Compte créé ou modifié	Compte ajouté aux Admins du domaine	4720, 4728
Service	Service installé au démarrage	7045
Tâche planifiée	Tâche lancée chaque nuit	4698
Clé de démarrage	Programme lancé à l'ouverture de session	Surveillance du registre
Accès distant tiers	Outil de prise de main installé	Inventaire logiciel

Tableau 12.3. Mécanismes de persistance

12.4 Les Limites du Testeur

★ Attention

Violation typique. Installer une persistance « pour montrer qu'on pourrait revenir ».

Règle : le testeur décrit la persistance possible, il ne l'installe pas, sauf exercice d'équipe rouge expressément convenu et tracé (Chapitre 20). Tout compte, fichier ou service créé est listé et supprimé avant la fin de la mission, et la suppression est vérifiée.

☑ Procédure de test

Le nettoyage de fin de mission

1. Relire le journal de mission : tout ce qui a été créé ou modifié.
2. Supprimer comptes, fichiers, services, tâches créés.
3. Restaurer les configurations modifiées.
4. Faire vérifier la suppression par le client.
5. Consigner le nettoyage dans le rapport.

12.5 Ce que Voient les Journaux

🔍 Scénario Opérationnel · Opération LOGONE. Ce que le SOC a vu, et pas vu

Constatations. Le SOC de nuit a reçu les journaux des contrôleurs de domaine et des serveurs de Garoua. Il a signalé le balayage. Il n'a pas corrélé la connexion du compte de la facturation, inhabituelle, à un poste ordinaire, ni sa nouvelle

appartenance au groupe visé.

Analyse (confiance moyenne). Les événements utiles étaient présents ; il manquait les règles. Après l'Opération GAROUA, c'est la seconde fois que les journaux contiennent l'attaque sans que personne ne la lise.

Fiche de constat · T-08 · Comptes d'administration utilisés sur des postes ordinaires

Description : des comptes membres de groupes à privilèges ouvrent des sessions sur des postes de travail. **Preuve :** sessions relevées sur 7 postes de Garoua (26 octobre). **Gravité :** moyenne. **Impact :** exposition de secrets à privilèges en cas de compromission d'un poste. **Recommandation :** appliquer le modèle par niveaux, administrer par le bastion. **Détection :** ouverture de session d'un compte à privilèges sur un poste du niveau inférieur.

Application Analyste SOC et équipe rouge

Écrire une règle par technique jouée. Après chaque test, l'analyste reprend les techniques ATT&CK jouées et vérifie, une par une, qu'une règle les aurait vues ; il écrit celles qui manquent.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Comprendre, s'étendre, durer, atteindre, agir** : les objectifs après l'élévation.
- **Le mouvement latéral** utilise des identifiants valides ; il laisse des traces d'ouverture de session et de services.
- **La persistance** : comptes, services, tâches, clés, outils d'accès.
- **Le testeur décrit, n'installe pas** ; il nettoie et fait vérifier.
- **Les journaux contiennent l'attaque** ; il faut les règles pour la lire.

Note

Points de contrôle de l'élève. Je sais : relier les objectifs aux tactiques ATT&CK ; associer une technique latérale à sa trace ; citer les mécanismes de persistance et leurs événements ; dérouler le nettoyage de fin de mission.

✍ Exercice 12.1. Tactiques ★☆☆

Rangez dans les tactiques d'ATT&CK les actions de l'attaquant de mars entre le 3 et le 5 mars.

✍ Exercice 12.2. Événements ★☆☆

Quel événement Windows signale : la création d'un compte ; l'installation d'un service ; la création d'une tâche planifiée ?

✍ Exercice 12.3. Nettoyage ★☆☆

Pourquoi faire vérifier le nettoyage par le client ?

✍ Exercice 12.4. Réutilisation d'empreinte ★★☆

Pourquoi la réutilisation d'empreinte rend-elle inutile la longueur du mot de passe ? Quelle mesure la bloque ?

✍ Exercice 12.5. Une règle ★★☆

Écrivez en français la règle qui aurait vu la connexion du compte de la facturation sur un poste ordinaire.

✍ Exercice 12.6. Persistance tracée ★★☆

Dans un exercice d'équipe rouge, une persistance est convenue. Quelles règles de traçabilité imposez-vous ?

✍ Exercice 12.7. T-08 ★★☆

Expliquez le lien entre T-08 et le modèle d'administration par niveaux du Chapitre 10.

✍ Exercice 12.8. GAROUA rejoué ★★☆

Pour chaque mécanisme de persistance de l'attaquant de mars, donnez l'événement qui l'aurait signalé.

✍ Exercice 12.9. Couverture ★★★

Construisez la matrice « technique ATT&CK jouée / règle de détection / détecté ou non » de l'Opération LOGONE.

✍ Exercice 12.10. Chasse ★★★

Proposez une recherche proactive de persistance à mener sur le parc de LiZbiZ après l'Opération LOGONE.

Note

Pour aller plus loin.

➢ MITRE ATT&CK [24].

Note

Transition. Presque tous les chemins passent par un mot de passe : le Chapitre 13 traite de leurs attaques et de leurs défenses.

13

MOTS DE PASSE : ATTAQUES ET DÉFENSES

« Un mot de passe que l'on retient facilement
se devine facilement. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 10 ; cours SEC3266, chapitre sur les identités.

✦ Objectifs du chapitre

- ➢ Distinguer les attaques en ligne et hors ligne.
- ➢ Expliquer la force brute, le dictionnaire, la pulvérisation et le bourrage d'identifiants.
- ➢ Comprendre pourquoi le hachage et sa lenteur comptent.
- ➢ Conduire un audit de mots de passe autorisé et en rendre compte sans exposer personne.
- ➢ Proposer une politique conforme au NIST SP 800-63B.

Question directrice : combien de mots de passe de LiZbiZ un attaquant retrouverait-il en un jour ?

Après T-01, M. ETEME demande un audit des mots de passe de l'annuaire, avec un accord écrit et sous contrôle de Mme NKENG. NYONG SÉCURITÉ obtient une copie des empreintes et tente, pendant 24 heures, de retrouver les mots de passe par des listes de mots courants et des règles de transformation. Le résultat est un chiffre, et une politique à revoir.

Plan du chapitre.

1. En ligne ou hors ligne (section 13.1).
2. Les attaques (section 13.2).
3. Le hachage (section 13.3).
4. L'audit de mots de passe (section 13.4).

© MaletYon

5. La politique (section 13.5).

13.1 En Ligne ou Hors Ligne

Attaque	Principe	Limite
En ligne	Essais contre le service (portail, messagerie)	Lente, visible, freinée par le verrouillage et le second facteur
Hors ligne	Essais contre une empreinte volée (base, ticket Kerberos)	Limitée seulement par la puissance de calcul et la lenteur du hachage

Tableau 13.1. Deux familles d'attaques

13.2 Les Attaques

Attaque (ATT&CK T1110)	Principe
Force brute	Toutes les combinaisons jusqu'à une longueur donnée
Dictionnaire et règles	Mots courants, noms, années, transformés (majuscule, chiffre, symbole)
Pulvérisation	Un ou deux mots de passe courants essayés sur de nombreux comptes, pour éviter le verrouillage
Bourrage d'identifiants	Couples identifiant et mot de passe volés ailleurs, réutilisés

Tableau 13.2. Les attaques sur les mots de passe [24]

★ Attention

Violation typique. Croire qu'une règle de complexité (majuscule, chiffre, symbole) rend un mot de passe fort.

Règle : « Lizbiz2026! » respecte la règle et figure dans tout dictionnaire bien conçu. La longueur et l'imprévisibilité comptent ; les règles de transformation des attaquants connaissent les habitudes humaines.

13.3 Le Hachage

Un système stocke une *empreinte* du mot de passe, pas le mot de passe. La vitesse à laquelle l'attaquant peut essayer dépend de la fonction de hachage : une fonction rapide

(comme l'empreinte NT de Windows) permet des milliards d'essais par seconde sur du matériel courant ; une fonction lente et salée, conçue pour les mots de passe (bcrypt, scrypt, Argon2), en permet des milliers. Le sel empêche de casser tous les comptes à la fois.

13.4 L'Audit de Mots de Passe

Procédure de test

Conduire un audit de mots de passe

1. Accord écrit de la direction ; information du délégué du personnel selon les règles internes.
2. Extraction des empreintes par l'administrateur, sur un poste isolé ; copie chiffrée.
3. Cassage hors ligne, durée et méthodes fixées à l'avance.
4. Résultats agrégés ; aucun mot de passe en clair dans le rapport ; liste nominative remise au seul responsable, pour réinitialisation.
5. Destruction des empreintes et des résultats à la fin.

Scénario Opérationnel · Opération LOGONE. Vingt-quatre heures de cassage

Constatations. 160 comptes actifs après la revue de mars. En 24 heures : 38 mots de passe retrouvés (23,75 %), dont 31 dans la première heure. 12 comptes partagent un même mot de passe avec au moins un autre compte. 9 mots de passe retrouvés contiennent « lizbiz ». Aucun compte d'administration n'est retrouvé, sauf celui de T-01, déjà connu.

Analyse (confiance élevée). Un attaquant qui volerait les empreintes ouvrirait près d'un compte sur quatre en une journée. Les mots de passe retrouvés respectent tous la règle de complexité en vigueur.

Fiche de constat · A-01 · Mots de passe prévisibles malgré la règle de complexité

Mission complémentaire : ce constat relève de l'audit des mots de passe, rapporté à part des quatorze constats du test (Chapitre 22). **Description :** 38 mots de passe sur 160 retrouvés en 24 heures. **Preuve :** statistiques agrégées ; liste nominative remise à M. KOUNOU. **Gravité :** moyenne (élevée en cas de vol des empreintes). **Recommandation :** longueur minimale de 12 à 15 caractères, liste de mots interdits (nom de l'entreprise, années), contrôle contre les listes divulguées, second facteur, réinitialisation des 38 comptes. **Détection :** échecs de connexion répartis sur de

nombreux comptes (pulvérisation).

13.5 La Politique

Recommandation (NIST SP 800-63B)	Application chez LiZbiZ
Longueur plutôt que complexité	12 caractères au moins, phrases de passe acceptées
Comparer aux listes de mots de passe compromis	Contrôle à chaque changement
Pas de changement périodique imposé sans motif	Changement en cas de soupçon de compromission
Limiter les essais	Verrouillage progressif, surveillance
Second facteur	Obligatoire pour les accès distants et les comptes à privilèges

Tableau 13.3. Une politique conforme au NIST SP 800-63B [7]

Application RSSI

Rendre compte sans désigner. Le RSSI présente l'audit en chiffres agrégés au comité ; les personnes concernées reçoivent une demande de changement, accompagnée de conseils, et non un reproche.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **En ligne** : lent et visible ; **hors ligne** : limité par le calcul et le hachage.
- **Force brute, dictionnaire, pulvérisation, bourrage** : quatre attaques.
- **Un hachage lent et salé** freine le cassage.
- **Un audit de mots de passe** est autorisé, agrégé, détruit à la fin.
- **Longueur, listes de compromis, second facteur** : la politique du NIST.

Note

Points de contrôle de l'élève. Je sais : distinguer attaques en ligne et hors ligne ; nommer les quatre attaques ; expliquer le rôle du hachage et du sel ; conduire un audit de mots de passe ; rédiger une politique conforme.

✍ Exercice 13.1. Le taux ★☆☆

Calculez le taux de mots de passe retrouvés en une heure et en 24 heures.

✍ Exercice 13.2. Quelle attaque ? ★☆☆

Nommez l'attaque : « Ete2026! » essayé sur 160 comptes ; les identifiants d'un site piraté essayés sur la messagerie de LiZbiZ.

✍ Exercice 13.3. Le sel ★☆☆

À quoi sert le sel dans le hachage d'un mot de passe ?

✍ Exercice 13.4. Complexité ★★☆

Pourquoi « Lizbiz2026! » respecte-t-il la règle de complexité et se casse-t-il vite ?

✍ Exercice 13.5. Pulvérisation ★★☆

Pourquoi la pulvérisation échappe-t-elle au verrouillage de compte ? Comment la détecter ?

✍ Exercice 13.6. Rapport ★★☆

Rédigez la section du rapport sur l'audit de mots de passe, sans exposer personne.

✍ Exercice 13.7. Réutilisation ★★☆

12 comptes partagent un mot de passe. Quel risque ? Que faire ?

✍ Exercice 13.8. Hachage ★★☆

Comparez l'empreinte NT et Argon2 du point de vue d'un attaquant hors ligne.

✍ Exercice 13.9. L'accord ★★★

Rédigez l'accord écrit d'audit des mots de passe : objet, méthodes, durée, données, destruction, information des salariés.

✍ Exercice 13.10. Politique ★★★

Rédigez la nouvelle politique de mots de passe de LiZbiZ et le plan de sa mise en œuvre.

● Note

Pour aller plus loin.

➢ NIST SP 800-63B [7] ; MITRE ATT&CK [24].

Note

Transition. La Partie IV passe des systèmes aux applications : le Chapitre 14 apprend à tester une application web.

partie IV

Applications et Nuage

© MaletYon

14

TESTER UNE APPLICATION WEB

« Une application web fait confiance à ce que le navigateur lui envoie ;
le testeur, lui, n'utilise pas forcément un navigateur. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 4 ; cours SEC3266, chapitre sur la sécurité applicative.

✦ Objectifs du chapitre

- ➢ Décrire une application web du point de vue du testeur : requêtes, réponses, état, session.
- ➢ Utiliser le guide de test de l'OWASP (WSTG) pour structurer une campagne.
- ➢ Cartographier une application : pages, paramètres, rôles.
- ➢ Tester l'authentification et la gestion de session.
- ➢ Lire un historique HTTP pour y repérer une faiblesse.
- ➢ Classer les constats selon le Top 10 de l'OWASP.

Question directrice : par où commencer le test d'un portail que l'on ne connaît pas ?

Le portail de suivi des colis de LiZbiZ permet aux clients de voir leurs expéditions et à 40 agents de les mettre à jour. M. TAMO reçoit deux comptes de test, un client et un agent, et l'adresse du portail de pré-production. Il dispose de 48 heures. Ce chapitre montre comment cartographier, puis tester méthodiquement, plutôt que d'essayer au hasard.

Plan du chapitre.

1. L'application vue par le testeur (section 14.1).
2. Le guide de test de l'OWASP (section 14.2).

3. Cartographier (section 14.3).
4. Authentification et session (section 14.4).
5. Lire un historique HTTP (section 14.5).
6. Classer selon le Top 10 (section 14.6).

14.1 L'Application vue par le Testeur

Définition

Requête HTTP : message envoyé par le client au serveur (méthode, chemin, en-têtes, corps). **Réponse HTTP** : message du serveur (code, en-têtes, corps). **Session** : état conservé entre requêtes, le plus souvent par un cookie (RFC 6265).

Le testeur observe et modifie chaque requête avant son envoi. Un serveur qui se fie à un contrôle fait côté navigateur (champ masqué, menu grisé, vérification en JavaScript) accepte une requête forgée qui ignore ce contrôle. La règle fondatrice du test web : *tout ce qui vient du client est contrôlable par le client.*

14.2 Le Guide de Test de l'OWASP

Le **Web Security Testing Guide** (WSTG) de l'OWASP organise le test d'une application web en catégories [16]. On ne les parcourt pas toutes à chaque mission ; on choisit selon le périmètre et le temps.

Catégorie WSTG	Ce qu'on y vérifie
Collecte d'informations	Technologies, points d'entrée, pages cachées
Configuration	En-têtes, méthodes autorisées, messages d'erreur
Gestion d'identité et authentification	Création de compte, connexion, réinitialisation
Gestion de session	Cookies, expiration, déconnexion
Contrôle d'accès	Un rôle peut-il atteindre les données d'un autre ?
Validation des entrées	Injections, scripts, chemins (Chapitre 15)
Logique métier	Enchaînements non prévus, contournement d'étapes

Tableau 14.1. Catégories du WSTG retenues pour LiZbiZ

14.3 Cartographier

Procédure de test

Cartographier une application web

1. Parcourir l'application avec chaque rôle, en enregistrant les requêtes dans un relais local autorisé.
2. Lister les pages, les points d'entrée et leurs paramètres.
3. Noter les en-têtes, les cookies, les technologies détectées.
4. Repérer les paramètres qui désignent un objet (numéro de colis, identifiant de compte).
5. Dresser la matrice rôle par page, pour préparer les tests de contrôle d'accès.

★ Attention

Violation typique. Lancer un robot d'exploration agressif sur la pré-production sans prévenir.

Règle : l'exploration automatique crée des données, envoie des courriels, déclenche des traitements. On fixe la cadence avec le client, on évite les formulaires d'envoi, on prévient l'équipe d'exploitation.

14.4 Authentification et Session

Point testé	Faiblesse recherchée
Robustesse de la connexion	Verrouillage absent, énumération des comptes par les messages
Réinitialisation de mot de passe	Jeton prévisible, lien qui n'expire pas
Cookie de session	Absence des attributs de sécurité (indisponible au script, réservé au canal chiffré)
Expiration	Session valide trop longtemps, pas d'invalidation à la déconnexion
Second facteur	Absent sur les comptes sensibles

Tableau 14.2. Tests d'authentification et de session

Scénario Opérationnel · Opération LOGONE. Le portail qui ne ferme pas la session

Constatations. Sur le portail de suivi, le cookie de session n'a pas l'attribut qui le réserve au canal chiffré ; à la déconnexion, le jeton reste valide 8 heures. Un message de connexion distingue « compte inconnu » de « mot de passe erroné », ce qui permet

d'énumérer les comptes.

Analyse (confiance élevée). Aucune de ces faiblesses n'est critique seule ; ensemble, elles facilitent le vol et la réutilisation de session. Elles alimentent le constat T-14 (délai de session trop long) du rapport.

14.5 Lire un Historique HTTP

L'essentiel du test web se lit dans l'historique des requêtes et des réponses. Le lab HE2-LAB-08 fournit un historique exporté ; l'élève y cherche les points d'entrée, les paramètres d'objet, les en-têtes manquants et les codes de réponse révélateurs.

Indice	Ce qu'il peut révéler
Paramètre numérique d'objet	Référence directe, à tester pour l'accès indirect (Chapitre 15)
Code 500	Erreur serveur, message parfois bavard
En-tête de version	Technologie et version, utile à l'attaquant
Absence d'en-têtes de sécurité	Protection du navigateur non activée
Réponse différente selon le compte	Énumération possible

Tableau 14.3. Lire un historique HTTP

14.6 Classer selon le Top 10

Le **Top 10** de l'OWASP classe les grandes familles de risques des applications web [17]. Il sert à ranger les constats et à parler un langage commun avec les équipes de développement.

Fiche de constat · T-12 · En-têtes de sécurité HTTP absents

Description : le portail de suivi ne renvoie pas les en-têtes de sécurité recommandés (politique de contenu, type de contenu strict, transport strict). **Preuve :** réponses relevées dans l'historique. **Gravité :** faible. **Impact :** protections du navigateur non activées ; aggrave d'autres failles. **Recommandation :** ajouter les en-têtes au niveau du serveur ou de l'application. **Détection :** contrôle périodique des en-têtes de réponse.

Application Pentesteur et développeur

Rapprocher le constat du code. Le pentesteur décrit la requête qui démontre la faille ; le développeur retrouve, à partir d'elle, la ligne de code responsable. Un bon constat web contient toujours la requête exacte.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Tout ce qui vient du client** est contrôlable par le client.
- **Le WSTG** structure la campagne en catégories.
- **Cartographier d'abord** : pages, paramètres, rôles.
- **Authentification et session** : verrouillage, cookies, expiration.
- **L'historique HTTP** contient l'essentiel des indices.
- **Le Top 10** range les constats et parle aux développeurs.

● Note

Points de contrôle de l'élève. Je sais : décrire requête, réponse et session ; choisir des catégories du WSTG ; cartographier une application ; tester authentification et session ; lire un historique HTTP ; classer un constat dans le Top 10.

✍ Exercice 14.1. Confiance au client ★☆☆

Pourquoi un contrôle fait uniquement en JavaScript ne protège-t-il pas le serveur ?

✍ Exercice 14.2. Catégories ★☆☆

Citez trois catégories du WSTG et un test pour chacune.

✍ Exercice 14.3. Cookie ★☆☆

À quoi servent les attributs « réservé au canal chiffré » et « indisponible au script » d'un cookie de session ?

✍ Exercice 14.4. Énumération ★★☆

Pourquoi un message de connexion qui distingue « compte inconnu » de « mot de passe erroné » est-il une faiblesse ? Quel message proposer ?

✍ Exercice 14.5. Cartographie ★★☆

Décrivez la matrice rôle par page du portail de suivi, avec les deux comptes de test.

✍ Exercice 14.6. Exploration prudente ★★☆

Quelles précautions prenez-vous avant de lancer une exploration automatique sur la pré-production ?

✍ Exercice 14.7. Historique ★★☆

Dans un historique, quels éléments trahissent un paramètre d'objet à tester ?

✍ Exercice 14.8. Session ★★☆

Rédigez le constat du cookie de session sans attribut de canal chiffré et sans invalidation à la déconnexion.

✍ Exercice 14.9. Plan WSTG ★★★

Établissez le plan de test, en catégories du WSTG, pour les 48 heures accordées à M. TAMO.

✍ Exercice 14.10. Top 10 ★★★

Rattachez chacun des constats web de l'Opération LOGONE à une catégorie du Top 10, en justifiant.

Note

Pour aller plus loin.

➢ OWASP WSTG [16] ; OWASP Top 10 [17].

Note

Transition. La catégorie la plus riche du test web est celle des entrées mal validées : le Chapitre 15 traite les injections et les défauts de contrôle d'accès.

15

INJECTIONS ET CONTRÔLE D'ACCÈS

« L'injection confond la donnée et la commande ;
le défaut d'accès confond l'identité et le droit. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 14 ; cours SEC3266, chapitre sur la sécurité applicative.

✦ Objectifs du chapitre

- ➢ Expliquer le mécanisme commun à toutes les injections.
- ➢ Reconnaître l'injection de requête de base de données et l'exécution de script dans le navigateur.
- ➢ Comprendre la référence directe non contrôlée à un objet.
- ➢ Distinguer contrôle d'accès horizontal et vertical.
- ➢ Tester sans endommager ni divulguer de données réelles.
- ➢ Rédiger les constats et leurs corrections.

Question directrice : pourquoi changer un seul chiffre dans une adresse donne-t-il accès au colis d'un autre client ?

Sur le portail de suivi, M. TAMO, connecté avec le compte client de test, remarque que l'adresse d'une page contient le numéro de son colis. Il remplace ce numéro par un autre : le portail affiche le colis d'un autre client, nom et adresse compris. Aucune injection, aucun outil : un simple défaut de contrôle d'accès. C'est le constat T-05.

Plan du chapitre.

1. Le mécanisme de l'injection (section 15.1).
2. Injection de requête et script dans le navigateur (section 15.2).
3. La référence directe à un objet (section 15.3).
4. Horizontal et vertical (section 15.4).

© MaletYon

5. Tester sans nuire (section 15.5).

15.1 Le Mécanisme de l'Injection

Définition

Injection : faille par laquelle une donnée fournie par l'utilisateur est interprétée comme une commande par un système en aval (base de données, interpréteur, navigateur), faute de séparation entre la donnée et la commande.

La parade est toujours la même : séparer la donnée de la commande (requêtes préparées, échappement selon le contexte, validation stricte des entrées). Le testeur, lui, cherche les endroits où cette séparation manque.

15.2 Injection de Requête et Script dans le Navigateur

Famille	Principe	Parade
Injection de requête de base de données	Une entrée modifie la requête exécutée	Requêtes préparées, paramètres liés
Script dans le navigateur	Une entrée renvoyée par la page s'exécute chez un autre visiteur	Échappement à la sortie, politique de contenu
Injection de commande système	Une entrée atteint un interpréteur du serveur	Éviter l'appel système, listes blanches

Tableau 15.1. Trois familles d'injection

Attention

Violation typique. Prouver une injection de base de données par une commande destructrice.

Règle : on démontre la faille par une preuve inoffensive (délai, valeur calculée, erreur contrôlée), jamais par une modification ou une suppression de données. On ne lit pas non plus les données réelles au-delà de ce qui prouve la faille.

15.3 La Référence Directe à un Objet

Définition

Référence directe non contrôlée à un objet : l'application désigne un objet (colis, compte, facture) par un identifiant visible, et ne vérifie pas que l'utilisateur a le droit d'y accéder. Changer l'identifiant donne accès à l'objet d'autrui.

Scénario Opérationnel · Opération LOGONE. Le colis du voisin

Constatation. Le portail affiche un colis à partir de son numéro, passé dans l'adresse, sans vérifier qu'il appartient au client connecté. En incrémentant le numéro, on accède aux colis d'autres clients : nom, téléphone, adresse de livraison.

Analyse (confiance élevée). La preuve est faite sur trois colis du compte de test et un colis voisin, puis arrêtée. L'impact théorique porte sur l'ensemble des expéditions. C'est le constat T-05, de gravité élevée.

Fiche de constat · T-05 · Accès indirect aux colis d'autrui

Description : le portail ne vérifie pas la propriété du colis désigné par son numéro. **Preuve :** requêtes sur quatre numéros, captures masquées. **Gravité :** élevée. **Impact :** divulgation des données de livraison de tous les clients. **Recommandation :** vérifier, à chaque accès, que l'objet appartient à l'utilisateur (contrôle côté serveur) ; identifiants non devinables. **Détection :** un compte qui consulte de nombreux colis qui ne sont pas les siens.

15.4 Horizontal et Vertical

Défaut d'accès	Exemple au portail
Horizontal	Un client accède aux données d'un autre client (T-05)
Vertical	Un client accède à une fonction réservée aux agents (mise à jour d'un colis)

Tableau 15.2. Deux défauts de contrôle d'accès

15.5 Tester sans Nuire

Procédure de test

Tester une référence directe à un objet, proprement

1. Repérer l'identifiant d'objet dans l'adresse ou le corps.
2. Avec un second compte de test, vérifier d'abord sur ses propres objets.
3. Tenter l'accès à un objet voisin ; s'arrêter à la première preuve.
4. Ne pas parcourir l'ensemble : la preuve suffit.
5. Masquer les données réelles dans le rapport.

Application Pentesteur et auditeur de sécurité

La preuve minimale. Une faille d'accès se prouve avec deux comptes et un objet voisin. L'auditeur qui télécharge toute la base pour « mesurer l'impact » dépasse son mandat et crée un risque ; l'impact se décrit, il ne se collecte pas.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'injection** confond donnée et commande ; la parade est de les séparer.
- **Requête, script, commande** : trois familles.
- **La référence directe à un objet** donne accès à l'objet d'autrui.
- **Horizontal** (autre utilisateur) et **vertical** (fonction réservée).
- **La preuve minimale** : deux comptes, un objet voisin, puis on s'arrête.

Note

Points de contrôle de l'élève. Je sais : expliquer le mécanisme d'injection ; nommer les trois familles ; définir la référence directe à un objet ; distinguer accès horizontal et vertical ; tester sans nuire.

Exercice 15.1. Mécanisme ★☆☆

En une phrase, qu'ont en commun toutes les injections ?

Exercice 15.2. Familles ★☆☆

Associez à chaque famille sa parade principale.

Exercice 15.3. T-05 ★☆☆

Pourquoi T-05 n'est-il pas une injection ?

Exercice 15.4. Preuve inoffensive ★★☆

Comment prouver une injection de base de données sans modifier ni lire de données réelles ?

Exercice 15.5. Horizontal ou vertical ★★☆

Classez : un client lit le colis d'un autre ; un client met à jour un colis alors que seuls les agents le peuvent.

✍ Exercice 15.6. Correction ★★☆

Rédigez la correction de T-05 pour l'équipe de développement.

✍ Exercice 15.7. Détection ★★☆

Quelle règle de détection signalerait l'exploitation de T-05 en production ?

✍ Exercice 15.8. Script ★★☆

Pourquoi un script renvoyé par la page met-il en danger un autre visiteur, et non le serveur ?

✍ Exercice 15.9. Procédure ★★★

Adaptez la procédure de test de référence directe au cas des factures d'un portail comptable.

✍ Exercice 15.10. Mandat ★★★

Un client demande « la preuve que toutes les données sont exposées ». Rédigez une réponse qui respecte le principe de la preuve minimale.

● Note

Pour aller plus loin.

➢ OWASP Top 10 [17] ; OWASP WSTG [16].

● Note

Transition. Les applications modernes exposent des interfaces de programmation et des applications mobiles : le Chapitre 16 leur est consacré.

16

INTERFACES DE PROGRAMMATION ET APPLICATIONS MOBILES

« L'application mobile n'est qu'une façade ;
le vrai test porte sur l'interface qu'elle appelle. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 15.

✦ Objectifs du chapitre

- ➢ Décrire une interface de programmation (API) du point de vue du testeur.
- ➢ Reconnaître les risques du Top 10 des API de l'OWASP, à commencer par le défaut d'accès au niveau de l'objet.
- ➢ Comprendre pourquoi l'application mobile ne protège pas le serveur.
- ➢ Tester une application mobile selon le standard MASVS.
- ➢ Rédiger les constats d'une mission mobile.

Question directrice : l'application mobile de LiZbiZ est-elle plus sûre que son portail web ?

En juillet, avant le test principal, LiZbiZ confie à NYONG SÉCURITÉ un test de son application mobile de suivi, l'Opération MEFOU. L'équipe découvre vite que l'application n'est qu'une fenêtre : toute la logique est dans l'interface de programmation qu'elle appelle, et c'est là que se trouvent les faiblesses. Six constats en ressortent.

Plan du chapitre.

1. L'interface de programmation vue par le testeur (section 16.1).
2. Le Top 10 des API (section 16.2).
3. La façade mobile (section 16.3).
4. Tester le mobile avec le MASVS (section 16.4).

5. L'Opération MEFOU (section 16.5).

16.1 L'Interface de Programmation vue par le Testeur

Définition

Interface de programmation (API) : ensemble de points d'entrée par lesquels des programmes échangent des données, le plus souvent en HTTP, avec des messages structurés. Le testeur l'interroge directement, sans passer par l'application qui s'en sert.

Une interface de programmation reçoit souvent moins d'attention que le site web : pas d'écran, pas de visiteur humain, l'illusion qu'elle est « interne ». C'est une erreur : elle est aussi exposée, et porte la logique métier.

16.2 Le Top 10 des API

Risque (OWASP API 2023)	Question du testeur
Accès au niveau de l'objet	Puis-je lire ou modifier l'objet d'un autre en changeant son identifiant ?
Authentification défaillante	Les jetons sont-ils solides, expirent-ils ?
Accès au niveau d'une propriété	Puis-je lire ou écrire un champ qui ne m'est pas destiné ?
Consommation de ressources	Puis-je épuiser le service par des appels massifs ?
Accès au niveau de la fonction	Puis-je appeler une fonction réservée à un administrateur ?

Tableau 16.1. Principaux risques des API [19]

Le premier risque, le défaut d'accès au niveau de l'objet, est l'équivalent de la référence directe du Chapitre 15, appliqué aux interfaces de programmation : c'est le plus fréquent et le plus grave.

16.3 La Façade Mobile

Attention

Violation typique. Croire qu'un contrôle présent dans l'application mobile protège le service.

Règle : tout ce que fait l'application mobile, un programme peut le refaire en appelant directement l'interface, sans ses contrôles. Une clé cachée dans l'application n'est pas secrète : elle se lit dans le paquet installé.

16.4 Tester le Mobile avec le MASVS

Le **standard de vérification de la sécurité des applications mobiles** (MASVS) de l'OWASP fixe les exigences à vérifier [18].

Domaine MASVS	Ce qu'on vérifie
Stockage des données	Secrets, jetons, données personnelles stockés en clair sur l'appareil
Communication réseau	Chiffrement du canal, contrôle du certificat
Authentification	Jetons, biométrie, verrouillage
Code et résistance	Secrets codés en dur, journaux bavards

Tableau 16.2. Domaines du MASVS

16.5 L'Opération MEFOU

Scénario Opérationnel · Opération MEFOU. Six constats sur le mobile

Constatations (juillet 2026). (1) L'application stocke le jeton de session en clair sur l'appareil. (2) Le service ne vérifie pas la propriété de l'objet demandé : un colis d'autrui est accessible par son numéro. (3) Une fonction d'administration est appelable par un compte ordinaire. (4) Le canal accepte un certificat non vérifié. (5) Une clé de service est codée en dur dans l'application. (6) Les journaux de l'application contiennent des données personnelles.

Analyse (confiance élevée). Les constats (2) et (3), des défauts d'accès, sont les plus graves ; ils préfigurent le constat T-05 du test principal. L'application a été corrigée avant octobre, sauf le service, dont le défaut d'accès subsiste et devient T-05.

Application Pentesteur et RSSI

Tester le service, pas l'écran. Pour une application mobile, le pentesteur intercepte le trafic et rejoue les appels sans l'application ; le RSSI retient que corriger l'application ne corrige pas le service, et que le service doit refaire tous les contrôles.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'interface de programmation** porte la logique ; on l'interroge directement.
- **Le défaut d'accès au niveau de l'objet** est le premier risque des API.
- **L'application mobile est une façade** ; ses contrôles ne protègent pas le

service.

- **Le MASVS** structure le test mobile.
- **MEFOU** a montré, dès juillet, le défaut d'accès devenu T-05.

Note

Points de contrôle de l'élève. Je sais : décrire une API pour le test ; citer les risques du Top 10 des API ; expliquer pourquoi le mobile ne protège pas le service ; nommer les domaines du MASVS ; relier MEFOU à T-05.

✍ Exercice 16.1. API ★☆☆

Pourquoi teste-t-on une interface de programmation directement, sans l'application qui l'utilise ?

✍ Exercice 16.2. Premier risque ★☆☆

Quel est le premier risque du Top 10 des API ? À quoi correspond-il dans le chapitre précédent ?

✍ Exercice 16.3. Clé cachée ★☆☆

Pourquoi une clé « cachée » dans une application mobile n'est-elle pas secrète ?

✍ Exercice 16.4. Façade ★★☆

Un développeur affirme que l'application empêche l'accès au colis d'autrui. Que lui répondez-vous ?

✍ Exercice 16.5. MASVS ★★☆

Pour chacun des six constats de MEFOU, donnez le domaine MASVS concerné.

✍ Exercice 16.6. MEFOU vers T-05 ★★☆

Expliquez pourquoi le défaut d'accès de MEFOU se retrouve en octobre comme T-05.

✍ Exercice 16.7. Interception ★★☆

Décrivez, sans outil précis, comment on observe les appels d'une application mobile lors d'un test autorisé.

✍ Exercice 16.8. Correction ★★☆

Rédigez la correction du constat « fonction d'administration appelable par un compte ordinaire ».

✍ Exercice 16.9. Plan API ★★★

Établissez le plan de test de l'interface de programmation de LiZbiZ selon le Top 10 des API.

✍ Exercice 16.10. Note au comité ★★★

Rédigez une note qui explique au comité pourquoi « l'application a été corrigée » ne suffit pas.

● Note

Pour aller plus loin.

➢ OWASP API Security Top 10 [19] ; OWASP MASVS [18].

● Note

Transition. Les services de LiZbiZ migrent vers le nuage : le Chapitre 17 traite du test des environnements en nuage et des conteneurs.

17

TESTER LE NUAGE ET LES CONTENEURS

> « Dans le nuage, la faille n'est presque jamais celle du fournisseur ; c'est celle de la configuration du client. »
>
> Principe du cours

Niveau : *Expert* • Chapitre 16 ; notions d'administration système.

✦ Objectifs du chapitre

- ➢ Expliquer le modèle de responsabilité partagée.
- ➢ Reconnaître les erreurs de configuration les plus courantes dans le nuage.
- ➢ Comprendre le risque des secrets et des droits trop larges.
- ➢ Décrire les faiblesses des conteneurs et de leur orchestration.
- ➢ Tester un environnement en nuage dans les limites du contrat avec le fournisseur.

Question directrice : à qui appartient la faille quand le service est hébergé chez un fournisseur ?

LiZbiZ héberge son nouveau portail et sa base chez un fournisseur de nuage. M. KOUNOU pense que la sécurité « est comprise dans l'abonnement ». Le test montre le contraire : le fournisseur sécurise son socle, mais la configuration, les droits et les secrets restent la responsabilité de LiZbiZ, et c'est là que sont les faiblesses.

Plan du chapitre.

1. La responsabilité partagée (section 17.1).
2. Les erreurs de configuration (section 17.2).
3. Secrets et droits (section 17.3).
4. Conteneurs et orchestration (section 17.4).
5. Tester dans les limites du contrat (section 17.5).

17.1 La Responsabilité Partagée

Définition

Modèle de responsabilité partagée : répartition des tâches de sécurité entre le fournisseur de nuage (socle matériel, virtualisation, services de base) et le client (configuration, droits, données, applications). La frontière dépend du service souscrit.

17.2 Les Erreurs de Configuration

Erreur fréquente	Conséquence
Espace de stockage ouvert au public	Fichiers et sauvegardes lisibles par tous
Service d'administration exposé	Console ou base accessible depuis l'Internet
Journalisation désactivée	Aucune trace en cas d'incident
Chiffrement non activé	Données au repos en clair
Réseau trop ouvert	Règles de filtrage permissives

Tableau 17.1. Erreurs de configuration courantes

17.3 Secrets et Droits

Deux risques dominent le nuage : les **secrets** (clés d'accès, jetons) laissés dans le code, les images ou les dépôts ; et les **droits** trop larges accordés à un compte ou à une machine, qui permettent, depuis une ressource compromise, d'atteindre tout l'environnement.

Attention

Violation typique. Utiliser une clé d'accès trouvée pour agir au-delà du périmètre.

Règle : une clé découverte se signale et se démontre dans la limite stricte du périmètre convenu. On ne crée pas de ressources, on ne touche pas aux données des autres clients du fournisseur, on respecte les règles de test de celui-ci.

17.4 Conteneurs et Orchestration

Faiblesse	Risque
Image non à jour	Vulnérabilités connues embarquées
Conteneur privilégié	Sortie du conteneur vers l'hôte
Secret dans l'image	Clé lisible par qui tire l'image
Tableau de bord d'orchestration exposé	Contrôle du groupe de conteneurs
Absence de limites	Un conteneur épuise l'hôte

Tableau 17.2. Faiblesses des conteneurs

17.5 Tester dans les Limites du Contrat

Procédure de test

Avant un test en nuage

1. Lire les règles de test du fournisseur ; certaines actions sont interdites ou exigent une déclaration.
2. Délimiter les comptes et ressources du périmètre.
3. Convenir des actions permises (lecture de configuration, oui ; création de ressources, non).
4. Prévoir la conduite en cas de découverte d'un secret.
5. Vérifier que l'environnement testé n'est pas partagé avec d'autres clients.

Fiche de constat · T-10 · Service de test exposé sur l'Internet

Description : une interface de programmation de test, hébergée dans le nuage, est accessible publiquement sans authentification. **Preuve :** adresse et réponse obtenue (données masquées). **Gravité :** moyenne. **Impact :** divulgation de données de test, parfois proches des données réelles ; point d'entrée. **Recommandation :** restreindre l'accès, authentifier, retirer les environnements de test inutiles. **Détection :** inventaire périodique des services exposés.

Application Auditeur de sécurité et RSSI

Auditer la configuration, pas le fournisseur. L'audit du nuage porte sur ce que le client configure : droits, secrets, exposition, journalisation. Les référentiels de configuration sécurisée (CIS) donnent la liste des points à vérifier.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **La responsabilité est partagée** ; la faille est presque toujours côté client.
- **Les erreurs de configuration** (stockage ouvert, service exposé) dominent.
- **Secrets et droits trop larges** sont les deux grands risques.
- **Les conteneurs** ajoutent leurs faiblesses propres.
- **Le test en nuage** respecte les règles du fournisseur.

Note

Points de contrôle de l'élève. Je sais : expliquer la responsabilité partagée ; citer les erreurs de configuration ; expliquer le risque des secrets et des droits ; décrire les faiblesses des conteneurs ; préparer un test en nuage conforme.

✍ Exercice 17.1. Frontière ★☆☆

Qui, du fournisseur ou du client, est responsable de la configuration des droits d'accès ?

✍ Exercice 17.2. Stockage ouvert ★☆☆

Pourquoi un espace de stockage ouvert au public est-il dangereux ?

✍ Exercice 17.3. Secret ★☆☆

Citez trois endroits où un secret peut traîner dans un environnement en nuage.

✍ Exercice 17.4. Droits larges ★★☆

Expliquez comment des droits trop larges transforment une ressource compromise en compromission de tout l'environnement.

✍ Exercice 17.5. Conteneur privilégié ★★☆

Pourquoi un conteneur privilégié met-il en danger l'hôte ?

✍ Exercice 17.6. Clé trouvée ★★☆

Vous découvrez une clé d'accès valide. Que faites-vous, et que ne faites-vous pas ?

✍ Exercice 17.7. T-10 ★★☆

Rédigez le plan de correction de T-10.

✍ Exercice 17.8. Règles du fournisseur ★★☆

Pourquoi faut-il lire les règles de test du fournisseur avant un test en nuage ?

✍ Exercice 17.9. Audit de configuration ★★★

Construisez une liste de contrôle de dix points pour auditer la configuration en nuage de LiZbiZ.

✍ Exercice 17.10. Responsabilité ★★★

Rédigez une note qui clarifie, service par service, la frontière de responsabilité entre LiZbiZ et son fournisseur.

Note

Pour aller plus loin.

➢ CIS Benchmarks [2] ; MITRE ATT&CK [24].

Note

Transition. La Partie V ouvre sur les tests au-delà du système d'information classique : le Chapitre 18 traite du sans-fil et des objets connectés.

partie V

Au-delà des Systèmes

© *MaletYon*

18

SANS-FIL ET OBJETS CONNECTÉS

« Le réseau filaire s'arrête aux murs ;
le réseau sans-fil franchit la rue. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 9 ; notions de réseaux radio.

✦ Objectifs du chapitre

- ➢ Décrire les faiblesses des réseaux sans-fil d'entreprise.
- ➢ Comprendre le point d'accès pirate et le portail jumeau.
- ➢ Reconnaître les risques des objets connectés.
- ➢ Tester un réseau sans-fil dans un cadre légal et autorisé.
- ➢ Rédiger les constats et les mesures de cloisonnement.

Question directrice : jusqu'où porte le réseau de l'entrepôt, et qui peut l'écouter ?

L'entrepôt de Douala utilise un réseau sans-fil pour ses lecteurs de codes et ses imprimantes d'étiquettes. Depuis le parking, Mme NGO MBOCK capte le signal. Ce chapitre explique les risques du sans-fil et des objets connectés, et comment les tester sans intercepter les communications de tiers.

Plan du chapitre.

1. Les faiblesses du sans-fil (section 18.1).
2. Point d'accès pirate et portail jumeau (section 18.2).
3. Les objets connectés (section 18.3).
4. Tester légalement (section 18.4).

© MaletYon

18.1 Les Faiblesses du Sans-Fil

Faiblesse	Risque
Clé partagée faible	Déchiffrement du trafic après capture
Protocole ancien	Attaques connues sur le chiffrement
Réseau invité relié au réseau interne	Un visiteur atteint les serveurs
Absence de cloisonnement	Un lecteur compromis atteint la bureautique
Identifiants par défaut sur les bornes	Prise de contrôle de la borne

Tableau 18.1. Faiblesses des réseaux sans-fil

18.2 Point d'Accès Pirate et Portail Jumeau

Définition

Point d'accès pirate : borne non autorisée branchée sur le réseau de l'entreprise, qui ouvre une porte dérobée. **Portail jumeau** : fausse borne qui imite le nom du réseau légitime pour capter les connexions et les identifiants des usagers.

Attention

Violation typique. Monter un portail jumeau sur le lieu de travail et capter les connexions des salariés.

Règle : capter les communications d'autrui est une infraction pénale (Chapitre 2). Un test de portail jumeau n'est permis que sur un réseau et des comptes dédiés au test, avec accord écrit, sans toucher aux usagers réels.

18.3 Les Objets Connectés

Les objets connectés (lecteurs, imprimantes, caméras, capteurs) partagent des faiblesses récurrentes : identifiants par défaut, micrologiciel non mis à jour, services d'administration ouverts, absence de chiffrement. Branchés sur le même réseau que la bureautique, ils deviennent un point d'entrée.

Scénario Opérationnel · Opération LOGONE. L'imprimante d'étiquettes

Constatation. À Douala, les imprimantes d'étiquettes conservent le mot de passe d'administration par défaut et sont sur le même réseau que les postes. L'une d'elles expose une interface web d'administration.

Analyse (confiance moyenne). Une imprimante compromise sert de point d'appui discret ; le constat rejoint T-04 (identifiants par défaut). La correction tient surtout au cloisonnement du réseau des objets.

Fiche de constat · T-04 · Identifiants par défaut sur des équipements

Description : imprimantes et une borne gardent leur mot de passe d'administration d'usine. **Preuve :** accès aux interfaces d'administration (sans modification). **Gravité :** moyenne. **Impact :** prise de contrôle d'équipements, point d'appui sur le réseau. **Recommandation :** changer les mots de passe, cloisonner le réseau des objets, inventorier. **Détection :** connexions d'administration depuis des adresses inhabituelles.

18.4 Tester Légalement

Procédure de test

Encadrer un test sans-fil

1. Autorisation écrite précisant les réseaux visés et le lieu.
2. Réseau et comptes dédiés au test pour tout essai de capture.
3. Pas d'interception des communications de tiers.
4. Inventaire des objets connectés avant les essais.
5. Restitution des équipements dans leur état initial.

Application Pentesteur et administrateur réseau

Cloisonner d'abord. La meilleure réponse au risque sans-fil et objets n'est pas l'audit répété, mais le cloisonnement : un réseau séparé pour les objets, un réseau invité coupé du réseau interne.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le sans-fil franchit les murs** ; sa portée dépasse le bâtiment.
- **Point d'accès pirate** et **portail jumeau** sont les deux menaces majeures.
- **Les objets connectés** cumulent identifiants par défaut et absence de mise à jour.
- **Capter les communications d'autrui** est une infraction ; on teste sur des réseaux dédiés.
- **Le cloisonnement** est la première parade.

Note

Points de contrôle de l'élève. Je sais : citer les faiblesses du sans-fil ; définir point d'accès pirate et portail jumeau ; décrire les risques des objets connectés ; encadrer légalement un test sans-fil.

✍ Exercice 18.1. Portée ★☆☆

Pourquoi le réseau sans-fil de l'entrepôt est-il captable depuis le parking ?

✍ Exercice 18.2. Jumeau ★☆☆

Quelle est la différence entre un point d'accès pirate et un portail jumeau ?

✍ Exercice 18.3. Objets ★☆☆

Citez trois faiblesses récurrentes des objets connectés.

✍ Exercice 18.4. Légalité ★★☆

Pourquoi un test de portail jumeau sur les salariés réels est-il interdit ? Comment le mener légalement ?

✍ Exercice 18.5. T-04 ★★☆

Rédigez la correction de T-04 pour l'entrepôt de Douala.

✍ Exercice 18.6. Cloisonnement ★★☆

Décrivez le cloisonnement réseau à mettre en place pour les objets connectés.

✍ Exercice 18.7. Réseau invité ★★☆

Pourquoi un réseau invité relié au réseau interne est-il dangereux ?

✍ Exercice 18.8. Inventaire ★★☆

Pourquoi commence-t-on un test d'objets connectés par un inventaire ?

✍ Exercice 18.9. Plan ★★★

Rédigez le plan d'un test sans-fil autorisé pour l'entrepôt, de l'autorisation à la restitution.

✍ Exercice 18.10. Architecture ★★★

Proposez une architecture réseau qui sépare bureautique, objets et invités.

Note

Pour aller plus loin.

➢ MITRE ATT&CK [24].

Note

Transition. La faiblesse la plus universelle n'est pas technique : le Chapitre 19 traite de l'ingénierie sociale.

19

INGÉNIERIE SOCIALE

« On ne teste pas les personnes pour les prendre en défaut ;
on teste un dispositif pour mieux les protéger. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 2 ; cours SEC3266, chapitre sur le facteur humain.

✦ Objectifs du chapitre

- ➢ Définir l'ingénierie sociale et ses principaux leviers.
- ➢ Décrire les formes d'hameçonnage.
- ➢ Conduire une campagne d'hameçonnage autorisée et éthique.
- ➢ Mesurer et interpréter les résultats sans stigmatiser.
- ➢ Proposer des mesures techniques et de sensibilisation.

Question directrice : combien de salariés de LiZbiZ cliquent sur un lien piégé, et qu'en conclure ?

Avec l'accord de la direction et l'information du personnel sur le principe d'un test, NYONG SÉCURITÉ envoie un courriel d'hameçonnage simulé à 60 salariés. Le but n'est pas de piéger des personnes, mais de mesurer un risque et d'améliorer un dispositif. Les chiffres orientent la sensibilisation, non les sanctions.

Plan du chapitre.

1. Les leviers de l'ingénierie sociale (section 19.1).
2. Les formes d'hameçonnage (section 19.2).
3. Une campagne éthique (section 19.3).
4. Mesurer sans stigmatiser (section 19.4).
5. Les parades (section 19.5).

© MaletYon

19.1 Les Leviers de l'Ingénierie Sociale

Définition

Ingénierie sociale : manipulation d'une personne pour obtenir une information, un accès ou une action, en exploitant la confiance, l'autorité, l'urgence, la peur ou la serviabilité.

Levier	Exemple
Autorité	Un courriel qui se présente comme la direction
Urgence	« Votre compte sera fermé dans une heure »
Peur	« Activité suspecte détectée, cliquez pour vérifier »
Serviabilité	Un faux collègue demande de l'aide
Appât	Une pièce jointe « bulletin de paie »

Tableau 19.1. Leviers de l'ingénierie sociale

19.2 Les Formes d'Hameçonnage

Forme	Description
Hameçonnage de masse	Courriel identique envoyé à un grand nombre
Hameçonnage ciblé	Courriel personnalisé visant une personne précise
Hameçonnage par message court	Par message téléphonique
Hameçonnage vocal	Par appel téléphonique

Tableau 19.2. Formes d'hameçonnage (ATT&CK T1566) [24]

19.3 Une Campagne Éthique

Procédure de test

Conduire une campagne d'hameçonnage autorisée

1. Accord écrit de la direction ; information préalable du personnel sur le principe (pas sur la date).
2. Scénario réaliste mais sans contenu humiliant ni thème sensible.
3. Page d'atterrissage pédagogique : la personne qui clique apprend aussitôt qu'il s'agissait d'un test.
4. Collecte limitée : taux de clic et de saisie, jamais le mot de passe réel.
5. Résultats agrégés ; aucune liste nominative de « fautifs ».

★ Attention

Violation typique. Diffuser la liste des personnes qui ont cliqué.

Règle : une campagne mesure un dispositif, pas des individus. On ne collecte jamais les mots de passe réels saisis ; on ne nomme personne ; on ne tourne pas le test en sanction, sous peine de détruire la confiance et le signalement.

19.4 Mesurer sans Stigmatiser

Scénario Opérationnel · Opération LOGONE. La campagne de 60 courriels

Constatations. 60 courriels envoyés. 14 personnes ont cliqué sur le lien (23,3 %). 5 ont commencé à saisir des identifiants sur la page de test (la saisie a été interrompue, aucun mot de passe réel n'a été conservé). 9 personnes ont signalé le courriel à l'informatique.

Analyse (confiance élevée). Le taux de clic (23,3 %) rejoint le constat T-11. Le taux de signalement (15 %) est encourageant et constitue le meilleur indicateur à faire progresser. Aucune conclusion individuelle n'est tirée.

Fiche de constat · T-11 · Taux de clic élevé à l'hameçonnage simulé

Description : 14 clics sur 60 (23,3 %) lors de la campagne autorisée ; 5 débuts de saisie. **Preuve :** statistiques agrégées de la plateforme de test. **Gravité :** moyenne. **Impact :** un courriel piégé réel ouvrirait un premier accès. **Recommandation :** sensibilisation régulière, bouton de signalement, second facteur, marquage des courriels externes. **Détection :** suivi du taux de signalement et du taux de clic dans le temps.

19.5 Les Parades

Parade	Effet
Sensibilisation régulière	Réduit le taux de clic, augmente le signalement
Bouton de signalement	Transforme chaque salarié en capteur
Second facteur	Un mot de passe saisi par erreur ne suffit plus
Marquage des courriels externes	Aide à repérer l'usurpation
Filtrage amont	Bloque une partie des courriels piégés

Tableau 19.3. Parades à l'hameçonnage

Application RSSI et analyste SOC

Faire du salarié un capteur. L'objectif d'une campagne n'est pas de faire baisser le taux de clic à zéro, impossible, mais de faire monter le taux de signalement : un salarié qui signale vite permet au SOC de réagir avant la propagation.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'ingénierie sociale** exploite autorité, urgence, peur, serviabilité, appât.
- **L'hameçonnage** prend plusieurs formes, de la masse au ciblé.
- **Une campagne éthique** informe, ne collecte pas les mots de passe, ne nomme personne.
- **On mesure un dispositif**, pas des individus.
- **Le taux de signalement** est le meilleur indicateur à faire progresser.

● Note

Points de contrôle de l'élève. Je sais : définir l'ingénierie sociale et ses leviers ; citer les formes d'hameçonnage ; conduire une campagne éthique ; interpréter les résultats sans stigmatiser ; proposer des parades.

✍ Exercice 19.1. Leviers ★☆☆

Associez à chaque courriel le levier exploité : « la direction exige » ; « compte fermé dans une heure ».

✍ Exercice 19.2. Formes ★☆☆

Distinguez hameçonnage de masse et hameçonnage ciblé.

✍ Exercice 19.3. Taux ★☆☆

Calculez le taux de clic et le taux de signalement de la campagne.

✍ Exercice 19.4. Page pédagogique ★★☆

Pourquoi la page d'atterrissage doit-elle être pédagogique et non culpabilisante ?

✍ Exercice 19.5. Collecte ★★☆

Pourquoi ne conserve-t-on jamais les mots de passe réels saisis ?

✍ Exercice 19.6. Signalement ★★☆

Pourquoi le taux de signalement est-il un meilleur objectif que le taux de clic ?

✍ Exercice 19.7. T-11 ★★☆

Rédigez le plan d'action lié à T-11.

✍ Exercice 19.8. Thèmes sensibles ★★☆

Pourquoi évite-t-on les thèmes sensibles (salaire, santé) dans un scénario de test ?

✍ Exercice 19.9. Campagne ★★★

Rédigez la note d'information préalable du personnel annonçant le principe d'une campagne, sans en révéler la date.

✍ Exercice 19.10. Programme ★★★

Proposez un programme annuel de sensibilisation et de mesure pour LiZbiZ.

● Note

Pour aller plus loin.

➢ MITRE ATT&CK [24].

● Note

Transition. L'ensemble de ces techniques se combine dans un exercice réaliste : le Chapitre 20 traite de l'équipe rouge et de l'équipe violette.

20

ÉQUIPE ROUGE ET ÉQUIPE VIOLETTE

« L'équipe rouge ne cherche pas toutes les failles ;
elle cherche à atteindre un objectif sans se faire voir. »

Principe du cours

Niveau : *Expert* • Toute la Partie III et la Partie IV ; Chapitre 19.

✦ Objectifs du chapitre

- ➢ Distinguer test d'intrusion, équipe rouge et équipe violette.
- ➢ Décrire le déroulement d'un exercice d'équipe rouge par objectifs.
- ➢ Comprendre la notion de scénario fondé sur une menace.
- ➢ Mesurer la détection et le temps de réaction du défenseur.
- ➢ Conduire une restitution conjointe qui améliore la défense.

Question directrice : la BANQUE SANAGA voit-elle une attaque discrète, et en combien de temps ?

En septembre, avant le test de LiZbiZ, NYONG SÉCURITÉ mène pour la BANQUE SANAGA l'Opération MBAM, un exercice d'équipe rouge par objectifs. La question n'est plus « combien de failles ? » mais « l'attaquant atteint-il l'objectif, et le défenseur le voit-il ? ». Cet exercice sert de référence au cours.

Plan du chapitre.

1. Trois exercices distincts (section 20.1).
2. L'exercice par objectifs (section 20.2).
3. Le scénario fondé sur une menace (section 20.3).
4. Mesurer la détection (section 20.4).
5. L'équipe violette (section 20.5).
6. L'Opération MBAM (section 20.6).

© *MaletYon*

20.1 Trois Exercices Distincts

Exercice	But	Discrétion
Test d'intrusion	Trouver le plus de failles exploitables	Peu importe
Équipe rouge	Atteindre un objectif précis comme le ferait un attaquant	Essentielle
Équipe violette	Rouge et bleue travaillent ensemble pour améliorer la détection	Transparente

Tableau 20.1. Trois types d'exercice offensif

20.2 L'Exercice par Objectifs

Définition

Équipe rouge : exercice où une équipe offensive cherche à atteindre un objectif convenu (un « drapeau »), par tous les moyens du périmètre, en restant discrète, pour évaluer la capacité de détection et de réaction de l'organisation.

Les objectifs, ou **drapeaux**, sont définis à l'avance avec un cercle restreint de responsables : atteindre un système critique, obtenir un droit d'administration, accéder à une donnée précise. Le reste de l'organisation n'est pas prévenu, pour mesurer une détection réelle.

20.3 Le Scénario Fondé sur une Menace

Un bon exercice d'équipe rouge imite un attaquant plausible pour l'organisation : ses techniques, sa patience, ses objectifs. On s'appuie sur la connaissance des menaces et sur les techniques d'ATT&CK pour construire un scénario réaliste, plutôt que de dérouler des outils au hasard.

★ Attention

Violation typique. Transformer l'exercice en démonstration de force qui perturbe la production.

Règle : l'équipe rouge garde un cercle de confiance qui peut tout arrêter, respecte des lignes à ne pas franchir (pas d'arrêt de service, pas de données réelles exfiltrées), et consigne chaque action avec son horaire pour la restitution.

20.4 Mesurer la Détection

Indicateur	Ce qu'il mesure
Temps jusqu'au premier objectif	Rapidité de l'attaquant
Temps jusqu'à la détection	Rapidité du défenseur à voir
Temps jusqu'à la réaction	Rapidité à contenir
Techniques détectées sur techniques jouées	Couverture de la détection
Techniques bloquées	Efficacité des parades

Tableau 20.2. Indicateurs d'un exercice d'équipe rouge

20.5 L'Équipe Violette

Définition

Équipe violette : démarche où l'équipe offensive (rouge) et l'équipe de défense (bleue) travaillent ensemble, en transparence : la rouge joue une technique, la bleue vérifie si elle la détecte, et l'on corrige aussitôt la détection manquante.

C'est souvent la suite la plus utile d'un exercice rouge : on rejoue les techniques non détectées, on écrit les règles manquantes, on vérifie qu'elles fonctionnent. Le lab HE2-LAB-09 fait construire cette matrice de couverture.

20.6 L'Opération MBAM

Scénario Opérationnel · Opération MBAM. Huit jours à la BANQUE SANAGA

Constatations (septembre 2026). Objectifs : F1 (accès au réseau interne), F2 (administration du domaine), F3 (accès au système de paiement).

- F1 atteint au 2e jour, après un hameçonnage ciblé de 12 employés (2 clics).
- F2 atteint au 8e jour (administration du domaine).
- F3 non atteint : le système de paiement, cloisonné, a résisté.
- Détection par le SOC au 9e jour ; confinement au 10e.
- 30 techniques d'ATT&CK jouées : 18 détectées (dont 11 après coup dans les journaux), 7 bloquées.

Analyse (confiance élevée). La banque a résisté là où elle avait cloisonné (F3) ; elle a vu tard (9 jours). La couverture de détection est de 60 % (18 sur 30), mais une part n'a été vue qu'a posteriori. La valeur de l'exercice tient à la phase violette qui a suivi : les 12 techniques non détectées en direct ont donné 12 règles nouvelles.

Application Analyste SOC / Red Team et RSSI

La vraie livraison, c'est la détection. Un exercice d'équipe rouge réussi ne se mesure pas au nombre de drapeaux pris, mais aux règles de détection écrites ensuite. Le RSSI valorise la phase violette autant que l'intrusion.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Test d'intrusion** (toutes les failles), **équipe rouge** (un objectif, discrètement), **équipe violette** (ensemble).
- **Les drapeaux** sont définis à l'avance avec un cercle restreint.
- **Le scénario** imite une menace plausible.
- **On mesure** temps jusqu'à l'objectif, jusqu'à la détection, couverture.
- **La phase violette** transforme l'exercice en règles de détection.

Note

Points de contrôle de l'élève. Je sais : distinguer les trois exercices ; décrire un exercice par objectifs ; expliquer le scénario fondé sur une menace ; citer les indicateurs ; expliquer la valeur de l'équipe violette.

Exercice 20.1. Distinction ★☆☆

En quoi un exercice d'équipe rouge diffère-t-il d'un test d'intrusion ?

Exercice 20.2. Drapeaux ★☆☆

Qu'est-ce qu'un drapeau ? Qui le définit ?

Exercice 20.3. Couverture ★☆☆

Calculez la couverture de détection de l'Opération MBAM.

Exercice 20.4. F3 ★★☆

Pourquoi le drapeau F3 n'a-t-il pas été atteint ? Quelle leçon en tirer ?

Exercice 20.5. Détecté après coup ★★☆

Quelle différence entre une technique détectée en direct et une technique retrouvée après coup dans les journaux ?

✍ Exercice 20.6. Cercle de confiance ★★☆

Pourquoi un cercle restreint doit-il pouvoir arrêter l'exercice à tout moment ?

✍ Exercice 20.7. Lignes rouges ★★☆

Citez trois lignes à ne pas franchir pendant un exercice d'équipe rouge.

✍ Exercice 20.8. Violette ★★☆

Décrivez le déroulement d'une séance d'équipe violette à partir des techniques non détectées de MBAM.

✍ Exercice 20.9. Scénario ★★★

Construisez un scénario d'équipe rouge fondé sur une menace plausible pour LiZbiZ, avec trois drapeaux.

✍ Exercice 20.10. Tableau de bord ★★★

Proposez le tableau de bord d'indicateurs que la BANQUE SANAGA devrait suivre d'un exercice à l'autre.

● Note

Pour aller plus loin.

➢ MITRE ATT&CK [24].

● Note

Transition. L'exercice rouge n'a de valeur que par la défense qu'il nourrit : le Chapitre 21 prend le point de vue du défenseur.

21

SE FAIRE DÉTECTER : LE POINT DE VUE DU DÉFENSEUR

> « Le meilleur testeur offensif est celui qui apprend au défenseur à le voir la prochaine fois. »
>
> Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 20 ; Chapitre 12.

✦ Objectifs du chapitre

- ➢ Comprendre comment un défenseur détecte chaque étape d'une attaque.
- ➢ Relier les techniques offensives étudiées à leurs traces.
- ➢ Construire une matrice de couverture de détection.
- ➢ Écrire une règle de détection à partir d'une technique jouée.
- ➢ Faire du testeur offensif un contributeur à la défense.

Orientation défensive

Ce chapitre prend délibérément le point de vue du défenseur. Il n'enseigne pas à contourner la détection : il enseigne à la mesurer et à l'améliorer. Le testeur éthique joue ses techniques *au vu et au su* du défenseur, pour renforcer ce dernier.

Question directrice : pour chaque technique jouée, le défenseur disposait-il d'une trace et d'une règle ?

Dans l'Opération MBAM, 30 techniques ont été jouées, 18 détectées, dont la moitié seulement en direct. La question de ce chapitre est systématique : pour chacune des techniques étudiées dans ce cours, quelle est sa trace, et quelle règle la transforme en alerte ?

Plan du chapitre.

1. Voir chaque étape (section 21.1).

© MaletYon

2. Des techniques aux traces (section 21.2).
3. La matrice de couverture (section 21.3).
4. Écrire une règle (section 21.4).
5. Le testeur, allié du défenseur (section 21.5).

21.1 Voir Chaque Étape

Étape	Trace typique	Source
Balayage	Nombreuses connexions refusées	Pare-feu, flux réseau
Hameçonnage	Courriel signalé, clic sur lien connu	Messagerie, mandataire web
Authentification suspecte	Connexion inhabituelle, NTLM depuis un poste anormal	Journaux du domaine
Mouvement latéral	Service distant installé, session réseau	Événements 7045, 4624
Persistance	Compte créé, tâche planifiée	Événements 4720, 4698

Tableau 21.1. Voir chaque étape d'une attaque

21.2 Des Techniques aux Traces

Chaque technique des Parties III à V laisse une trace, déjà signalée dans son chapitre. Le défenseur regroupe ces traces par source de journal et s'assure que chacune est bien collectée : une trace non journalisée est une technique invisible.

21.3 La Matrice de Couverture

Définition

Matrice de couverture de détection : tableau qui croise les techniques (par exemple celles d'ATT&CK) avec l'état de la détection : trace collectée, règle existante, règle testée. Elle montre les trous.

Procédure de test

Construire une matrice de couverture

1. Lister les techniques jouées ou attendues.
2. Pour chacune, noter la trace et sa source.

3. Indiquer si la trace est collectée.
4. Indiquer si une règle existe, et si elle a été testée.
5. Prioriser les trous selon la gravité de la technique.

21.4 Écrire une Règle

Une règle de détection s'exprime d'abord en français : *quelle condition, sur quelle source, déclenche quelle alerte*. On la teste en rejouant la technique (phase violette), on mesure les fausses alertes, puis on l'ajuste. Le lab HE2-LAB-09 fait écrire et tester de telles règles.

Scénario Opérationnel · Opération LOGONE. Les règles qui manquaient

Constatation. Les traces de la connexion anormale du compte de la facturation et de son ajout à un groupe à privilèges existaient, mais aucune règle ne les transformait en alerte.

Analyse (confiance élevée). Après restitution, deux règles ont été écrites et testées : « compte à privilèges se connectant depuis un poste ordinaire » et « ajout d'un compte à un groupe sensible hors fenêtre de maintenance ». La détection ne coûtait pas d'outil nouveau, seulement des règles.

21.5 Le Testeur, Allié du Défenseur

Application Analyste SOC / Red Team

Livrer les traces, pas seulement les failles. À la fin d'une mission, l'analyste remet au défenseur la liste horodatée de ses actions : c'est le meilleur jeu de test pour vérifier et compléter la détection.

★ Attention

Violation typique. Se vanter d'être « resté invisible » sans aider le défenseur à le devenir moins.

Règle : rester discret est un moyen de mesurer la détection, pas une fin. Le testeur éthique livre toujours ce qu'il faut pour que le défenseur le détecte la fois suivante.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

➢ **Chaque étape** d'une attaque laisse une trace, dans une source précise.

- **Une trace non collectée** rend la technique invisible.
- **La matrice de couverture** montre les trous de détection.
- **Une règle** s'énonce en français, se teste, s'ajuste.
- **Le testeur** livre ses actions horodatées pour nourrir la défense.

Note

Points de contrôle de l'élève. Je sais : relier une étape à sa trace et à sa source ; expliquer pourquoi une trace doit être collectée ; construire une matrice de couverture ; énoncer une règle de détection ; décrire l'apport du testeur à la défense.

✍ Exercice 21.1. Traces ★☆☆

Donnez la trace et la source de : un balayage ; la création d'un compte.

✍ Exercice 21.2. Invisible ★☆☆

Pourquoi une technique dont la trace n'est pas collectée est-elle invisible ?

✍ Exercice 21.3. Matrice ★☆☆

Quelles colonnes comporte une matrice de couverture de détection ?

✍ Exercice 21.4. Règle en français ★★☆

Énoncez en français la règle qui détecte un compte à privilèges se connectant depuis un poste ordinaire.

✍ Exercice 21.5. Fausses alertes ★★☆

Pourquoi faut-il mesurer les fausses alertes d'une règle avant de la déployer ?

✍ Exercice 21.6. En direct ou après coup ★★☆

Que faut-il changer pour détecter en direct une technique aujourd'hui vue seulement après coup ?

✍ Exercice 21.7. LOGONE ★★☆

À partir du scénario, proposez une troisième règle utile pour LiZbiZ.

✍ Exercice 21.8. Livraison ★★☆

Pourquoi la liste horodatée des actions du testeur est-elle un bon jeu de test pour le SOC ?

✍ **Exercice 21.9. Couverture complète** ★★★

Construisez la matrice de couverture des techniques des Chapitres 9 à 12.

✍ **Exercice 21.10. Programme** ★★★

Proposez un programme d'amélioration continue de la détection fondé sur des exercices violets trimestriels.

● **Note**

Pour aller plus loin.

➢ MITRE ATT&CK [24].

● **Note**

Transition. Toutes ces conclusions doivent être restituées : la Partie VI commence par le Chapitre 22, consacré au rapport.

partie VI

Restituer et Progresser

© *MaletYon*

22

LE RAPPORT DE TEST D'INTRUSION

« Un test d'intrusion ne vaut que par son rapport ;
le reste n'est qu'une collection de preuves. »

Principe du cours

Niveau : *Intermédiaire* • Toutes les parties précédentes ; Chapitre 4.

✦ Objectifs du chapitre

- ➢ Décrire la structure d'un rapport de test d'intrusion.
- ➢ Rédiger une synthèse pour la direction et un détail technique.
- ➢ Coter chaque constat et le hiérarchiser.
- ➢ Rédiger un constat complet : description, preuve, impact, recommandation.
- ➢ Présenter les 14 constats de l'Opération LOGONE comme modèle.

Question directrice : comment transformer dix jours de test en un document utile à la direction et aux techniciens ?

Le test de LiZbiZ est terminé : 14 constats, des preuves, des notes. Il faut maintenant un document que M. ETEME lira en dix minutes et que M. KOUNOU suivra ligne à ligne pour corriger. Ce chapitre construit ce document.

Plan du chapitre.

1. La structure du rapport (section 22.1).
2. Deux lecteurs, deux niveaux (section 22.2).
3. Coter et hiérarchiser (section 22.3).
4. L'anatomie d'un constat (section 22.4).
5. Les 14 constats de LOGONE (section 22.5).

© *MaletYon*

22.1 La Structure du Rapport

Partie	Contenu
Synthèse pour la direction	Verdict, risques majeurs, recommandations prioritaires, sans jargon
Contexte et périmètre	Objectifs, limites, dates, règles d'engagement
Démarche	Méthode suivie, outils, degré de couverture
Constats détaillés	Un par faiblesse, coté et documenté
Plan de correction	Actions priorisées, responsables, échéances
Annexes	Preuves, liste des actions horodatées, périmètre technique

Tableau 22.1. Structure d'un rapport de test d'intrusion

22.2 Deux Lecteurs, Deux Niveaux

★ Attention

Violation typique. Un rapport uniquement technique, illisible pour la direction, ou une synthèse vague, inutilisable par les techniciens.

Règle : la synthèse parle risque et décision ; le détail parle technique et correction. Les deux disent la même vérité, à deux niveaux.

22.3 Coter et Hiérarchiser

Chaque constat reçoit une gravité. On peut s'appuyer sur le système commun de notation des vulnérabilités (CVSS 3.1, Chapitre 7) pour les failles techniques, et sur une appréciation du risque métier pour le reste. La gravité combine la facilité d'exploitation et l'impact.

Gravité	Nombre	Exigence de traitement
Critique	2	Correction immédiate
Élevée	4	Sous quelques jours
Moyenne	5	Planifiée au trimestre
Faible	3	Au fil de l'eau

Tableau 22.2. Répartition des 14 constats de LOGONE

22.4 L'Anatomie d'un Constat

Procédure de test

Rédiger un constat

1. Identifiant et titre court.
2. Description : la faiblesse, en termes clairs.
3. Preuve : ce qui l'établit (requête, capture masquée, relevé).
4. Impact : ce qu'un attaquant en ferait.
5. Gravité : cotation justifiée.
6. Recommandation : la correction, concrète et vérifiable.
7. Détection : comment voir l'exploitation en production.

Tous les encadrés « Fiche de constat » des chapitres précédents suivent exactement cette anatomie.

22.5 Les 14 Constats de LOGONE

Id	Constat	Gravité	Chapitre
T-01	Compte de service vulnérable au vol de ticket (facturation)	Critique	10
T-02	Mot de passe administrateur local en clair dans un script partagé	Critique	11
T-03	Accès distant sans second facteur	Élevée	7
T-05	Accès indirect aux colis d'autrui (portail)	Élevée	15
T-06	Protocole de partage ancien et vulnérable	Élevée	8
T-09	Exécution de code sur l'ancien portail	Élevée	8
T-04	Identifiants par défaut sur des équipements	Moyenne	18
T-07	Signature de partage non exigée et résolutions locales actives	Moyenne	9
T-08	Comptes d'administration utilisés sur des postes ordinaires	Moyenne	12
T-10	Service de test exposé sur l'Internet	Moyenne	17
T-11	Taux de clic élevé à l'hameçonnage simulé	Moyenne	19
T-12	En-têtes de sécurité HTTP absents	Faible	14
T-13	Bannières de version exposées	Faible	6
T-14	Délai d'expiration de session trop long	Faible	14

Tableau 22.3. Les 14 constats de l'Opération LOGONE

L'audit des mots de passe (constat A-01, Chapitre 13) est rapporté séparément,

comme mission complémentaire.

Application Pentesteur et RSSI

Écrire pour l'action. Un constat réussi est celui que le destinataire sait corriger sans rappeler l'auteur. La recommandation est concrète, vérifiable, et distingue la correction de fond du palliatif immédiat.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le rapport** est le livrable ; tout le reste le prépare.
- **Deux niveaux** : synthèse pour la direction, détail pour les techniciens.
- **Chaque constat** est coté et hiérarchisé.
- **L'anatomie** : description, preuve, impact, gravité, recommandation, détection.
- **Les 14 constats de LOGONE** suivent ce modèle.

Note

Points de contrôle de l'élève. Je sais : donner la structure d'un rapport ; écrire à deux niveaux ; coter et hiérarchiser ; rédiger un constat complet ; situer chaque constat de LOGONE.

Exercice 22.1. Structure ★☆☆

Citez les six parties d'un rapport de test d'intrusion.

Exercice 22.2. Deux lecteurs ★☆☆

Qu'attend la direction du rapport ? Qu'attend le technicien ?

Exercice 22.3. Répartition ★☆☆

Combien de constats critiques, élevés, moyens et faibles compte LOGONE ?

Exercice 22.4. Anatomie ★★☆

Rédigez le constat T-06 selon l'anatomie en sept points.

Exercice 22.5. Synthèse ★★☆

Rédigez la synthèse pour la direction de l'Opération LOGONE, en dix lignes.

✍ Exercice 22.6. Priorité ★★☆

Justifiez pourquoi T-01 et T-02 passent avant T-12 et T-13.

✍ Exercice 22.7. Mission complémentaire ★★☆

Pourquoi l'audit des mots de passe (A-01) est-il rapporté à part des 14 constats ?

✍ Exercice 22.8. Recommandation ★★☆

Réécrivez une recommandation vague (« améliorer la sécurité ») en recommandation concrète et vérifiable.

✍ Exercice 22.9. Plan de correction ★★★

Construisez le plan de correction de LOGONE : ordre, responsables, échéances.

✍ Exercice 22.10. Rapport complet ★★★

Rédigez le plan complet du rapport de LOGONE, partie par partie, avec le nombre de pages visé.

● Note

Pour aller plus loin.

➢ PTES [20] ; CVSS 3.1 [5].

● Note

Transition. Un rapport sans vérification des corrections reste théorique : le Chapitre 23 traite du contre-test.

23

LE CONTRE-TEST

« Une faille n'est corrigée que lorsqu'un second test le prouve. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 22.

✦ Objectifs du chapitre

- ➢ Définir le contre-test et sa place dans le cycle.
- ➢ Vérifier qu'une correction ferme réellement la faille.
- ➢ Distinguer correction de fond et palliatif.
- ➢ Documenter l'état de chaque constat après correction.
- ➢ Clore une mission proprement.

Question directrice : les corrections de LiZbiZ ont-elles vraiment fermé les failles ?

Trois semaines après le rapport, M. KOUNOU annonce que « tout est corrigé ». NYONG SÉCURITÉ revient vérifier, constat par constat. Certaines failles sont bien fermées, d'autres seulement masquées, une a été rouverte par une nouvelle configuration. Le contre-test établit la vérité.

Plan du chapitre.

1. Qu'est-ce qu'un contre-test (section 23.1).
2. Fond ou palliatif (section 23.2).
3. L'état des constats (section 23.3).
4. Clore la mission (section 23.4).

© MaletYon

23.1 Qu'est-ce qu'un Contre-Test

Définition

Contre-test : vérification, après correction, que chaque faiblesse rapportée a bien été traitée, en rejouant le test qui l'avait révélée, dans les mêmes conditions.

23.2 Fond ou Palliatif

Attention

Violation typique. Déclarer une faille corrigée parce qu'un symptôme a disparu.

Règle : on vérifie la cause, pas le symptôme. Masquer une bannière de version ne corrige pas la version ; bloquer une adresse ne corrige pas le défaut d'accès. On distingue clairement la correction de fond du palliatif temporaire.

23.3 L'État des Constats

Scénario Opérationnel · Opération LOGONE. Le contre-test de novembre

Constatations. Sur les 14 constats : 9 fermés (dont T-01 et T-02, critiques), 3 partiellement traités (T-07 corrigé sur les serveurs mais pas les postes ; T-08 en cours ; T-11, sensibilisation engagée), 1 palliatif (T-13, bannières masquées mais versions inchangées), 1 rouvert (T-10, un nouveau service de test exposé).

Analyse (confiance élevée). Les deux failles critiques sont bien fermées. Le constat rouvert montre l'intérêt d'un contre-test : sans lui, la réexposition serait passée inaperçue.

État	Signification
Fermé	La faille ne se reproduit plus ; correction de fond vérifiée
Partiel	Une partie du périmètre reste exposée
Palliatif	Symptôme masqué, cause non traitée
Rouvert	La faille, fermée, est réapparue
Non traité	Aucune correction

Tableau 23.1. États d'un constat au contre-test

23.4 Clore la Mission

Procédure de test

Clore une mission

1. Rejouer chaque test et noter l'état du constat.
2. Rédiger un addendum au rapport avec les états.
3. Distinguer fond et palliatif pour chaque correction.
4. Convenir d'un suivi pour les constats partiels.
5. Détruire les données de test et restituer les accès.

Application Auditeur de sécurité et RSSI

Le contre-test ferme la boucle. Sans contre-test, un rapport reste une liste de promesses. Le RSSI inscrit le contre-test au contrat et en fait la condition de clôture.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le contre-test** rejoue le test après correction.
- **On vérifie la cause**, pas le symptôme.
- **Chaque constat** reçoit un état : fermé, partiel, palliatif, rouvert, non traité.
- **Un constat rouvert** justifie à lui seul le contre-test.
- **La clôture** documente les états et détruit les données.

Note

Points de contrôle de l'élève. Je sais : définir le contre-test ; distinguer fond et palliatif ; attribuer un état à un constat ; rédiger un addendum ; clore une mission.

Exercice 23.1. Définition ★☆☆

Qu'est-ce qu'un contre-test ?

Exercice 23.2. Fond ou palliatif ★☆☆

Masquer une bannière de version est-il une correction de fond ou un palliatif ? Pourquoi ?

✍ Exercice 23.3. États ★☆☆

Donnez les cinq états possibles d'un constat au contre-test.

✍ Exercice 23.4. T-10 rouvert ★★☆

Comment un constat fermé peut-il être rouvert ? Que recommander ?

✍ Exercice 23.5. Partiel ★★☆

T-07 est corrigé sur les serveurs mais pas les postes. Quel état, et quel suivi ?

✍ Exercice 23.6. Addendum ★★☆

Rédigez l'addendum de contre-test pour T-01 et T-13.

✍ Exercice 23.7. Condition de clôture ★★☆

Pourquoi faire du contre-test une condition de clôture au contrat ?

✍ Exercice 23.8. Bilan ★★☆

Dressez le bilan chiffré du contre-test de LOGONE.

✍ Exercice 23.9. Procédure ★★★

Proposez une procédure de contre-test réutilisable pour les futures missions de NYONG SÉCURITÉ.

✍ Exercice 23.10. Indicateur ★★★

Définissez un indicateur de qualité de correction, calculé à partir des états de contre-test.

● Note

Pour aller plus loin.

➢ PTES [20].

● Note

Transition. Lorsqu'une faille touche un produit utilisé par d'autres, sa correction dépasse le client : le Chapitre 24 traite de la divulgation coordonnée.

24

LA DIVULGATION COORDONNÉE

« Trouver une faille crée un devoir :
celui de la faire corriger sans nuire. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 2 ; Chapitre 22.

✦ Objectifs du chapitre

- ➢ Définir la divulgation coordonnée de vulnérabilités.
- ➢ Distinguer divulgation privée, coordonnée et complète.
- ➢ Décrire le processus des normes ISO/IEC 29147 et 30111.
- ➢ Situer la divulgation dans le cadre juridique camerounais.
- ➢ Rédiger un signalement responsable.

Question directrice : que faire d'une faille découverte dans un logiciel utilisé par beaucoup d'autres ?

En testant LiZbiZ, M. TAMO découvre que la faille de l'ancien portail (T-09) vient d'un composant répandu, utilisé par de nombreuses organisations. La corriger chez LiZbiZ ne protège pas les autres. Comment signaler la faille à l'éditeur sans exposer tout le monde ? C'est l'objet de la divulgation coordonnée.

Plan du chapitre.

1. Trois façons de divulguer (section 24.1).
2. Le processus coordonné (section 24.2).
3. Les normes 29147 et 30111 (section 24.3).
4. Le cadre juridique (section 24.4).
5. Rédiger un signalement (section 24.5).

© MaletYon

24.1 Trois Façons de Divulguer

Façon	Principe et limite
Privée	On informe le seul éditeur ; sûr, mais sans pression si l'éditeur n'agit pas
Coordonnée	On informe l'éditeur, puis on publie après correction ou délai convenu
Complète et immédiate	On publie tout aussitôt ; expose les utilisateurs avant correctif

Tableau 24.1. Trois modes de divulgation

La divulgation **coordonnée** est le compromis responsable : elle donne à l'éditeur le temps de corriger, puis informe les utilisateurs pour qu'ils se protègent.

24.2 Le Processus Coordonné

Procédure de test

Divulguer de façon coordonnée

1. Trouver le contact de sécurité de l'éditeur.
2. Signaler la faille par un canal sûr, avec les éléments de reproduction.
3. Convenir d'un délai de correction raisonnable.
4. Laisser l'éditeur corriger et, le cas échéant, obtenir un identifiant public de vulnérabilité.
5. Publier une description après le correctif, sans mode d'emploi d'attaque inutile.

★ Attention

Violation typique. Publier la faille avec son code d'exploitation avant tout correctif, « pour forcer l'éditeur ».

Règle : la divulgation vise à protéger, pas à nuire ni à se mettre en avant. On laisse un délai raisonnable, on ne publie pas d'arme prête à l'emploi, on pense d'abord aux utilisateurs exposés.

24.3 Les Normes 29147 et 30111

Norme	Objet
ISO/IEC 29147	Comment *recevoir* et publier les signalements de vulnérabilités (côté celui qui divulgue et celui qui reçoit)
ISO/IEC 30111	Comment *traiter* en interne une vulnérabilité signalée jusqu'à sa correction

Tableau 24.2. Deux normes complémentaires [9], [10]

Les deux normes sont complémentaires : 29147 organise l'échange avec le monde extérieur, 30111 organise le travail interne de correction.

24.4 Le Cadre Juridique

Jurisprudence & Droit applicable

La découverte d'une faille ne vaut pas autorisation d'y accéder. Au Cameroun, la loi 2010/012 sur la cybersécurité réprime l'accès et le maintien frauduleux dans un système, même sans dommage (Chapitre 2). Un chercheur qui découvre une faille hors d'un mandat doit s'en tenir à ce qu'il a constaté sans intrusion supplémentaire, et signaler.

24.5 Rédiger un Signalement

Application Pentesteur et RSSI

Signaler avec mesure. Un bon signalement est factuel, reproductible et courtois : il décrit la faille, son impact, les conditions de reproduction, et propose un délai. Il n'exige rien, il coopère.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Trouver une faille** crée le devoir de la faire corriger sans nuire.
- **La divulgation coordonnée** donne le temps de corriger, puis informe.
- **29147** organise l'échange, **30111** le traitement interne.
- **Découvrir n'autorise pas à accéder** : la loi 2010/012 s'applique.
- **Un signalement** est factuel, reproductible, coopératif.

Note

Points de contrôle de l'élève. Je sais : distinguer les trois modes de divulgation ; dérouler le processus coordonné ; distinguer 29147 et 30111 ; rappeler le cadre juridique ; rédiger un signalement.

✍ Exercice 24.1. Trois modes ★☆☆

Distinguez divulgation privée, coordonnée et complète immédiate.

✍ Exercice 24.2. Normes ★☆☆

Quelle norme organise la réception des signalements ? Laquelle organise leur traitement interne ?

✍ Exercice 24.3. Devoir ★☆☆

Pourquoi corriger T-09 chez LiZbiZ ne suffit-il pas ?

✍ Exercice 24.4. Délai ★★☆

Pourquoi laisse-t-on un délai à l'éditeur avant publication ? Qu'est-ce qu'un délai raisonnable ?

✍ Exercice 24.5. Pas d'arme ★★☆

Pourquoi ne publie-t-on pas le code d'exploitation prêt à l'emploi ?

✍ Exercice 24.6. Droit ★★☆

Un chercheur découvre une faille sur un site public. Que peut-il faire, que ne peut-il pas faire, selon la loi 2010/012 ?

✍ Exercice 24.7. Contact ★★☆

Comment trouve-t-on le contact de sécurité d'un éditeur ?

✍ Exercice 24.8. Signalement ★★☆

Rédigez le signalement de la faille de composant à l'éditeur.

✍ Exercice 24.9. Politique ★★★

Rédigez une politique de divulgation que LiZbiZ pourrait publier pour recevoir des signalements, inspirée de 29147.

✍ Exercice 24.10. Processus interne ★★★

Décrivez le processus interne de traitement d'une vulnérabilité signalée, inspiré de 30111.

Note

Pour aller plus loin.

- ISO/IEC 29147 [9] ; ISO/IEC 30111 [10].
- Loi 2010/012 [12].

Note

Transition. Toutes ces compétences se cultivent dans un cadre d'entraînement : le Chapitre 25 traite du laboratoire et de la pratique continue.

25

LE LABORATOIRE ET LA PRATIQUE CONTINUE

« On n'apprend pas à tester en lisant ;
on apprend dans un laboratoire que l'on a le droit d'attaquer. »

Principe du cours

Niveau : *Tous niveaux* • L'ensemble du cours.

✦ Objectifs du chapitre

- ➢ Comprendre pourquoi l'entraînement se fait en laboratoire fermé.
- ➢ Monter un laboratoire personnel légal.
- ➢ Utiliser les plateformes d'entraînement et les épreuves.
- ➢ Entretenir ses compétences dans la durée et dans la légalité.
- ➢ Situer la plateforme NDAP SUKULU du cours.

Question directrice : où s'entraîner sans jamais enfreindre la loi ?

Les techniques de ce cours ne se pratiquent que sur des systèmes que l'on a le droit d'attaquer. La tentation de « s'exercer » sur un site réel est une faute et une infraction. Ce chapitre montre où et comment s'entraîner légalement, et présente la plateforme du cours.

Plan du chapitre.

1. Pourquoi un laboratoire fermé (section 25.1).
2. Monter son laboratoire (section 25.2).
3. Plateformes et épreuves (section 25.3).
4. Entretenir ses compétences (section 25.4).
5. La plateforme NDAP SUKULU (section 25.5).

© *MaletYon*

25.1 Pourquoi un Laboratoire Fermé

★ Attention

Violation typique. S'entraîner sur un site réel « juste pour voir ».

Règle : tout essai sur un système dont on n'a pas l'autorisation écrite est une infraction (Chapitre 2), quelles que soient l'intention et l'absence de dommage. L'entraînement se fait en laboratoire fermé, isolé du réseau réel.

25.2 Monter son Laboratoire

☑ Procédure de test

Monter un laboratoire personnel légal

1. Un hyperviseur sur sa propre machine ; un réseau virtuel isolé.
2. Des machines cibles prévues pour l'entraînement (volontairement vulnérables, fournies à cet effet).
3. Aucune connexion de ce réseau au réseau réel ni à l'Internet lors des essais offensifs.
4. Des instantanés pour revenir à l'état initial.
5. Un journal d'entraînement pour suivre ses progrès.

25.3 Plateformes et Épreuves

Des plateformes en ligne proposent des cibles légales à attaquer et des épreuves de capture de drapeau. Elles offrent un cadre autorisé : on y a le droit explicite de tester. Elles complètent le laboratoire personnel et permettent de se mesurer.

Cadre	Usage
Laboratoire personnel	Apprendre à son rythme, tout casser sans risque
Plateforme d'entraînement en ligne	Cibles variées, légales, mises à jour
Épreuve de capture de drapeau	Se mesurer, travailler en équipe, sous pression
Plateforme du cours (NDAP SUKULU)	Fiches, labs et exercices alignés sur ce cours

Tableau 25.1. Cadres d'entraînement légaux

25.4 Entretenir ses Compétences

La sécurité offensive évolue vite. Les techniques de fond (reconnaissance, accès, élévation, latéralité, restitution) restent ; les détails changent. On entretient ses compétences par une pratique régulière, une veille mesurée, et le partage au sein d'une communauté.

Application Pentesteur, analyste SOC / Red Team, RSSI

Pratiquer, dans la durée et la légalité. Le professionnel réserve un temps régulier au laboratoire, documente ses essais, et ne cède jamais à la facilité d'un essai « réel » non autorisé : sa réputation et sa liberté en dépendent.

25.5 La Plateforme NDAP SUKULU

Le cours s'appuie sur la plateforme NDAP SUKULU : pour chaque chapitre, une fiche d'auto-évaluation ; pour les chapitres pratiques, un lab qui fait manipuler des pièces (relevés, historiques, journaux) dans un cadre entièrement fermé. Les dix labs du cours (HE2-LAB-01 à 10) couvrent le périmètre, l'OSINT, le balayage, la priorisation, l'annuaire, l'élévation, l'audit de mots de passe, l'historique web, la couverture de détection et le calcul de gravité.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **On s'entraîne** seulement sur ce qu'on a le droit d'attaquer.
- **Le laboratoire fermé** est isolé du réseau réel.
- **Plateformes et épreuves** offrent des cibles légales.
- **On entretient** ses compétences par une pratique régulière.
- **NDAP SUKULU** aligne fiches et labs sur le cours.

● Note

Points de contrôle de l'élève. Je sais : expliquer pourquoi l'entraînement est en laboratoire fermé ; monter un laboratoire légal ; citer les cadres d'entraînement ; organiser l'entretien de mes compétences ; décrire NDAP SUKULU.

✍ Exercice 25.1. Légalité ★☆☆

Pourquoi ne s'entraîne-t-on jamais sur un site réel sans autorisation ?

✍ Exercice 25.2. Isolation ★☆☆

Pourquoi le réseau du laboratoire doit-il être isolé du réseau réel ?

✍ Exercice 25.3. Cadres ★☆☆

Citez trois cadres d'entraînement légaux.

✍ Exercice 25.4. Instantanés ★★☆

À quoi servent les instantanés dans un laboratoire ?

✍ Exercice 25.5. Capture de drapeau ★★☆

Qu'apporte une épreuve de capture de drapeau par rapport au laboratoire personnel ?

✍ Exercice 25.6. Veille ★★☆

Comment organiser une veille mesurée sans s'y noyer ?

✍ Exercice 25.7. Journal ★★☆

Que consigne-t-on dans un journal d'entraînement ?

✍ Exercice 25.8. NDAP SUKULU ★★☆

Décrivez ce que la plateforme du cours apporte à chaque chapitre.

✍ Exercice 25.9. Montage ★★★

Décrivez le montage complet d'un laboratoire personnel pour pratiquer les Parties III et IV.

✍ Exercice 25.10. Plan annuel ★★★

Proposez votre plan d'entraînement sur un an pour entretenir les compétences du cours.

● Note

Pour aller plus loin.

➢ Les dix labs de NDAP SUKULU pour ce cours.

● Note

Transition. Reste à savoir mesurer la valeur de tout cela : le Chapitre 26 clôt le cours sur la mesure de la sécurité offensive.

26

MESURER LA SÉCURITÉ OFFENSIVE

« Un test qui ne se mesure pas ne s'améliore pas ;
et ce qui ne peut être tranché doit être dit indéterminé. »

Principe du cours

Niveau : *Avancé* • L'ensemble du cours ; notions d'auditologie (cours d'audit).

✦ Objectifs du chapitre

- ➢ Définir ce que mesure un test d'intrusion.
- ➢ Construire des indicateurs utiles et honnêtes.
- ➢ Appliquer le verdict à trois valeurs OUI, NON, NEK.
- ➢ Éviter les indicateurs trompeurs.
- ➢ Inscrire le test dans un cycle d'amélioration.

Question directrice : LiZbiZ est-elle « sûre » après le test ?

À la fin de la mission, M. ETEME pose la question la plus simple et la plus piégée : « sommes-nous sûrs maintenant ? ». La réponse honnête n'est ni oui ni non en général : elle est un ensemble de verdicts précis, et, pour ce qui n'a pu être tranché, un franc « indéterminé ». Ce chapitre apprend à mesurer sans tromper.

Plan du chapitre.

1. Ce que mesure un test (section 26.1).
2. Des indicateurs honnêtes (section 26.2).
3. Le verdict à trois valeurs (section 26.3).
4. Les indicateurs trompeurs (section 26.4).
5. Le cycle d'amélioration (section 26.5).

© *MaletYon*

26.1 Ce que Mesure un Test

Un test d'intrusion ne mesure pas « la sécurité » en général : il mesure la résistance d'un périmètre donné, à un moment donné, face à un effort donné. Il dit ce qu'un attaquant de niveau comparable aurait pu faire, pas ce qu'un attaquant quelconque fera demain.

26.2 Des Indicateurs Honnêtes

Indicateur	Ce qu'il dit
Objectifs atteints sur objectifs fixés	Résistance aux scénarios visés
Constats par gravité	Ampleur et priorité des faiblesses
Couverture de détection	Part des techniques vues par le défenseur
Temps jusqu'à la détection	Rapidité du défenseur
Taux de correction au contre-test	Qualité du traitement
Taux de signalement d'hameçonnage	Vigilance humaine

Tableau 26.1. Indicateurs d'un test d'intrusion

26.3 Le Verdict à Trois Valeurs

Définition

Verdict à trois valeurs : pour chaque question d'audit, la réponse est OUI (la propriété est vérifiée, avec preuve), NON (elle est réfutée, avec preuve), ou NEK (indéterminé : les preuves manquent pour trancher). Le NEK n'est pas un aveu de faiblesse : c'est une exigence d'honnêteté.

Verdict	Sens	Exemple (LOGONE)
OUI	Propriété démontrée	« Le système de paiement cloisonné a résisté » (F3 non atteint, MBAM)
NON	Propriété réfutée	« Un attaquant interne devient administrateur du domaine » (T-01)
NEK	Indéterminé	« La résistance du nuage au-delà du périmètre testé » (hors mandat)

Tableau 26.2. Le verdict OUI / NON / NEK appliqué [14]

★ Attention

Violation typique. Conclure OUI (« c'est sûr ») faute d'avoir trouvé une faille, alors qu'on n'a pas cherché.

Règle : l'absence de preuve n'est pas une preuve d'absence. Ce qui n'a pas été testé, ou n'a pu être tranché, est NEK, pas OUI. Le NEK dit au client où porter l'effort suivant.

26.4 Les Indicateurs Trompeurs

Indicateur trompeur	Pourquoi il trompe
Nombre brut de failles	Dépend de l'outil, pas du risque
« Zéro faille trouvée »	Peut signifier « rien cherché »
Note globale unique	Masque les constats critiques dans la moyenne
Temps passé	Mesure l'effort, pas le résultat

Tableau 26.3. Indicateurs à manier avec prudence

26.5 Le Cycle d'Amélioration

Un test n'est pas une fin : c'est une étape d'un cycle. Les constats alimentent les corrections ; le contre-test les vérifie ; la phase violette nourrit la détection ; le test suivant repart des NEK et des zones non couvertes. La sécurité offensive sert la défense, et se mesure à ce qu'elle lui apporte.

Application RSSI, auditeur de sécurité, pentesteur

Dire le vrai, y compris le NEK. Le professionnel ne cède pas à la pression du OUI rassurant. Il distingue ce qu'il a démontré, ce qu'il a réfuté, et ce qu'il n'a pu trancher : c'est à ce triple langage qu'on reconnaît un rapport honnête.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Un test** mesure une résistance, à un moment, face à un effort donné.
- **Les bons indicateurs** relient objectif, gravité, détection, correction.
- **Le verdict** est OUI, NON ou NEK.
- **L'absence de preuve** n'est pas preuve d'absence : c'est NEK.
- **Le test** sert un cycle d'amélioration continue de la défense.

Note

Points de contrôle de l'élève. Je sais : dire ce que mesure un test ; construire des indicateurs honnêtes ; appliquer OUI / NON / NEK ; reconnaître les indicateurs trompeurs ; inscrire le test dans un cycle.

✍ Exercice 26.1. Ce que mesure un test ★☆☆

Un test mesure-t-il « la sécurité » en général ? Que mesure-t-il ?

✍ Exercice 26.2. Trois valeurs ★☆☆

Donnez le sens de OUI, NON et NEK.

✍ Exercice 26.3. Trompeur ★☆☆

Pourquoi « zéro faille trouvée » peut-il tromper ?

✍ Exercice 26.4. Absence de preuve ★★☆

Expliquez « l'absence de preuve n'est pas une preuve d'absence » sur un exemple de LOGONE.

✍ Exercice 26.5. Classer ★★☆

Attribuez OUI, NON ou NEK : le système de paiement de MBAM ; l'accès administrateur de LiZbiZ ; la sécurité du nuage hors périmètre.

✍ Exercice 26.6. Note unique ★★☆

Pourquoi une note globale unique est-elle dangereuse ?

✍ Exercice 26.7. Indicateurs ★★☆

Choisissez trois indicateurs pour le tableau de bord de LiZbiZ et justifiez.

✍ Exercice 26.8. Répondre au DG ★★☆

Rédigez la réponse honnête à « sommes-nous sûrs maintenant ? », en OUI / NON / NEK.

✍ Exercice 26.9. Cycle ★★★

Décrivez le cycle d'amélioration reliant test, correction, contre-test, détection et test suivant.

✍ Exercice 26.10. Tableau de bord ★★★

Construisez le tableau de bord de sécurité offensive que LiZbiZ devrait suivre d'une année sur l'autre, verdicts NEK compris.

● Note

Pour aller plus loin.

➢ Cadre d'auditologie et verdict à trois valeurs [14].

● Note

Fin du cours. De la lettre d'autorisation au verdict mesuré, le test d'intrusion aura montré qu'autoriser, reconnaître, tester et restituer forment un même service : défendre, en pensant comme l'attaquant, sans jamais le devenir.

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les notions définies dans les chapitres. Le renvoi indique le chapitre où la notion est présentée.

Active Directory Annuaire des réseaux Windows : comptes, groupes, machines et droits d'un domaine (Ch. 10).

Charge utile Ce qu'un exploit fait exécuter après avoir déclenché la faille (Ch. 8).

Contre-test Vérification, après correction, que chaque faiblesse rapportée a bien été traitée (Ch. 23).

CVSS Système commun de notation des vulnérabilités, de 0 à 10 (Ch. 7).

Divulgation coordonnée Signalement d'une faille à l'éditeur, suivi d'une publication après correction ou délai convenu (Ch. 24).

Élévation de privilèges Obtention de droits supérieurs à ceux du compte de départ (Ch. 11).

Empoisonnement de résolution Réponse frauduleuse à une requête de résolution de nom diffusée, qui détourne la connexion de la victime (Ch. 9).

Énumération Recueil détaillé des services, comptes et partages exposés, après le balayage (Ch. 6).

Équipe rouge Exercice offensif visant un objectif précis, discrètement, pour mesurer la détection (Ch. 20).

Équipe violette Démarche où offensive et défensive travaillent ensemble pour améliorer la détection (Ch. 20).

Exploit Moyen technique de tirer parti d'une vulnérabilité (Ch. 8).

Faux négatif Vulnérabilité réelle qu'un outil ne signale pas (Ch. 7).

Faux positif Alerte d'un outil sans vulnérabilité réelle (Ch. 7).

Hacking éthique Recherche autorisée de faiblesses dans un système, pour le renforcer, dans un cadre légal et sans dommage (Ch. 1).

Ingénierie sociale Manipulation d'une personne pour obtenir une information, un accès ou une action (Ch. 19).

Injection Faille où une donnée fournie est interprétée comme une commande, faute de séparation (Ch. 15).

Interface de programmation (API) Points d'entrée par lesquels des programmes échangent des données (Ch. 16).

Kerberoasting Vol d'un ticket de service Kerberos, cassé hors ligne si le mot de passe du compte de service est faible (Ch. 10).

Matrice de couverture de détection Tableau croisant les techniques avec l'état de leur détection (Ch. 21).

MITRE ATT&CK Base de connaissances des tactiques et techniques des attaquants (Ch. 4).

Modèle d'administration par niveaux Organisation qui interdit d'utiliser un compte à privilèges sur une machine de niveau inférieur (Ch. 10).

Modèle de responsabilité partagée Répartition des tâches de sécurité entre le fournisseur de nuage et le client (Ch. 17).

Mouvement horizontal Passage d'un compte à un autre de même niveau (Ch. 11).

Mouvement latéral Prise de contrôle d'autres machines du réseau avec des identifiants valides (Ch. 12).

OSINT Renseignement tiré de sources ouvertes, sans solliciter la cible (Ch. 5).

Point d'accès pirate Borne non autorisée branchée sur le réseau de l'entreprise (Ch. 18).

Portail jumeau Fausse borne qui imite le réseau légitime pour capter les connexions (Ch. 18).

Preuve de concept Démonstration minimale et inoffensive qu'une faille est réelle (Ch. 8).

Reconnaissance active Collecte d'informations en sollicitant directement la cible (Ch. 5).

Reconnaissance passive Collecte d'informations sans solliciter la cible (Ch. 5).

Référence directe non contrôlée à un objet Accès à l'objet d'autrui en changeant un identifiant visible, faute de contrôle (Ch. 15).

Règles d'engagement Cadre convenu d'une mission : périmètre, horaires, actions permises, contacts, mot d'arrêt (Ch. 3).

Requête HTTP Message du client au serveur : méthode, chemin, en-têtes, corps (Ch. 14).

Réponse HTTP Message du serveur au client : code, en-têtes, corps (Ch. 14).

Session État conservé entre requêtes, souvent par un cookie (Ch. 14).

Signature SMB Mécanisme qui lie les échanges de partage et empêche leur relais (Ch. 9).

Test d'intrusion Simulation autorisée d'attaque pour démontrer ce qu'un attaquant ferait (Ch. 1).

Top 10 de l'OWASP Classement des grandes familles de risques des applications web ou des API (Ch. 14, 16).

Transparence des certificats Journaux publics des certificats émis, utiles pour cartographier la surface (Ch. 5).

Verdict à trois valeurs (OUI, NON, NEK) Réponse d'audit : vérifiée, réfutée, ou indéterminée faute de preuves (Ch. 26).

Web Security Testing Guide (WSTG) Guide de l'OWASP organisant le test d'une application web en catégories (Ch. 14).

B

RÉFÉRENTIEL DES OUTILS

Les outils cités sont des exemples. Le cours insiste sur la méthode et la compréhension : l'outil sert le raisonnement, il ne le remplace pas. Tout usage se fait dans un cadre autorisé ou en laboratoire fermé (Ch. 25).

Catégorie d'outil	Usage	Chapitre, lab
Sources ouvertes (OSINT)	Journaux de certificats, moteurs de recherche, registres publics	Ch. 5, HE2-LAB-02
Balayage réseau	Découverte des hôtes et des services	Ch. 6, HE2-LAB-03
Scanner de vulnérabilités	Détection assistée, à vérifier	Ch. 7, HE2-LAB-04
Relais web local	Observation et modification des requêtes	Ch. 14, HE2-LAB-08
Analyse d'annuaire	Groupes, comptes, chemins d'attaque	Ch. 10, HE2-LAB-05
Audit de mots de passe	Cassage hors ligne autorisé	Ch. 13, HE2-LAB-07
Référentiel ATT&CK	Planifier et mesurer la détection	Ch. 21, HE2-LAB-09
Tableur	Priorisation, calcul de gravité, matrices	Ch. 7, HE2-LAB-10
Laboratoire virtuel	Entraînement en environnement fermé	Ch. 25

★ Attention

Rappel. Aucun de ces outils ne se dirige vers un système réel sans autorisation écrite. En dehors d'une mission mandatée, l'entraînement se fait en laboratoire isolé (Ch. 25).

© MaletYon

C

MODÈLES ET PROCÉDURES

Les modèles ci-dessous reprennent ceux des chapitres, sous une forme prête à l'emploi.

Lettre d'autorisation

Rubrique	Contenu
Parties	Commanditaire et prestataire, signataires habilités
Périmètre	Adresses et systèmes visés (notation CIDR), exclusions
Dates et horaires	Fenêtres autorisées
Règles d'engagement	Actions permises et interdites, mot d'arrêt
Contacts d'urgence	Joignables jour et nuit
Données et preuves	Minimisation, masquage, destruction en fin
Signature	Responsable habilité, date

Fiche de constat

Rubrique	Contenu
Identifiant et titre	T-xx, titre court
Description	La faiblesse, en termes clairs
Preuve	Requête, capture masquée, relevé
Impact	Ce qu'un attaquant en ferait
Gravité	Cotation justifiée (CVSS ou risque métier)
Recommandation	Correction concrète et vérifiable
Détection	Comment voir l'exploitation en production

Procédure de nettoyage de fin de mission

1. Relire le journal de mission : tout ce qui a été créé ou modifié.
2. Supprimer comptes, fichiers, services, tâches créés.
3. Restaurer les configurations modifiées.
4. Faire vérifier la suppression par le client.
5. Consigner le nettoyage dans le rapport.

Plan du rapport

1. Synthèse pour la direction.
2. Contexte et périmètre.
3. Démarche et couverture.
4. Constats détaillés, cotés.
5. Plan de correction priorisé.
6. Annexes : preuves, actions horodatées.

D

TEXTES JURIDIQUES ET NORMATIFS

Seuls les articles lus dans le texte officiel sont cités entre guillemets dans les chapitres. Ce tableau indique où les trouver. Les numéros d'articles non vérifiés ne sont pas reproduits ; on renvoie au texte publié.

Droit camerounais

Texte	Objet	Chapitre
Loi n° 2010/012 du 21 décembre 2010	Cybersécurité et cybercriminalité ; accès et maintien frauduleux	2
Loi n° 2024/017 du 23 décembre 2024	Protection des données à caractère personnel	2

Note

Les articles de ces lois se lisent dans le texte publié au Journal officiel de la République du Cameroun. Le cours ne cite que des articles vérifiés dans ce texte.

Normes et guides internationaux

© *MaletYon*

Référence	Objet	Chapitre
NIST SP 800-115	Guide technique du test de sécurité	4
PTES	Standard d'exécution d'un test d'intrusion	4
OSSTMM 3	Méthodologie de test de sécurité	4
OWASP WSTG	Guide de test des applications web	14
OWASP Top 10	Risques des applications web	14
OWASP API Top 10	Risques des interfaces de programmation	16
OWASP MASVS	Vérification de la sécurité des applications mobiles	16
CIS Controls v8	Mesures de sécurité prioritaires	1
CVSS 3.1 (FIRST)	Notation des vulnérabilités	7
MITRE ATT&CK	Tactiques et techniques des attaquants	4
ISO/IEC 29147	Divulgation de vulnérabilités	24
ISO/IEC 30111	Traitement des vulnérabilités	24
RFC 4120	Kerberos version 5	9
RFC 4795	Résolution de noms locale (LLMNR)	9

E

BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures, avec ce qu'elles apportent. Les références complètes figurent dans la bibliographie du livre.

Partie I · Le cadre

- CIS Controls v8 [2] : la place du test dans un programme de sécurité.
- NIST SP 800-115 [21] : le cadre d'un test de sécurité.
- Lois 2010/012 [12] et 2024/017 [13] : le droit applicable au Cameroun.

Partie II · Reconnaître

- OWASP WSTG [16] : la collecte d'informations sur une application.
- CVSS 3.1 [5], EPSS [6], catalogue KEV [3] : prioriser les vulnérabilités.
- Programmes CVE [23] : identifier les vulnérabilités publiées.

Partie III · Les systèmes

- MITRE ATT&CK [24] : le vocabulaire des techniques.
- RFC 4120 [15] et RFC 4795 [1] : Kerberos et la résolution locale.
- NIST SP 800-63B [7] : les mots de passe.

Partie IV · Les applications

- OWASP Top 10 [17] et API Top 10 [19] : les risques web et API.
- OWASP MASVS [18] : la sécurité mobile.
- CIS Controls v8 [2] : la configuration du nuage.

Partie V · Au-delà

- MITRE ATT&CK [24] : scénarios fondés sur une menace et couverture de détection.

Partie VI · Restituer

- PTES [20] : la phase de restitution.
- ISO/IEC 29147 [9] et 30111 [10] : la divulgation coordonnée.
- T. E. Minka Mi Nguidjoï [14] : le verdict à trois valeurs et la mesure.

F

CONTACTS ET RESSOURCES

Les adresses sont celles des sites institutionnels à la date de rédaction ; à vérifier.

Organisation	Rôle	Site
ANTIC	Régulation de la sécurité électronique au Cameroun	`www.antic.cm`
MINPOSTEL	Tutelle des communications électroniques	`www.minpostel.gov.cm`
OWASP	Guides de test et Top 10	`owasp.org`
MITRE	ATT&CK, CVE	`attack.mitre.org`
FIRST	CVSS, EPSS	`www.first.org`
NIST	Publications SP 800	`www.nist.gov`
CIS	Controls et Benchmarks	`www.cisecurity.org`
ISO	Normes ISO et ISO/IEC	`www.iso.org`

● Note

La plateforme du cours. Les fiches d'auto-évaluation et les dix labs de NDAP SUKULU pour ce cours sont accessibles par le code `SEC4062`.

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] B. Aboba, D. Thaler et L. Esibov, « Link-Local Multicast Name Resolution (LLMNR), » Internet Engineering Task Force, RFC 4795, 2007.

[2] Center for Internet Security, *CIS Critical Security Controls, Version 8*, Center for Internet Security, East Greenbush, NY, 2021.

[3] Cybersecurity and Infrastructure Security Agency, *Known Exploited Vulnerabilities Catalog*, CISA, https://www.cisa.gov/known-exploited-vulnerabilities-catalog, 2024.

[4] W. M. Eddy, « Transmission Control Protocol (TCP), » Internet Engineering Task Force, RFC 9293, 2022.

[5] FIRST, *Common Vulnerability Scoring System version 3.1 : Specification Document*, Forum of Incident Response and Security Teams, 2019.

[6] FIRST, *Exploit Prediction Scoring System (EPSS)*, Forum of Incident Response and Security Teams, https://www.first.org/epss/, 2023.

[7] P. A. Grassi, M. E. Garcia et J. L. Fenton, « Digital Identity Guidelines: Authentication and Lifecycle Management, » National Institute of Standards et Technology, NIST Special Publication 800-63B, 2017.

[8] P. Herzog, *OSSTMM 3 : The Open Source Security Testing Methodology Manual*, ISECOM, 2010.

[9] ISO/IEC, *ISO/IEC 29147:2018 — Information technology — Security techniques — Vulnerability disclosure*, International Organization for Standardization, Genève, 2018.

[10] ISO/IEC, *ISO/IEC 30111:2019 — Information technology — Security techniques — Vulnerability handling processes*, International Organization for Standardization, Genève, 2019.

[11] B. Laurie, A. Langley et E. Kasper, « Certificate Transparency, » Internet Engineering Task Force, RFC 6962, 2013.

[12] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun*, Version anglaise officielle : Law No. 2010/012 of 21 December 2010 relating to cybersecurity and cybercriminality in Cameroon, 21 déc. 2010.

[13] *Loi n° 2024/017 du 23 décembre 2024 régissant la protection des données à caractère personnel au Cameroun*, Articles à lire dans le texte publié au Journal officiel de la République du Cameroun, 23 déc. 2024.

[14] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. adresse : https://hal.science/hal-05701007

[15] C. Neuman, T. Yu, S. Hartman et K. Raeburn, « The Kerberos Network Authentication Service (V5), » Internet Engineering Task Force, RFC 4120, 2005.

[16] OWASP, *Web Security Testing Guide (WSTG)*, OWASP Foundation, Version 4.2, 2020.

[17] OWASP, *OWASP Top 10:2021 : The Ten Most Critical Web Application Security Risks*, OWASP Foundation, 2021.

[18] OWASP, *Mobile Application Security Verification Standard (MASVS)*, OWASP Foundation, 2023.

[19] OWASP, *OWASP API Security Top 10:2023*, OWASP Foundation, 2023.

[20] PTES Team, *The Penetration Testing Execution Standard*, http://www.pentest-standard.org/, Consulté en 2026, 2014.

[21] K. Scarfone, M. Souppaya, A. Cody et A. Orebaugh, « Technical Guide to Information Security Testing and Assessment, » National Institute of Standards et Technology, NIST Special Publication 800-115, 2008.

[22] M. Souppaya et K. Scarfone, « Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology, » National Institute of Standards et Technology, NIST Special Publication 800-40 Rev. 4, 2022.

[23] The MITRE Corporation, *Common Vulnerabilities and Exposures (CVE) Program*, https://www.cve.org/, Consulté en 2026, 2024.

[24] The MITRE Corporation, *MITRE ATT&CK : Adversarial Tactics, Techniques, and Common Knowledge*, https://attack.mitre.org/, Consulté en 2026, 2024.

INDEX

Active Directory, 72

cadres d'exploitation, 61
Charge utile, 60
Contre-test, 158
contrôleurs de domaine, 72
coordonnée, 162
CVSS, 33

drapeaux, 138
droits, 118

Empoisonnement de résolution, 66
Exploit, 60

Faux négatif, 52
Faux positif, 52

graphe, 73

Hacking éthique, 14

Ingénierie sociale, 132
Injection, 106
Interface de programmation, 112

Kerberoasting, 73

Matrice de couverture de détection, 144
MITRE ATT&CK, 32
modèle d'administration par niveaux, 74
Modèle de responsabilité partagée, 118
Mouvement horizontal, 80
Mouvement latéral, 86

OSINT, 40

Point d'accès pirate, 126
point de départ, 15
Portail jumeau, 126
Preuve de concept, 60

Reconnaissance active, 40
Reconnaissance passive, 40
Requête HTTP, 100
Règles d'engagement, 26
Référence directe non contrôlée à un objet, 106
Réponse HTTP, 100

scanner de vulnérabilités, 52
secrets, 118
Session, 100
signature, 66
standard de vérification de la sécurité des applications mobiles, 113

termes clés, vii
Test d'intrusion, 14
test d'intrusion, 4
Top 10, 102
transparence des certificats, 40

Verdict à trois valeurs, 172

Web Security Testing Guide, 100

Élévation de privilèges, 80
Énumération, 46
Équipe rouge, 138
Équipe violette, 139

À propos de ce cours

Tester un système comme un attaquant, avec l'autorisation de son propriétaire, pour qu'il soit mieux défendu : c'est le hacking éthique. Ce cours en enseigne la démarche, le droit, les techniques et la restitution.

Il progresse en six parties, précédées d'un prologue : le cadre du test (droit, règles d'engagement, méthodologies), la reconnaissance, les systèmes et les réseaux (dont Active Directory), les applications et le nuage, les tests au-delà des systèmes (sans fil, ingénierie sociale, équipe rouge), et la restitution (rapport, contre-test, divulgation, mesure).

Chaque notion est ancrée dans les standards internationaux et dans le droit camerounais. Le cours s'adresse aux élèves ingénieurs en génie informatique de l'ENSP Yaoundé et aux professionnels qui exercent comme pentesteurs, auditeurs de sécurité, analystes SOC ou membres d'une équipe rouge, ou comme RSSI. Chaque technique y est présentée avec sa détection et sa parade.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information